PowerScale OneFS

9.13.0.0 Security Configuration Guide

9.13.0.0

December 2025

DELL Technologies

Notes, cautions, and warnings

NOTE: A NOTE indicates important information that helps you make better use of your product.

CAUTION: A CAUTION indicates either potential damage to hardware or loss of data and tells you how to avoid the problem.

WARNING: A WARNING indicates a potential for property damage, personal injury, or death.

Copyright © 2016 - 2025 Dell Inc. All Rights Reserved. Dell Technologies, Dell, and other trademarks are trademarks of Dell Inc. or its subsidiaries. Other trademarks may be trademarks of their respective owners.

Contents

Chapter 1: Preface **7**
Scope of document 7
Document references 7
Security resources 7
Where to get help 8
Additional options for getting help 8
Reporting vulnerabilities 8
Legal disclaimers 8

Chapter 2: Security Quick Reference **9**
Security assumptions 9
Deployment models 9
Security profiles 10

Chapter 3: Product and Subsystem Security **12**
Security controls map 12
Authentication 12
Kerberos authentication 12
Login security settings 13
Authentication types and setup 17
User and credential management 19
Authentication to external systems 23
Authorization 23
General authorization settings 23
RBAC privileges 23
Security privileges 24
Multi-Party Authorization 25
Data Protection Mode 25
Secure Snapshots 25
Network security 26
Network exposure 26
Disable nonessential HTTP services 36
Communication security settings 37
Firewall default settings 37
Protocols 38
FTP security 38
HDFS security 39
HTTP and HTTPS security 39
Apache server and HTTP default configurations 40
NFS security 41
S3 security 41
SMB security 42
Mixed data-access protocol environments 44
Data security 44

Data access settings 44
Data-at-rest encryption..... 44
Data sanitization 44
Data recovery..... 44
Key stores..... 45
Cryptography..... 46
Cryptographic options..... 47
Certificate management 50
Regulatory information..... 50
Auditing and logging..... 51
Logs..... 51
Log management..... 52
Log protection..... 52
Logging format..... 52
Events and alerts..... 52
Physical security..... 53
Security of the data center..... 53
Physical ports on nodes..... 53
Statement of volatility..... 53
Serviceability..... 53
Dell Technologies connectivity services..... 54
Security checks and verifications 54
Maintenance Aids..... 55
Dell Technologies Technical Advisories, Security Advisories, and OneFS patches..... 56
Authenticity and integrity..... 57
Package authenticity 57
Verifying packages and manifests..... 57
Using UEFI secure boot..... 58
Checking MD5 hash files 58
Restricted CLI..... 58
Session description..... 59
Limitations..... 60
Audit logs and message types..... 60
Enable and disable global restricted shell 61
Assign shell to user profile..... 61
Emergency exit from a Restricted CLI session 61
View log files..... 62
isi_log_access..... 64

Chapter 4: United States Federal and DoD Standards and Compliance..... 65
SRG and STIG Compliance..... 65
CAT 1 security requirement..... 65
Onsite customer deployment guidance..... 66
Upgrading a previously hardened cluster to OneFS 9.5.0.0 or later..... 66
IPv6 defaults..... 66
Security hardening module..... 67
Licensing..... 67
Hardening concepts..... 67
Using the STIG profile..... 69
Run hardening compliance reports..... 72

Recurring security checks 75

Chapter 5: FIPS Standards and Compliance 77
FIPS 140-2 compliance 77
Enable FIPS mode 77
Required: Update password hash scheme 78
Disable FIPS mode 78
Verify and reset FIPS mode 78
Certified cryptographic modules 79
FIPS and SSO 79

Chapter 6: Security Best Practices 80
Overview 80
Persistence of security settings 80
General cluster security best practices 81
Protect /ifs and /ifs/data 81
Set BIOS password for node physical security 82
Set iDRAC user passwords 83
Disable USB ports across the cluster 83
Enable and disable USB ports on individual nodes 83
Create a login message 85
Change password on backend switches 86
UEFI secure boot 87
Verify install package authenticity 90
Set a timeout for idle CLI sessions (CLI) 91
Set a timeout for idle SSH sessions 92
Forward audited events to remote server 93
External to cluster firewall security 93
Disable OneFS services that are not in use 94
Configure WORM directories using SmartLock 94
Back up cluster data 95
Use NTP time 95
Login, authentication, and privileges best practices 96
Restrict root logins to the cluster 96
Use Root Lockdown Mode 96
Use RBAC accounts instead of root 97
Disable the root account for SSH sessions 97
Privilege elevation: Assign select root-level privileges to nonroot users 97
Restrict authentication by external providers 99
Use secure connections to LDAP server 100
Set password policy 102
SNMP security best practices 102
Use SNMPv3 for cluster monitoring 103
Keep SNMP disabled except for SNMP cluster monitoring 103
Change default community string for SNMPv2 103
SSH security best practices 103
Restrict SSH access to specific users and groups 104
Disable root SSH access to the cluster 104
Manage SSH host keys 105

Data-access protocols best practices....105
Use a trusted network to protect files and authentication credentials that are sent in cleartext....105
Use compensating controls to protect authentication credentials that are sent in cleartext....105
Use compensating controls to protect files that are sent in cleartext....106
Initial Sequence Numbers (ISNs) through TCP connections....106
FTP best practices....106
HDFS best practices....106
HTTP file protocol best practices....107
NFS best practices....107
SMB best practices....109
SMB signing....110
Web interface security best practices....112
Replace the TLS certificate....112
Remove persistent older versions of TLS....112
CloudPools best practices....112
Restricting access to untrusted users....112

Chapter 7: Miscellaneous Configuration and Management Elements 113
Preventing malware....113
Specialized security devices....113
Intel microarchitectural mitigations....114

Chapter 8: Glossary....117
Terminology....117

Appendix A: Links to security standards 119

1

Preface

This document describes the security features in Dell Technologies PowerScale OneFS. It describes how to modify configurations to maximize the security posture of OneFS in your environment. It also explains the expectations that Dell Technologies has of the environment in which you are deploying OneFS. The Dell Technologies capabilities for secure remote and on-site serviceability are also described.

Topics:

- Scope of document
- Document references
- Security resources
- Where to get help
- Reporting vulnerabilities
- Legal disclaimers

Scope of document

This guide provides an overview of the security configuration controls and settings available in PowerScale OneFS. This guide is intended to help facilitate secure deployment, usage, and maintenance of the software and hardware used in PowerScale clusters.

Document references

The complete documentation set for OneFS is available online here.

Security resources

Resources include Dell Security Advisories (DSAs), Common Vulnerabilities and Exposures (CVEs), and a list of false positives.

Table 1. Security resources from Dell

Type	Description
DSAs and CVEs	Dell Security Advisories (DSAs) notify customers about potential security vulnerabilities and their remedies for Dell Technologies products. The advisories include specific details about an issue and instructions to help prevent or alleviate that security exposure. Common Vulnerabilities and Exposures (CVEs) identify publicly known security concerns. A DSA can address one or more CVEs. All PowerScale and OneFS DSAs, together with the CVEs that they address, are listed on the Product Advisories tab on the Dell support site.
False positives	It is possible for a security scan to incorrectly identify a CVE as affecting a Dell Technologies product. CVEs in this category are termed false positives. False positives are listed in Dell Technologies OneFS, SDEdge, DataIQ, and InsightIQ False Positive Security Vulnerabilities.

Register for advisory notifications

On the Product Advisories tab on the Dell support site, you can register to receive email notifications of DSAs.

1. If you are not signed on to the support site, click **Sign In** on the banner and provide your Dell account information.

2. Click **Contact Support** on the right.
3. Click **Notifications**.
4. Click the **Dell EMC Security Advisories** button.

Where to get help

The Dell Technologies Support site contains important information about products and services including drivers, installation packages, product documentation, knowledge base articles, and advisories.

A valid support contract and account might be required to access all the available information about a specific Dell Technologies product or service.

Additional options for getting help

This section contains resources for getting answers to questions about PowerScale products.

Dell Technologies Support	• Contact Technical Support
Telephone support	• United States: 1-800-SVC-4EMC (1-800-782-4362) • Canada: 1-800-543-4782 • Worldwide: 1-312-725-5401 • Local phone numbers for a specific country or region are available at Contact Technical Support.
PowerScale OneFS Documentation Info Hubs	• PowerScale OneFS Info Hubs
Dell Knowledge Base (KB) articles	KB articles are available on the Dell Technologies support site.

Reporting vulnerabilities

Dell Technologies takes reports of potential vulnerabilities in our products seriously. For the latest on how to report a security issue to Dell Technologies, see the Dell Vulnerability Response Policy on the Dell.com site.

Legal disclaimers

This document might contain language from third-party content that is not under Dell Technologies control and is not consistent with the current guidelines for Dell Technologies content. When the third-party content changes, this document is revised.

2

Security Quick Reference

Topics:

- Security assumptions
- Deployment models
- Security profiles

Security assumptions

A PowerScale cluster is only one component of a complex installation. The cluster co-exists with the surrounding physical and electronic environment. Customers must develop and maintain comprehensive security policies for the entire environment.

Physical access and backend network access are equivalent to admin access and should be protected accordingly.

Dell Technologies assumes that you implemented the following security controls before deploying the PowerScale cluster.

Table 2. Assumed security controls

Security control	Description
Physical security system of unit room facilities	Physical security uses locks, guards, cameras, and processes to: ● Prevent unauthorized direct access to PowerScale equipment. ● Monitor for intrusions. ● Report violations.
Comprehensive network security	Network security uses network software to block unauthorized users, possibly detect intrusions, and generate alerts on violations. The customer defines and controls detailed implementation requirements.
Monitoring of system-related controls	Security administrators must plan and enforce policies that control which users have privileges to perform which actions. OneFS provides the software that implements those policies. The software enforces policies that define: ● Data and program access ● A secure organizational structure for managing login and access rights ● Change-control policies that prevent unauthorized modifications to programs.
Service continuity	Service continuity includes plans to ensure that critical services and processes remain operational during a disaster or data breach. Service continuity for PowerScale clusters should be part of an overall and dedicated business continuity and disaster recovery plan that the customer defines and controls. OneFS offers many ways to support service continuity, including SyncIQ or remote backups to a DataDomain/Disk Library appliance.

Deployment models

OneFS is a scale-out file system offering a multiprotocol file server. OneFS supports the following security-related deployment models:

- General business
- Security hardening
- SmartLock
- Root Lockdown Mode

General business

The default OneFS deployment includes a solid set of security controls. The main purpose of this guide is to describe those security controls and to identify which of them are configurable.

For additional protection, the following security options are available.

Security hardening

The United States Federal Department of Defense (DoD) publishes Security Requirements Guides (SRGs) and Security Technical Implementation Guides (STIGs). These guides describe the security controls that are required for DoD implementations. Many of the STIG guidelines are industry-accepted best practices and are incorporated into OneFS as default behavior. A OneFS cluster benefits from those controls by default.

A subset of STIG guidelines is not implemented by default. For deployments that require full STIG compliance, the Security Hardening module is available. For information about STIG compliance and the OneFS Security Hardening module, see United States Federal and DoD Standards and Compliance.

The Security Hardening module also supports Federal Information Processing Standard (FIPS) 140-2 compliance. For information about FIPS cryptography and FIPS compliance, see FIPS Standards and Compliance.

SmartLock

The SmartLock software module protects files on a PowerScale cluster from being modified, overwritten, or deleted. To protect files in this manner, you must activate a SmartLock license.

SmartLock is deployed in one of these modes:

- Compliance mode—SmartLock compliance mode lets you protect data in compliance with U.S. Securities and Exchange Commission (SEC) rule 17a-4.
- Enterprise mode—SmartLock enterprise mode does not conform to SEC regulations. However, it lets you create SmartLock directories and apply SmartLock controls to protect files so that they cannot be rewritten or erased.

With SmartLock, you can identify a directory in OneFS as a write-once, read-many (WORM) domain. Files in a WORM domain may be modified as needed until they are committed to a WORM state. After a file is committed, it is nonerasable and nonmodifiable until a user-configurable retention period expires. When the retention period expires, the file is erasable but not modifiable.

In SmartLock Enterprise mode, a privileged delete feature exists that allows an administrator to delete, but not modify, a file before its specified retention expiration date. SmartLock Compliance domains do not allow for privileged delete.

For information about SmartLock, see the "File retention with SmartLock" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Root Lockdown Mode

Root Lockdown Mode (RLM) reduces the risks that are associated with using the root account. This feature ensures that protections that are enabled by other features cannot be overridden by the root account, by disabling and preventing access to the root account.

Both Hardening and SmartLock licenses are required to apply RLM. RLM adds the root-lockdown hardening profile which can be applied or disabled. The STIG and root-lockdown hardening profiles cannot be applied to one cluster simultaneously.

NOTE: RLM cannot be enabled if the cluster has previously been configured to be in Compliance Mode.

For best practices, see Use Root Lockdown Mode. For instructions on applying RLM, see the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*

Security profiles

Security profiles are representations of the product security posture through specific configuration setting combinations.

OneFS has a default security profile and a STIG hardening profile.

- Default profile—This profile is used with the general business and SmartLock deployment models. Dell Technologies considers STIG recommendations during all security development life cycles. Many STIG recommendations make sense for any robust enterprise system and are implemented as default settings in the general product.
- Hardening profile—The STIG hardening profile changes the cluster configuration so that it is compliant with United States federal government Approved Product List (APL) requirements. See United States Federal and DoD Standards and Compliance for more information.

3

Product and Subsystem Security

Topics:

- Security controls map
- Authentication
- Authorization
- Network security
- Protocols
- Data security
- Cryptography
- Auditing and logging
- Physical security
- Serviceability
- Authenticity and integrity
- Restricted CLI

Security controls map

The following diagram provides an overview of the various security controls that are available on PowerScale clusters.

Figure 1. Security controls map

Authentication

For general information about authentication not covered in this guide, see the "Authentication" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Kerberos authentication

Kerberos is a network authentication provider that negotiates encryption tickets for securing a connection. OneFS supports Microsoft Kerberos and MIT Kerberos authentication providers on a cluster. If you configure an Active Directory provider, support for Microsoft Kerberos authentication is provided automatically. MIT Kerberos works independently of Active Directory.

For MIT Kerberos authentication, you define an administrative domain, also called a realm. Within this realm, an authentication server has the authority to authenticate a user, host, or service; the server can resolve to either IPv4 or IPv6 addresses. You can optionally define a Kerberos domain to allow additional domain extensions to be associated with a realm.

The authentication server in a Kerberos environment is called the Key Distribution Center (KDC) and distributes encrypted tickets. When a user authenticates with an MIT Kerberos provider within a realm, a cryptographic ticket-granting ticket (TGT) is created. The TGT enables user access to a service principal name (SPN).

Each MIT Kerberos provider is associated with a `groupnet`. The `groupnet` is a top-level networking container that manages hostname resolution against DNS nameservers. It contains subnets and IP address pools. The `groupnet` specifies which networking properties the Kerberos provider uses when it communicates with external servers. The `groupnet` associated with the Kerberos provider cannot be changed. Instead, delete the Kerberos provider and create it again with the new `groupnet` association.

You can add an MIT Kerberos provider to an access zone as an authentication method for clients connecting through the access zone. An access zone may include at most one MIT Kerberos provider. The access zone and the Kerberos provider must reference the same `groupnet`. You can discontinue authentication through an MIT Kerberos provider by removing the provider from associated access zones.

NOTE: Do not use the NULL account with Kerberos authentication. Using the NULL account for Kerberos authentication can cause issues.

Session ticket lifetimes

The duration of connections that are authenticated using Kerberos is based on the Kerberos ticket lifetime settings. These settings are controlled on the Kerberos Distribution Center (KDC). For information about configuring maximum lifetimes, see the appropriate provider documentation as shown in the following table.

SMB only checks ticket validity during initial authentication. As a result, SMB connections may remain valid and in use after Kerberos tickets expire. For information about immediately closing active SMB sessions, contact Dell Technologies Support.

Table 3. Provider Types

Provider type	Documentation for configuring maximum lifetimes
Microsoft Kerberos with Active Directory Domain Services	See the following Microsoft documentation: • Maximum lifetime for service ticket • Maximum lifetime for user ticket
MIT Kerberos	See the MIT Kerberos documentation for configuring the `kdc.conf` file. The `max_life` setting in `kdc.conf` controls the lifetime duration.

Login security settings

Login security includes login banners (usually presenting legal disclaimers and other usage and privacy policies), failed login behavior, and account lockout options.

Login banner configuration

Login banners can display critical system information and proper usage, and they can list restrictions and privacy policies. If legal information is relevant, such as enforcement and discipline upon failure, you can display those notices here also.

The banner contents are displayed before a user logs in.

The hardening process creates a banner file. For nonhardened systems, cluster administrators can create a root-owned banner file.

Table 4. Login banner creation

Choices	Procedure
To create a login banner in the web administration interface:	1. On the OneFS web administration interface, click **Cluster Management** > **General Settings** > **Cluster Identity**. 2. In the **Login Message** area, type a title in the **Message Title** field and a message in the **Cluster Description** field. 3. Click **Save Changes**.

To create a login banner on the command line:	1. Use the following command:
	`isi cluster identity modify --motd "This is an example of configuring a MOTD. Add literal newlines to get new lines "`
	2. To view the current MOTD:
	`isi cluster identity view`

Failed login behavior

The following table describes the behavior of OneFS when authentication is unsuccessful.

Table 5. Failed login behavior

Failed login scenario	Expected behavior
Behavior when the number of failed login attempts exceeds the threshold.	Prevents local provider and file provider logins until a given duration is exceeded.

The lockout-window period over which failed attempts are counted; otherwise the count resets when the window expires.	The default lockout-window is 5 minutes. A larger value makes the user wait longer before the failed-attempt counters are reset. You can configure the default lockout-window for the local provider using the following command:
	`isi auth local modify <provider> --lockout-window <duration>`
	You can configure the default lockout-window for the file provider using the following command:
	`isi auth file modify <provider> --lockout-window <duration>`

The number of failed login attempts that are allowed before triggering the exceeded behavior.	Configurable in the local provider using the following command:
	`isi auth local modify --lockout-threshold=<count> <provider>`
	You can configure the parity for the file provider using the following command:
	`isi auth file modify --lockout-threshold=<count> <provider>`

Delay between login attempts	Configurable globally using the following command: `isi auth settings global modify --failed-login-delay-time <duration>` Where `<duration>` is the amount of time that a user must wait before attempting to sign in after a failed attempt. For example, if `<duration>` is `10s` , a root user logging into an SSH session who receives a failed password error must wait 10 seconds to try again. Where `<duration>` is: ● An integer without any modifier is interpreted as seconds and is limited to 69.4 days. ● An integer followed by one of `[ s | m | H | D | W | M ]` to indicate the unit of time. For example: `8H`. The maximum duration time is 1M or its equivalent.
Account lockout duration	Configurable in the local provider using the following command: `isi auth local modify --lockout-duration=<duration> <provider>` Where `<duration>` is: ● An integer without any modifier is interpreted as seconds and is limited to 69.4 days. ● An integer followed by one of `[ s | m | H | D | W | M ]` to indicate the unit of time. For example: `8H`. The maximum duration time is 1M or its equivalent. Configurable in file provider using the following command: `isi auth local modify --lockout-duration=<duration> <provider>`
Privileges required to resolve account lockout.	An administrator requires read/write `ISI_PRIV_AUTH` privileges to configure the lockout behavior of the local provider.

Table 5. Failed login behavior (continued)

Failed login scenario	Expected behavior
	NOTE: This feature only affects the local provider. Other authentication providers do not have this feature.
Event logging	Failed login attempts are logged to `/var/log/messages`.

Emergency user lockout

Administrators can block access to the system using the following features.

The best practice for locking out users is to disable authentication, which prevents new logins.

For methods to terminate active user sessions, see "Terminate active user sessions" below.

Table 6. Emergency user lockout

Lockout scenario	Details
User or role that can generate an emergency user lockout event.	You can disable a user or remove a privilege, which requires a read/write privilege of `ISI_PRIV_AUTH`. This action does not log out a user who is logged in.
User or role that can undo an emergency user lockout event.	This action is similar to the above scenario. An admin with read/write `ISI_PRIV_AUTH` can enable a user.
Description of emergency user lockout behavior	Prevents new logins. For methods to terminate active user sessions, see "Terminate active user sessions" below.
How to lock out a specific user.	`isi auth users modify <user> --enabled=false`

How to lock out all users.	Disabling authentication for a provider prevents new logins from that provider. You can also disable login privileges by role.
	To disable logins by provider, use the following commands. All providers in the authentication zone must be set individually.
	`isi auth local modify --authentication=false <provider>`
	`isi auth file modify --authentication=false <provider>`
	`isi auth ads modify --authentication=false <provider>`
	`isi auth ldap modify --authentication=false <provider>`
	`isi auth nis modify --authentication=false <provider>`
	To disable logins by role, you remove a privilege from a role. For example, the following command prevents users holding a specific role from logging in using SSH.
	`isi auth roles modify <role> --remove-priv \ ISI_PRIV_LOGIN_SSH`

How to reenable access for a specific user or all users to the system.	Reenable a specific user: `isi auth users modify <user> --enabled=true`

Terminate active user sessions

Several protocols in OneFS use the concept of a session. These instructions describe how an administrator can immediately terminate an in-use session.

NOTE: Terminating a session that is transmitting or accessing data has potential risks for data loss or corruption.

Terminate an FTP session

FTP performs authentication at initial connection setup. FTP caches those credentials during the connection.

NOTE: Forcefully disconnecting an FTP connection could result in data loss or corruption for any files that the FTP client is accessing.

1. Identify the IP address and user of the FTP client that must be disconnected.
2. Disable the user. Disabling the user ensures that they cannot authenticate again after the connection is terminated.

```
isi auth users modify --enabled=false <user>
```

3. Contact Dell Technologies Support for next steps. The steps require root or account of last resort access.

Terminate an HDFS session

Dell Technologies recommends requiring Kerberos authentication for HDFS. Kerberos uses session tickets to grant access to HDFS on OneFS. There are configurable timeouts in Kerberos that control how long a session ticket remains valid. For information about configuring Kerberos session ticket lifetime values, see Kerberos authentication.

Terminate an NFS session

Dell Technologies recommends requiring Kerberos authentication for NFS. Kerberos uses session tickets to grant access to NFS on OneFS. There are configurable timeouts in Kerberos that control how long a session ticket remains valid. For information about configuring Kerberos session ticket lifetime values, see Kerberos authentication.

Terminate an S3 session

S3 continually revalidates authorization with a short cache lifetime. Disabling or deleting a user prevents any further requests that the user sends from succeeding.

Terminate an SMB session

SMB sessions perform authentication during the initial connection setup. The session caches these credentials during the session.

NOTE: Forcefully disconnecting an SMB session from OneFS could cause data loss or data corruption for any files that are open by the SMB client. Ensure that you balance the risk of data corruption against the risk of continued access to the cluster from this session.

To disconnect an active user on OneFS:

1. Identify the client or user that you want to disconnect from OneFS. Ensure that this user is disabled in the appropriate authentication provider.
2. Find the node that contains the session that you want to disconnect.

   Run the `isi smb sessions list` command on every node in the cluster. A single client may have multiple connections to multiple nodes.

```
onefs-1# isi_for_array isi smb sessions list

onefs-1: Lnn Computer User
onefs-1: -----------------
onefs-1: -----------------
onefs-1: Total: 0
onefs-3: Lnn  Computer       User
onefs-3: ---------------------------------------
onefs-3: 3    192.168.187.49 onefs\joe
onefs-3: ---------------------------------------
onefs-3: Total: 1
onefs-2: Lnn Computer User
onefs-2: -----------------
```

```
onefs-2: -----------------
onefs-2: Total: 0
```

3. Using the information provided by the `isi smb sessions list` command, identify the node (`Lnn`, `Computer`, and `User` of the session to disconnect.
4. Log in to the node that you identified.
5. Forcibly delete the SMB client session by using the `isi smb sessions delete` command.

```
onefs-3# isi smb sessions delete 192.168.187.49 --user-name onefs\\joe
Are you sure you want to disconnect SMB sessions for user=onefs\joe
computer=192.168.187.49? (yes/[no]): yes
```

An alternate command that has the same result is: onefs-3# isi smb sessions delete-user onefs\\joe --computer-name 192.168.187.49
Are you sure you want to disconnect SMB sessions for user=onefs\joe computer=192.168.187.49? (yes/[no]): yes

If the client is using the recommended Kerberos authentication and the Kerberos service ticket remains valid, the client may continue connecting to SMB on OneFS. For information about configuring Kerberos service ticket lifetimes, see Kerberos authentication.

Terminate an SSH session

SSH sessions perform authentication during the initial connection. The session caches privileges during the session.

NOTE: Forcefully disconnecting an SSH session from OneFS could cause unintended behavior.

To disconnect an SSH connection from the cluster, follow these steps.

1. Identify the user for the SSH connection that you want to disconnect.
2. Disable the user. Disabling the user ensures that they cannot authenticate again after the connection is terminated.

```
isi auth users modify --enabled=false <user>
```

3. Contact Dell Technologies Support for next steps. The steps require root or account of last resort access.

Authentication types and setup

Configure the authentication types and different possible sources for the system.

For general information about Authentication types and setup, see the "Authentication" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Configuring local authentication sources

For information about configuring local authentication sources, see the Managing local users and groups section in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Configuring Active Directory

For information about configuring Active Directory, see the "Authentication" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Certificate and key-based authentication

See the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

- For information about client and server authentication using TLS certificates, see the Certificates section in the "General cluster administration" chapter.
- For information about the supported key-based authentication methods, see the "Authentication" chapter.

Single Sign-on (SSO) security

OneFS supports single sign-on (SSO) authentication to the WebUi using a third-party system as the SSO Identity Provider.

The following two components work together to provide SSO authentication.

- The Identity Provider (IdP) performs user authentication. In OneFS, the verified IdP is Active Directory Federation Services (ADFS). Other IdPs may work.
- The Service Provider (SP) forwards an authentication request to the IdP. In the OneFS SSO solution, the SP is OneFS.

SSO is implemented in access zones. You can enable or disable SSO separately in each access zone, and each access zone must be configured with an IdP. The IdP may be the same or different for each access zone. Each access zone can have only one IdP.

SAML

Communications between OneFS and the IdP (ADFS) occur using SAML. All SAML protocol messages go through the "/session/1/" endpoint. The isi_saml_d daemon interacts with other processes.

For more information about configuring the SAML, see the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Certificates

By default, OneFS generates a 2048-bit RSA signing key and certificate that expires after two years and three months. The admin can change the bits and lifetime of the certificate and regenerate the signing key and certificate.

The CELOG event SW_SSO_CONFIG_CERT_EXPIRING is raised 31 days before a certificate expires. The event message includes whether it is the IDP or SP certificate that is expiring. The message includes the affected access zone.

The OneFS CLI and WebUI interfaces generate the Service Provider certificate for the trust between OneFS and the IdP.

If the signing certificate expires, OneFS disables SSO. An authorized administrator can renew an expired certificate.

1. On the WebUI, go to **Access** > **Authentication providers** > **SSO** > ***<access-zone>***.
2. Click the link that appears under the **SSO Enable/Disable** switch.

For more information about managing, replacing, and renewing certificates, see the Certificates section in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

SSO and the STIG hardening profile

The STIG hardening profile requires SSO for all users. When SSO login is required, all users must have ISI_PRIV_LOGIN_PAPI privilege and log in using SSO.

The hardening profile checks that each access zone has SSO enabled and that each zone has an IDP and SP configured for it.

SSO with MFA

To combine single sign-on with multifactor authentication (MFA), you must configure the MFA feature in the IdP, rather than in OneFS.

CAC/PIV authentication

OneFS supports authentication to the cluster over SSH using a Common Access Card or Personal Identity Verification (CAC/PIV) card.

When a user logs in, the cluster verifies that the user possesses a key that is signed by the Certificate Authority (CA). The user must have a x509 compatible SSH client such as SecureCRT or pkix-ssh. Each OneFS node ships with pkix-ssh as the default SSH client.

For more information about configuring CAC/PIV for authentication, see the *PowerScale OneFS 9.13.0.0 Web Administration Guide*.

Multifactor authentication

See the Multifactor authentication section in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Other authentication sources

OneFS authentication providers are:

- ADS
- Duo
- File
- KRB5
- LDAP
- Local
- NIS

For information about configuring these authentication sources, see the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Unauthenticated interfaces

The following interfaces do not require authentication for access.

- LCD front panel and buttons
- File over HTTP without Basic authentication, and not using RAN
- SNMPv1
- Using syslog to remote server
- Anonymous FTP
- Joining to the cluster
- SyncIQ, if configured without authentication. SyncIQ supports authentication.

NOTE: Activities that are related to the LCD front-panel and cluster joining require physical access. The others are described in appropriate chapters in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Selecting authentication sources

For general information about selecting authentication sources, see the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

User and credential management

Preloaded accounts

OneFS includes preloaded accounts. Most preloaded accounts are for internal system usage and are not available for user logins.

The table below lists the preloaded accounts and provides the following additional information:

- **Username**—FreeBSD provides some predefined accounts. OneFS hides some of the FreeBSD accounts using the `isi auth` interface. OneFS defines a few additional accounts.
- **Login enabled**—Indicates whether the account is active and usable for user logins by default.

  NOTE: Do not enable inactive accounts unless instructed to do so by Dell Technologies support.

- **Not listable**—Indicates whether `isi auth user list` lists the account. An x means that the account is not listable.
- **Not modifiable**—Indicates whether you can change the underlying properties of the account, such as the environment or home directory. An x means that the account is not modifiable.

Table 7. Preloaded accounts

Username	Login enabled	Not listable	Not modifiable
`root`	Yes	--	--
`daemon`	No	x	x
`operator`	No	x	x
`bin`	No	x	x
`tty`	No	x	x
`kmem`	No	x	x
`news`	No	x	x
`man`	No	x	x
`Guest` The SMB guest account is disabled by default. Do not enable unless directed to do so by Dell Technologies Support.	No	--	--
`admin` PowerScale UI Administrator	Yes	--	--
`compadmin` PowerScale SmartLock Compliance Administrator	Yes	--	--
`remotesupport` Remote Support user	No	--	--
`ese` Internal account used by Dell Technologies connectivity services to communicate with PAPI. No login is permitted.	No	--	--
`ftp`	No	--	--
`insightiq`	No	--	--
`isdmgmt`	No	--	--
`sshd`	No	x	x
`smmsp`	No	x	x
`mailnull`	No	x	x
`bind`	No	x	x
`unbound`	No	x	x
`proxy`	No	x	x
`_pflogd`	No	x	x
`_dhcp`	No	x	x
`uucp`	No	x	x
`pop`	No	x	x
`auditdistd`	No	x	x
`www`	No	--	--

Table 7. Preloaded accounts (continued)

Username	Login enabled	Not listable	Not modifiable
_ypldap	No	x	x
hast	No	x	x
_lldpd	No	x	x
nobody	No	--	--
everyone - while the everyone user is technically not unlistable or unmodifiable, the unfindable setting is set by default for this user.	No	--	--
null	No	x	x
group	No	x	x
git_daemon	No	--	--
ntpd	No	x	x

Table 8. Predefined groups

Username	Not listable	Not modifiable
wheel	--	--
admin	--	--
remotesupport	--	--
ese	--	--
ftp	--	--
guest	--	--
video	--	--
ifs	--	--
ntpd	x	x
_ypldap	x	x
_lldpd	x	x
everyone - while the everyone group is technically not unlistable or unmodifiable, the unfindable setting is set by default for this group.	--	--
git_daemon	--	--
Administrators	--	--
Users	--	--
Guests	--	--
Backup Operators	--	--
Isilon Users	--	--
daemon	x	x
kmem	x	x
sys	x	x
tty	x	x
operator	x	x

Table 8. Predefined groups (continued)

Username	Not listable	Not modifiable
mail	x	x
bin	x	x
news	x	x
man	x	x
staff	x	x
sshd	x	x
smmsp	x	x
mailnull	x	x
bind	x	x
proxy	x	x
authpf	x	x
_pflogd	x	x
_dhcp	x	x
uucp	x	x
dialer	x	x
network	x	x
audit	x	x
www	x	x
nogroup	x	x
null	x	x
insightiq	x	x
isdmgmt	x	x
unbound	x	x
hast	x	x
nobody	--	x

Disable local accounts

You can disable a local account. This action does not remove the home directory for the user account.

Delete the home directory of the user account to avoid inadvertently exposing data to an unauthorized account that uses the same UID and GID. Delete a home directory using the `rm` or `rmdir` commands.

For information about creating, disabling, deleting, and modifying local accounts, see the section "Managing local users and groups" in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Managing credentials

For information about managing credentials, see the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Securing credentials

For information about securing credentials, see the File provider section in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Password complexity

For information about password complexity, see the Managing local users or groups section in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Authentication to external systems

Configure OneFS to communicate with and authenticate to external systems.

Remote component authentication

OneFS can connect to an AD domain or an LDAP server.

Connection requires the external component usernames and passwords that have required privileges.

- For AD configuration, you need a username with Domain Admin Privileges.
- For LDAP, you need the username and password for an LDAP account that can authenticate and view all accounts.

For configuration information to connect and authenticate to these components, see the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Authorization

Authorization controls which actions a user is allowed to perform. Authorization is a critical component of any security model for OneFS.

In addition to general settings, OneFS includes Role-Based Access Control (RBAC).

General authorization settings

A new user has a clean directory and some UNIX and SMB permissions on various files throughout the system. In general, user access must be explicitly granted. UNIX permissions and SMB ACLs can grant users `read`, `write`, and `execute` permissions on specific files. All other access is granted through RBAC privileges.

Regarding processes, most processes run as root. By default, only root has access to act directly on those processes. However, RBAC can allow nonroot users to explicitly act on components that they otherwise would not be allowed to access.

NOTE: Dell Technologies recommends using RBAC to fine-tune access to needed components per user, as opposed to granting root-level access to many users.

For details about authorization and RBAC in particular, see the "Administrative Roles and Privileges" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

RBAC privileges

Role-Based Access Control (RBAC) assigns privileges to users through roles.

NOTE: OneFS RBAC is session-based. If roles are changed while a user is logged in, the new assignments do not take effect until the user logs out and logs back in.

OneFS supports a hierarchy of privileges. Broad-reaching privileges are intended for administrators. Granular privileges can restrict user access to a specific feature set, a specific subfeature, or even specific attributes within a feature.

For information about RBAC and privileges, including default roles, configuring roles with privileges, and role mapping, see the "Administrative Roles and Privileges" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* and the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Security privileges

The following table describes the privileges and subprivileges that allow users to assign privileges to others. Subprivileges inherit their permission type from their parent privilege. Permission types are No permission (-), Read (r), Execute (x), and Write (w). The permission that is listed for each privilege is the highest permission allowed.

Table 9. Security privileges

Privilege or Subprivilege	Description	Permission
ISI_PRIV_AUTH	Configure external authentication providers, including root-level accounts.	Write
ISI_PRIV_AUTH_GROUPS	User groups from authentication provider.	Write
ISI_PRIV_AUTH_PROVIDERS	Configure authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_ADS	Configure ADS authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_FILE	Configure file authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_KRB5	Configure Kerberos authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_LDAP	Configure LDAP authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_LOCAL	Configure local authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_NIS	Configure NIS authentication providers.	Write
ISI_PRIV_AUTH_PROVIDERS_SSO	Configure SSO authentication providers.	Write
ISI_PRIV_AUTH_RULES	User-mapping rules.	Write
ISI_PRIV_AUTH_SETTINGS_ACLS	Configure ACL policy settings.	Write
ISI_PRIV_AUTH_SETTINGS_GLOBAL	Configure global authentication settings.	Write
ISI_PRIV_AUTH_SETTINGS_KRB5	Configure Kerberos settings.	Write
ISI_PRIV_AUTH_USERS	Users from authentication providers.	Write
ISI_PRIV_AUTH_ZONES	Configure access zones.	Write
ISI_PRIV_HARDENING	Used for the Configurable Hardening Engine.	Write
ISI_PRIV_RESTRICTED_AUTH	Find and list users, set user passwords, unlock user accounts, and add or remove users and groups. Administrators with this privilege can modify only users and groups that have the same or less privilege.	Write
ISI_PRIV_RESTRICTED_AUTH_GROUPS	Configure groups with the same or less privilege.	Write
ISI_PRIV_RESTRICTED_AUTH_USERS	Configure users with the same or less privilege.	Write
ISI_PRIV_RESTRICTED_ROLE	Configure roles with the same or lesser privileges.	Write
ISI_PRIV_ROLE	Create roles and assign privileges, including root-level accounts.	Write

Table 9. Security privileges (continued)

Privilege or Subprivilege	Description	Permission
ISI_PRIV_IFS_BYPASS_RETENTION	Allow users to reduce lock retention of objects in Object Lock-enabled buckets and reduce bucket retention in Bucket Lock-enabled buckets.	Read

Multi-Party Authorization

Multi-Party Authorization (MPA) provides an additional layer of protection by requiring administrative approval to perform certain privileged actions. Enabling MPA minimizes the risk of system damage stemming from a malicious attempt or an accident.

When enabled, all predefined privileged actions require approval from dedicated approval administrative accounts before the action can be performed. Once MPA has been enabled, it cannot be disabled. MPA is not supported in compliance mode.

In order to enable MPA, a minimum of two users must be registered as the Approval Administrators in the System zone. The ApprovalAdmin role has the `ISI_PRIV_MPA_APPROVAL` privilege which allows for all MPA approval operations. An approver can approve or reject any MPA requests submitted by users, but no single user or approver can approve its own request.

Any authorized user can create an MPA request through the command-line interface, the API, or the web administration interface. The `ISI_PRIV_MPA_REQUEST` privilege is required for manual creation. Also, if a user attempts to perform one of the privileged actions, an MPA request is automatically created.

There is no notification for requests created; Approval Admins must check the dashboard to review and act on requests.

See the *PowerScale OneFS 9.13.0.0 Web Administration Guide* for more information.

Data Protection Mode

When S3 and Multi-Party Authorization (MPA) are enabled, Data Protection Mode (DPM) is available. DPM relies on MPA to restrict specific privileged actions from being performed without having proper approval permission.

The following actions are privileged and require approval from an Approval Admin before they can be performed. For more information about MPA, see *PowerScale OneFS 9.13.0.0 Web Administration Guide*.

Table 10. Data Protection Mode privileged actions

Component	Action	Description
S3	Reduce immutable bucket retention	Reduction in bucket retention for an immutable bucket.
S3	Modify server access logging configuration	Changing the configuration of access logging for a bucket.
Platform	Reduce immutable bucket retention	Reduction in bucket retention for an immutable bucket.
Platform	Modify server access logging configuration	Changing the configuration of access logging for a bucket.

Secure Snapshots

Secure Snapshots relies on Multi-Party Authorization (MPA) to restrict specific privileged actions from being performed without having proper approval permission.

The following actions are privileged and require approval from an Approval Admin before they can be performed. For more information about MPA, see *PowerScale OneFS 9.13.0.0 Web Administration Guide*.

Table 11. Secure Snapshots privileged actions

Component	Action	Description
Snapshot	Delete snapshot	Delete a given snapshot.
Snapshot	Modify snapshot	Modify a given snapshot.
Snapshot	Delete snapshot schedule	Delete a given snapshot schedule.
Snapshot	Modify snapshot schedule	Modify a given snapshot schedule.

Network security

OneFS security includes the security of networked subsystems and interfaces.

Network exposure

The following sections describe the network exposure of OneFS, including ports, protocols, services exposed, and default states.

Network port usage

Standardized protocols enable other system units to exchange data with OneFS.

The TCP/IP protocol suite uses numbered ports to describe the communication channel within the protocol. Generally, the OneFS system uses a well-known port for receiving incoming data. The client uses an ephemeral port number to send data. Port numbers and IP addresses are included with a data packet, which enables other systems to make determinations about the data stream. TCP and UDP protocols within the TCP/IP suite use ports that range from 1 to 65535.

The Internet Assigned Numbers Authority (IANA) assigns and maintains port numbers. They are divided into three ranges:

1. Well-known ports—Ranges are from 0 to 1023.
2. Registered ports—Ranges are from 1024 to 49151.
3. Dynamic or private ports—Ranges are from 49152 to 65535.

Protocols support both IPv4 and IPv6 addresses, except where noted.

As a security best practice, use an external firewall or enable the OneFS host-based firewall. Configure the firewall to:

- Limit access to the cluster to trusted clients and servers that require access.
- For ports that are required for communication, allow restricted access only.
- Block access to all other ports.

Table 12. Network ports

Port	Service name	Protocol	Connection type	Usage and description	Effect if closed	Installed default
20	ftp-data	TCP	Outbound	• FTP access (disabled by default) • Data channel for FTP service	FTP access is unavailable.	Disabled
21	ftp	TCP	Inbound	• FTP access • Control channel for FTP access	FTP access is unavailable.	Disabled
22	ssh	TCP	Inbound	• SSH login service • SRS console management **NOTE:** SRS does not support IPv6.	SSH secure shell access is unavailable.	Enabled
25	smtp	TCP	Outbound	Email deliveries	Outbound email alerts from OneFS are unavailable.	Disabled

Table 12. Network ports (continued)

Port	Service name	Protocol	Connection type	Usage and description	Effect if closed	Installed default
53	DNS	UDP	Outbound	Domain Name Service resolution	Services are not able to resolve domain names.	Enabled
53	DNS	TCP, UDP	Inbound	SmartConnect DNS requests and incoming DNS request responses	SmartConnect DNS resolution is unavailable.	Enabled on the localhost interface only by default.
68	DHCP	UDP	Inbound	The cloud provider allocates primary IP addresses in cloud deployments and communicates them over DHCP.	Primary IP addresses are removed causing cluster data unavailability.	Enabled only in cloud deployments.
80	http	TCP	Inbound	File access (Basic file access and WebDav)	HTTP access to files is unavailable.	Disabled
88	Kerberos	TCP, UDP	Outbound	Kerberos authentication services that are used to authenticate users against Microsoft Active Directory domains.	Kerberos authentication is unavailable.	Disabled
111	rpcbind	TCP, UDP	Inbound	ONC RPC portmapper that is used to locate services such as NFS, mountd, and isi_cbind_d.	Cannot be closed; disrupts core functionality.	Enabled
123	ntp	UDP	Outbound	Network Time Protocol used to synchronize host clocks within the cluster.	Cluster time cannot be synchronized with an external NTP time source.	Enabled
135	dcerpc	TCP, UDP	Inbound	RPC Endpoint mapper service	Witness connections for SMB continuous availability are not established.	Disabled
137	netbios-ns	UDP	Inbound	NetBIOS Name Service that provides name resolution service for pre-Windows 2000 SMB1 clients.	None.	Disabled
138	netbios-dgm	UDP	Inbound	NetBIOS Datagram Service that provides legacy connectionless service for pre-Windows 2000 SMB1 clients.	None.	Disabled
139	netbios-ssn	TCP	Inbound	NetBIOS Session Service that provides SMB1 support for pre-Windows 2000 clients.	Old SMB1 clients unable to use port 445 cannot access the server.	Disabled
161	snmp	UDP	Inbound	Simple Network Management Protocol support. Typically, agents listen on port 161.	SNMP communications are not available.	Disabled
162	snmptrap	UDP	Outbound	Simple Network Management Protocol support. Typically, asynchronous traps are received on port 162.	SNMP communications are not available.	Disabled
300	mountd	TCP, UDP	Inbound	NFSv3 mount service	NFSv3 mount service is not available.	Disabled
302	statd	TCP, UDP	Inbound	NFS Network Status Monitor (NSM)	The NSM service is not available.	Disabled

Table 12. Network ports (continued)

Port	Service name	Protocol	Connection type	Usage and description	Effect if closed	Installed default
304	lockd	TCP, UDP	Inbound	NFS Network Lock Manager (NLM)	The NLM service is not available.	Disabled
305	nfsrquotad	TCP, UDP	Inbound	nfs rpc.quota daemon	The daemon is not available.	Disabled
306	nfsmgmtd	--	Inbound	nfs management daemon	The daemon is not available.	Disabled
389	ldap	TCP, UDP	Outbound	Microsoft Active Directory domain service. Used to fetch the list of servers from the Active Directory domain and other domain information.	The cluster cannot fetch a list of AD domains or verify that they are active.	Disabled
389	ldap	UDP	Outbound	CLDAP pings. Used to determine if a domain server is running.	The cluster cannot perform user or group lookups or authentications against LDAP or Active Directory.	Disabled
389	ldap	TCP	Outbound	LDAP SASL (secure LDAP). Typically used to query for user and group information after authentication. **NOTE:** SASL is configured on the AD or LDAP servers, not on the cluster. During LDAP connection setup, there is an option to determine whether to use a secure connection.	The cluster cannot perform user or group lookups or authentications against LDAP or Active Directory.	Disabled
443	https	TCP	Inbound	File access (Basic file access and WebDav) S3 HTTPS service if configured	Access to files is unavailable over TLS.	Disabled
443	https	TCP	Outbound	A port for CloudPools access to a cloud storage provider. **NOTE:** Port 443 is typical, but not always the correct port. The cloud storage provider (or other archive location such as ECS or another PowerScale cluster) may use or require a different port. Customer load balancers may also affect which port is required for CloudPools connections.	If CloudPools is using this port, CloudPools features are not available.	Disabled
445	microsoft-ds (SMB)	TCP	Inbound and Outbound	SMB1 and SMB2 client	N/A	Disabled
445	microsoft-ds (SMB)	TCP	Outbound	SMB1 and SMB2 client	Joining an Active Directory domain and the NTLM authentication against it are not possible.	Disabled

Table 12. Network ports (continued)

Port	Service name	Protocol	Connection type	Usage and description	Effect if closed	Installed default
514	syslog	UDP	Inbound and Outbound	syslog	Cannot be closed; disrupts core functionality.	Enabled
585	hdfs (datanode)	TCP (IPv4 only)	Inbound	HDFS (Hadoop file system)	HDFS is unavailable.	Disabled
623	isi_ipmi_d	TCP, UDP	Inbound	Reserved for hardware	N/A	Enabled
636	ldap	TCP	Outbound	• LDAP Directory service queries used byOneFS Identity services. • Default port for LDAPS	LDAP is unavailable.	Disabled
989	ftps-data (implicit)	TCP	Outbound	• Secure FTP access (disabled by default). • Secure data channel for FTP service	Secure FTP access is unavailable.	Disabled
990	ftps (implicit)	TCP	Inbound	• Secure FTP access • Control channel for FTP access	Secure FTP access is unavailable.	Disabled
2049	nfs	TCP, UDP	Inbound	Network File Service (NFS) server	The NFS server and all related NFS services (including mount, NSM, and NLM) are not available. NFS is an important component of the OneFS interaction, even if no NFS exports are visible externally.	Disabled
2097	SyncIQ	TCP	Inbound	isi_replicate	SyncIQ is unavailable.	Disabled
2098	SyncIQ	TCP	Inbound	SyncIQ: isi_migr_pworker	SyncIQ is unavailable.	Disabled
3147	isi_replicate	TCP	Inbound	isi_repl_bandwidth	SyncIQ is unavailable.	Disabled
3148	SyncIQ	TCP	Inbound	SyncIQ: isi_migr_bandwidth	SyncIQ is unavailable.	Disabled
3149	SyncIQ	TCP	Inbound	SyncIQ: isi_migr_bandwidth	SyncIQ is unavailable.	Disabled
3268	lsass	TCP	Outbound	Used for unencrypted communications with a Microsoft Active Directory Global Catalog LDAP server.	Some forms of Active Directory authentication might not work, depending on the configuration.	Disabled
5019	ifs	TCP	Inbound or Outbound (Internal)	PowerScale file system	Intracluster communication is not available.	Enabled
5055	smartconnect	UDP	Inbound (Internal)	SmartConnect	SmartConnect is unavailable.	Enabled
5666	isi_replicate	TCP	Inbound	isi_repl_sworker	SyncIQ is unavailable.	Disabled
5667	SyncIQ	TCP	Inbound	SyncIQ: isi_migr_sworker	SyncIQ is unavailable.	Disabled
5668	SyncIQ	TCP	Inbound	SyncIQ: isi_migr_sworker	SyncIQ is unavailable.	Disabled
6514	syslog	TCP	Outbound	syslog over TLS	`syslog` only uses port 514.	Disabled

Table 12. Network ports (continued)

Port	Service name	Protocol	Connection type	Usage and description	Effect if closed	Installed default
6557	isi_ph_rpcd	TCP	Inbound	Performance collector	Performance collection and analysis are unavailable.	Disabled
7722	isi_dm_d	TCP	Inbound	SmartSync daemon control and data transfer	SmartSync is unavailable.	Disabled
8020	hdfs (namenode)	TCP (IPv4 only)	Inbound	HDFS (Hadoop file system)	HDFS is unavailable.	Disabled
8080	isi_webui	HTTPS, TCP	Inbound	• OneFS Web UI • PAPI • Remote service • CloudPools, when a second PowerScale cluster is used for archiving.	• HTTPS access to the Web UI is unavailable. • PAPI is unavailable. • CloudPools archive to another PowerScale cluster is unavailable.	Enabled
8082	WebHDFS	http, TCP	Inbound	webhdfs, jmx, imagetransfer over HTTP	Access to HDFS data is unavailable through WebHDFS.	Disabled
8440	Ambari agent	TCP (IPv4 only)	Outbound	Handshake from Ambari agent to Ambari server.	Ambari Agent is unavailable to monitor and report the status of HDFS access zone.	Disabled
8441	Ambari agent	TCP (IPv4 only)	Outbound	Heartbeat status from Ambari agent to Ambari server.	Ambari Agent is unavailable to monitor and report the status of HDFS access zone.	Disabled
8443	webhdfs_ran	https, TCP	Inbound	• Restful access to namespace (RAN) • webhdfs, jmx, imagetransfer	• Unable to access RAN • Unable to access webhdfs, jmx, imagetransfer over HTTPS	Disabled
8470	SyncIQ	TCP	Inbound	SyncIQ: isi_replicate	SyncIQ is unavailable.	Disabled
9020	s3	http	Inbound	• S3 service access • CloudPools, when S3 or ECS is used as the archive service provider.	• S3 access is unavailable. • CloudPools archive to S3 or to ECS is unavailable.	Disabled
9021	s3	https	Inbound	• S3 service access • Configurable: S3 HTTPS port can be set to 443 (standard HTTPS) or any port in the range 1024–65535 • CloudPools, when S3 or ECS is used as the archive service provider.	• S3 access is unavailable. • CloudPools archive to S3 or to ECS is unavailable.	Disabled
9443	isi_esrs_d	TCP	Outbound	SRS outbound alerts	PowerScale is unable to send alerts, log gathers, and other event data to Dell Technologies technical support.	Disabled
10000	NDMP	TCP	Inbound	Network data management for backup	NDMP backup is disabled.	Disabled

Table 12. Network ports (continued)

Port	Service name	Protocol	Connection type	Usage and description	Effect if closed	Installed default
12228	CEE CEE/CAVA CEE/Audit	http	Outbound	The same CEE software handles CAVA anti-virus and Audit requests. Both CAVA and Audit use this port. The CEE service handles the request packets, which are HTTP with an XML body. CEE forwards the request to one of the other services. CAVA scan requests and heartbeats travel between the cluster and the CEE and CAVA servers using HTTP on port 12228. Audit records are forwarded to an Audit server. **NOTE:** Also, SMB must be enabled. The CEE software reads and updates files over SMB (port 445) using configured IP pool addresses.	The CAVA servers are unreachable. Audit records are not forwarded to the audit server.	Disabled (both CAVA and Audit)
15000	isi_lcd_d	TCP	Inbound (Internal)	Internal communication	None	Enabled
15100	isi_upgrade_agent_d	UDP	Inbound (Internal)	PowerScale upgrade daemon	Cluster reimages are unavailable.	Enabled
20049	NFSv3 over RDMA	RDMA	Inbound or Outbound	Transport NFSv3 data access communication over RDMA as an alternative to TCP or UDP, for enhanced performance.	RDMA transport not possible	Disabled
Dynamic	lwwit	TCP, UDP	Inbound	SMB witness	Tied to SMB service	Disabled (both CAVA and Audit)
Dynamic	isi_cbind_d	UDP	Inbound or Outbound	The dynamic port that is used for communicating with the DNS server for sending and receiving DNS queries and responses. There could be multiple dynamic ports; a port is created for each groupnet that is configured on the cluster.	isi_cbind_d	Enabled

Network port controls

The following table shows the commands that enable or disable the network ports.

Table 13. Commands to enable or disable network ports

Port	Service name	Install default	Command usage
20	ftp-data	Disabled	Opened on use when the FTP service is enabled. `isi services vsftpd <enable or disable>`
21	ftp	Disabled	`isi services vsftpd <enable or disable>`
22	ssh	Enabled	See SSH security best practices.

Table 13. Commands to enable or disable network ports (continued)

Port	Service name	Install default	Command usage
25	smtp	Disabled	See "Configure SMTP email settings" section in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.
53	DNS	Enabled	Not modifiable.
68	DHCP	Enabled	Not modifiable. Specific to cloud versions.
80	http	Disabled	`isi http settings modify --service <enabled or disabled>`

88	kerberos	Disabled	`isi auth krb5 delete <provider-name>`
			To reenable Kerberos, create a Kerberos provider by running:
			`isi auth krb5 create <realm> { <user> | --keytab-file <string> }`
			View all options for Kerberos provider creation using `isi auth krb5 create --help`.

111	rpcbind	Enabled	Disabling this service is not recommended, isi_cbind_d requires this service.
123	ntp	Enabled	Not modifiable.
135	dcerpc	Disabled	See SMB service.
137	netbios-ns	Disabled	Not modifiable.
138	netbios-dgm	Disabled	Not modifiable.
139	netbios-ssn	Disabled	Not modifiable.
161	snmp	Disabled	`isi snmp settings modify --service=<true | false>`
162	snmptrap	Disabled	This must be configured before traps are sent. `isi snmp settings modify --service=<true | false>`
300	mountd	Disabled	Not modifiable.
302	statd	Disabled	Not modifiable.
304	lockd	Disabled	Not modifiable.
305	nfsquotad	Disabled	From the WebUI, go to **Protocols > UNIX sharing (NFS) > Global settings** tab, and check the box for **NFS export service enabled**. Then click **Save**.
306	nfsmgmtd	Disabled	From the WebUI, go to **Protocols > UNIX sharing (NFS) > Global settings** tab, and check the box for **NFS export service enabled**. Then click **Save**.

389	ldap	Disabled	The port is opened on usage. To ensure nonusage, delete the LDAP configuration:
			`isi auth ldap delete <provider name>`
			To reenable this service, create a provider.
			1. View all options for LDAP provider creation:
			`isi auth ldap create --help`
			2. Create a provider:
			`isi auth ldap create <provider name> <additional options>`

443	https / s3 https	Disabled	https: `isi http settings modify --https <enable or disable>` **NOTE:** This command takes effect immediately, unless the `--service` flag is not enabled. Otherwise, enable the service. s3 https: `isi s3 settings global modify --https-port=443`

Table 13. Commands to enable or disable network ports (continued)

Port	Service name	Install default	Command usage
			NOTE: This command takes effect immediately, unless s3 is not enabled or https has already used that port.
445	microsoft-ds	Disabled	From the WebUI, go to **Protocols > Windows sharing (SMB) > SMB server settings** tab, and check the box for **Enable SMB service**. Then click **Save**.
514	syslog	Enabled	Not modifiable.
585	hdfs (datanode)	Disabled	From the WebUI, enable the HDFS Service by going to **Protocols > Hadoop (HDFS)** and click **Update**. Then click **Save**.
623	isi_ipmi_d	Enabled	Not modifiable.

636	ldap	Disabled	The port is opened on usage. To ensure nonusage, delete the LDAP configuration:
			`isi auth ldap delete <provider name>`
			To reenable this service, create a provider.
			1. View all options for LDAP provider creation:
			`isi auth ldap create --help`
			2. Create a provider:
			`isi auth ldap create <provider name> <additional options>`

989	ftps-data (implicit)	Disabled	Not modifiable.
990	ftps (implicit)	Disabled	Not modifiable.
2049	nfs	Disabled	From the WebUI, go to **Protocols > UNIX sharing (NFS) > Global settings** tab, and check the box for **NFS export service enabled**. Then click **Save**.
2097	SyncIQ	Disabled	`isi services -a isi_replicate <enable or disable>`
2098	SyncIQ	Disabled	`isi sync settings modify --service <on or off>`
3147	SyncIQ	Disabled	`isi services -a isi_replicate <enable or disable>`
3148	SyncIQ	Disabled	`isi sync settings modify --service <on or off>`
3149	SyncIQ	Disabled	`isi sync settings modify --service <on or off>`
3268	lsass	Disabled	Enabled on use. For information about using AD, see the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.
5019	ifs	Enabled	Not modifiable.
5055	smartconnect	Enabled	Not modifiable.
5666	SyncIQ	Disabled	`isi services -a isi_replicate <enable or disable>`
5667	SyncIQ	Disabled	`isi sync settings modify --service <on or off>`
5668	SyncIQ	Disabled	`isi sync settings modify --service <on or off>`
6514	syslog	Disabled	To enable: `isi audit settings global modify --config-auditing-enabled true --config-syslog-enabled true --config-syslog-tls-enabled true --config-syslog-servers <IP address>:6514` To disable: `isi audit settings global modify --config-syslog-tls-enabled false`
6557	isi_ph_rpcd	Disabled	This port is enabled or disabled as necessary by the Performance Collection daemon.

Table 13. Commands to enable or disable network ports (continued)

Port	Service name	Install default	Command usage
7722	isi_dm_d	Disabled	`isi services -a isi_dm_d <enable or disable>`
8020	hdfs (namenode)	Disabled	From the WebUI, enable the HDFS Service by going to **Protocols > Hadoop (HDFS)** and check the box for **Enable HDFS service**. Then click **Save**. HDFS has to first be activated.
8080	isi_webui	Enabled	`isi http services modify --service-id=PowerScaleUI --enabled=false`
8082	WebHDFS	Disabled	From the WebUI, enable the HDFS Service by going to **Protocols > Hadoop (HDFS)** and check the box for **Enable HDFS service**. Then click **Save**. HDFS has to first be activated.
8440	Ambari agent	Disabled	`isi hdfs settings modify --ambari-server` For more information and options, see the HDFS Reference Guide on the Support site.
8441	Ambari agent	Disabled	`isi hdfs settings modify --ambari-server`
8443	webhdfs-ran	Disabled	`isi services apache2 <enable or disable>`
8470	N/A	Disabled	Not modifiable.
9020	s3	Disabled	From the WebUI, go to **Protocols > Object storage (S3) > Global settings** tab, and check the box for **Enable S3 service**. Then click **Save**.
9021	s3	Disabled	From the WebUI, go to **Protocols > Object storage (S3) > Global settings** tab, and check the box for **Enable S3 service**. Then click **Save**.
10000	NDMP	Disabled	`isi ndmp settings global modify --service=true`
12228	cava	Disabled	`isi antivirus cava settings modify --service-enabled=true --ip-pool=subnet0.pool1`
15000	isi_lcd_d	Enabled	Not modifiable.
15100	isi_upgrade_agent_d	Enabled	Not modifiable.
20049	nfsordma	Disabled	`isi nfs settings global modify --nfs-rdma-enabled=true`
Dynamic	isi_cbind_d	Enabled	Not modifiable.
Dynamic	lwwit	Disabled	From the WebUI, go to **Protocols > Windows sharing (SMB) > SMB server settings** tab, and check the box for **Enable SMB service**. Then click **Save**.

Services that are safe to disable

To improve security, you should restrict access to the PowerScale cluster by disabling network services that you do not use.

NOTE: There are some services that you should not disable, because doing so could have a detrimental effect on cluster operations. The list below includes only those services that can be disabled without disrupting other operations on the cluster. This list does not include all the network services available on OneFS.

You can disable network services by running the following command, where *<service>* is the name of the service to disable:

```
isi services <service> disable
```

Disable the following services when they are not in use:

Table 14. Services to disable when not in use

Service name	Service description	Service function	Corresponding daemons and processes	Default setting
`antivirus`	CAVA anti-virus Service	Enables or disables CAVA. Note: a CAVA anti-virus server must be configured to fully enable.	`lwavscan`	Disabled
`apache2`	Apache2 Web Server	Connects to the Apache web server. Disabling apache2 disables file sharing over HTTP or HTTPS, but the OneFS web interface is still available.	`httpd`	Disabled
`isi_diags_d`	Diagnostics Launcher Daemon	Manages administrator requests for gathering diagnostic information.	• `isi_diags_d` • `isi_gather_info` • `isi_netlogger`	Enabled
`isi_dm_d`	Lhotse Data Mover	Enables or disables Data Mover.	`isi_dm_d`	Disabled
`isi_esrs_d`	Secure Remote Services Service Daemon	Communicates with legacy Dell Secure Remote Services for problem reporting, diagnostics, managed file transfer, and telemetry.	`isi_esrs_d`	Disabled
`isi_hwmon`	Hardware Monitor	API for interfacing with the Isilon Management Board.	`isi_start_hwmon`	Disabled
`isi_iceage_d`	Ice Age Monitor Daemon	Automated crash debugging.	• `isi_iceage_d` • `iceage_monitor` • `iceage_monitor_upload`	Enabled
`isi_migrate`	SyncIQ Service	Enables or disables SyncIQ.	• `isi_migr_bandwidth` • `isi_migr_pworker` • `isi_migr_sworker` • `isi_migr_sched`	Disabled
`isi_object_d`	PowerScale Object Interface	Enables or disables RAN.	`isi_object_d`	Enabled
`isi_pp_d`	Partitioned Performance Daemon	Enables or disables SmartQoS.	`isi_pp_d`	Enabled
`isi_sasphymon`	SAS PHY Monitor Daemon	SAS topology checker.	• `isi_sasphymon` • `isi_checksasphy` • `isi_sasphymon_ctl`	Disabled
`isi_smartquotas`	SmartQuotas Service	Quota-management tool that monitors and enforces administrator-defined storage limits.	• `isi_quota_sweeper_d` • `isi_quota_report_d` • `isi_quota_notify_d`	Enabled
`isi_supportassist`	Connectivity Monitor	Communicates with Dell Technologies connectivity services for problem reporting, diagnostics, and health check definition updates.	• `ese` • `isi_rice_d` • `isi_crispies_d`	Disabled
`isi_telemetry`	Telemetry Monitor	Communicates with current Dell Technologies connectivity services for telemetry.	`isi_telemtry_d`	Disabled

Table 14. Services to disable when not in use (continued)

Service name	Service description	Service function	Corresponding daemons and processes	Default setting
`isi_upgrade_d`	Upgrade Daemon	Enables or disables the legacy upgrade service for isi_reimage. `isi_reimage` automates the enabling and disabling of this service, this should remain disabled.	`isi_upgrade_d`	Disabled
`ndmpd`	Network Data Management Protocol Daemon	Backs up and restores services.	`isi_ndmp_d`	Disabled
`nfs`	NFS Server	Manages Network File System (NFS) protocol settings.	• `isi_netgroup_d` • `nfs` • `lw-container nfs`	Disabled
`s3`	S3 Service	Connects to the S3 server.	• `lw-container s3` • `/usr/libexec/isilon/s3`	Disabled
`smb`	SMB Service	Enables or disables the Server Message Block (SMB) server.	• `srv` • `srvsvc` • `lw-container srvsvc`	Disabled
`snmp`	SNMP Server	Connects to the Simple Network Management Protocol (SNMP) server.	`bsnmpd`	Disabled
`sshd`	Secure Shell Server	Enables or disables OpenSSH.	`sshd`	Enabled
`vsftpd`	VSFTPD Server	Connects to the Very Secure FTP (VSFTPD) server.	`vsftpd`	Disabled

Disable nonessential HTTP services

You can disable and enable nonessential capabilities that listen on 8080 ports. The capabilities can be disabled and enabled independently of each other. For security reasons, it is a best practice to disable services that are not required.

You can disable services using the CLI or API. The required privilege is **ISI_PRIV_HTTP**. In the CLI, use the `isi http services modify` command. For example, to disable the PowerScale Web UI while still allowing other remote access through the PAPI and CLI:

```
isi http services modify --service-id=PowerScaleUI --enabled=false
```

The following table shows the services that you can control with this command and the results of disabling each service.

Table 15. Service IDs

Service id	Description	Results when disabled
`PowerScaleUI`	The PowerScale Web Administration UI (Web UI)	The Web UI is not available.
`Platform-API-External`	The external interface to the PowerScale API (PAPI)	API queries originating external to the cluster are not accepted. The WebUI is not available. Internal platform APIs continue to operate.
`RAN`	The restful access namespace	Web UI pages that depend on REST are not available: • Remote file browser • File system explorer

Table 15. Service IDs (continued)

Service id	Description	Results when disabled
`RemoteService`	The remote support service interface (`rsapi`)	Secure Remote Services management capabilities in the UI are not available. For example, the Manage Remote Services and Licensing pages are not available.

When a service is disabled and a user tries to use that service, a 503 HTTP error `Service Not Available` is returned.

There are some dependencies among the services, as described in the following table.

Table 16. Service names

Service name	Affects on other services when enabled	Affects on other services when disabled
`PowerScaleUI`	When you enable the `PowerScaleUI` service, the `Platform-API-External` service is also enabled. The Web UI requires the PAPI for all functions. **NOTE:** When you disable the `PowerScaleUI`, the `Platform-API-External` service is not automatically disabled. The PAPI can continue to service other external requests when the Web UI is disabled.	--
`Platform-API-External`	--	If you disable the `Platform-API-External` service, the `PowerScaleUI` service is also disabled. The Web UI cannot operate without the PAPI. **NOTE:** If you enable the `Platform-API-External` service, the system does not automatically enable the `PowerScaleUI` service.

Communication security settings

For information about how to authenticate between client nodes and Dell Technologies PowerScale systems, see the "Authentication" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Firewall default settings

PowerScale 9.5.0.0 and later supports a host-based firewall. The firewall controls inbound traffic on the frontend network. You can enable default global policies or create custom policies and rules that are based on your network management and security requirements.

The host-based firewall is disabled by default. The firewall is based on policies, which are collections of rules. You can apply policies to subnets or network pools. The STIG hardening profile enables the firewall and the default policies.

The firewall comes with predefined default policies that protect the PowerScale default ports. You can modify the default policies and reset them back to their original installed state.

NOTE: If your installation does not use the default port for an inbound traffic protocol, you must change the rules for those protocols in the default firewall policies. Otherwise, the default policies do not protect your changed ports.

You can create custom policies and custom rules that define a firewall for your specific network management and security requirements. For convenience in developing custom policies, you can start by creating a clone of an existing policy.

The following table describes the default policies that are installed with OneFS.

Table 17. Default firewall policies

Policy	Summary

default_pools_policy	Contains rules for the inbound default ports for TCP and UDP services in OneFS. For a list of default ports, see Network port usage.
	Firewall policies can be viewed with the following commands:
	`isi network firewall policies list`
	`isi network firewall policies view <policy-id>`

default_subnets_policy	Contains rules for: • DNS port 53 • Rule for ICMP • Rule for ICMP6

In OneFS 9.9.0 and later versions, the Differentiated Service Code Point (DSCP) setting allows you to configure Cost of Service (CoS) and Quality of Service (QoS) values on outgoing IP packets for four types of network traffic:

1. Transactional data: Data protocols such as SMB, NFS, HDFS (setdscp 18)
2. Network management: WebUI, SSH, SMTP, SNMP, syslog (setdscp 16)
3. Bulk data: Datamover, SyncIQ, backup (setdscp 10)
4. Best effort: All IP packets that are not matched to the other three DSCP rules (setdscp 0)

When IP packets are outgoing from the frontend ports, they are matched to these four rules. If DSCP is enabled and a match is found on the source or destination port, the firewall engine marks the DSCP bits to the value specified in the corresponding rule. This functionality applies only if both the firewall service and the DSCP setting are enabled.

The DSCP values are applied consistently throughout the cluster and are preserved across upgrades.

For information about configuring the firewall, see the "Host-based firewall" section in the "Networking" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Protocols

OneFS includes several communication protocols.

NOTE:

On new installations of OneFS, all protocols are disabled by default. You must enable any protocols that you plan to use. In addition, the default `/ifs` export and the `/ifs` share no longer exist.

Upgrading to or from other versions does not affect existing configurations. If a service or share is enabled, it continues to be enabled after upgrades.

As a security best practice, it is recommended that you disable or place restrictions on all protocols that you do not plan to support. For instructions, see Data-access protocols best practices.

FTP security

The FTP service is disabled by default. You can set the FTP service to allow any node in the cluster to respond to FTP requests through a standard user account.

When configuring FTP access, ensure that the specified FTP root is the home directory of the user who logs in. For example, the FTP root for the local user `jsmith` should be `/ifs/home/jsmith`. You can enable the transfer of files between remote FTP servers and enable anonymous FTP service on the root by creating a local username `anonymous` or `ftp`.

NOTE: OneFS supports FTP, the `gate-ftp` variant of FTP, `pftp`, and `sftp`. OneFS does not support `tftp`.

CAUTION: The FTP service supports cleartext authentication. If you enable the FTP service, the remote FTP server allows username and password transmission in cleartext. As a result, authentication credentials might be intercepted. If you must use FTP, it is recommended that you enable TLS on the FTP service, and then connect with an FTP client that supports TLS.

To enable TLS on the FTP service:

1. Change the `<ssl_enable>` property in the `/etc/mcp/sys/vsftpd_config.xml` file to the following:

```
<ssl_enable default="NO">YES<isi-meta-tag id="ssl_enable" can-mod-text="yes"/></
ssl_enable>
```

2. With that change, the FTP service requires a TLS certificate. The following parameter indicates where `vsftpd` looks for a certificate:

```
<rsa_cert_file default="/usr/share/ssl/certs/vsftpd.pem">/usr/share/ssl/certs/
vsftpd.pem<isi-meta-tag id="rsa_cert_file" can-mod-text="yes"/></rsa_cert_file>
```

3. If needed, acquire a certificate from a trusted certificate authority and add it to the cluster. For more information, see the Certificates section in the "General cluster administration" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

The `/etc/mcp/templates/vsftpd.conf` file should be modified to only accept TLS 1.2 or 1.3 connections with approved ciphers. This is the default behavior, but if upgrading from versions earlier than 9.5.0.0 to 9.5.0.0, this file must be manually updated.

1. Change the following properties in the `/etc/mcp/templates/vsftpd.conf` file to the following:

```
ssl_tlsv1=NO
ssl_tlsv11=NO
ssl_tlsv12=YES
ssl_tlsv13=YES
```

2. Also change the `<ssl_ciphers=HIGH>` property to the following:

```
ssl_ciphers=ECDHE-RSA-AES256-GCM-SHA384:ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-
AES128-GCM-SHA256:ECDHE-ECDSA-AES128-GCM-SHA256
```

HDFS security

See the *PowerScale OneFS HDFS Reference Guide* for security information.

One additional security consideration is that Cloudera Data Platform (CDP) Hadoop supports only secure URLs.

HTTP and HTTPS security

Basic authentication

The HTTP Basic authentication method is disabled by default.

WARNING: Enabling HTTP Basic authentication increases the risk that is associated with cross-site request forgery (CSRF) attacks.

Session-based authentication is a recommended alternative. If you are disabling Basic authentication after having it enabled, URIs that worked with Basic authentication will no longer work by default.

Accessing the Web UI when HTTP is disabled

HTTPS is always available for accessing the Web UI, even when HTTP is disabled.

To access the web UI with HTTPS, specify the port number in the URL. The default port is 8080. For example, access the OneFS web UI as follows:

```
https://<ip>:8080
```

Using port 8080 for access to the Web UI

Encryption and Data Security

- Port-agnostic TLS encryption: HTTPS can be served securely on any port, including port 8080, when strong protocols (TLS 1.2 or higher) and appropriately signed certificates are in use. The confidentiality and integrity of the data that is transmitted is determined by the TLS configuration, not the port number. PowerScale OneFS 9.10.0.0 introduced OpenSSL 3.0.9 and TLS 1.3 for all supported protocols, including the web administration interface.
- Certificates and trust validation: For management consoles and encryption servers, Dell Technologies recommends importing certificates that are signed by trusted authorities for all encrypted connections. Trust validation requirements and instructions apply, regardless of the port.
- Firewall and Security Controls: The firewall architecture for PowerScale OneFS clusters accounts for service-specific ports. The default pools policy enforces the port numbers and protocols that are required for each OneFS service - including the Web UI on port 8080. Administrators can modify firewall rules to allow or deny only required traffic to port 8080 for management, while keeping the user data access ports on the cluster distinct.
- Use of port 443 in OneFS: PowerScale OneFS uses port 443 for HTTPS file access when the cluster is configured for this use.

Apache server and HTTP default configurations

The OneFS Apache server and HTTP services are configured by default for a secure and accessible experience.

NOTE: Changing the default Apache configurations may weaken the security of the system.

The following default configurations are implemented.

- OneFS runs two instances of the Apache server. One instance handles HTTP requests for data access (the data path). The other instance handles administrative functions (the control path). These Apache instances monitor the following ports by default:
  - Port 8080 is used for administrative access, which includes:
    - Web UI and PAPI
    - RAN in nonhardened mode
  - Ports 80, 443, 8082, and 8443 are used for data access.

    Table 18. Ports for data access

Ports	Access
Ports 80 and 443	Basic file and WebDav access
Port 8082	`webhdfs`, `jmx`, and `imagetransfer` HTTP access
Port 8443	RAN and `webhdfs`, `jmx`, and `imagetransfer` HTTPS access

    For more information about port usage, see Network port usage.
- The server is run under a reduced privileged user-called daemon.
- Apache web server application directories, libraries, and configuration files are accessible only to privileged users.
- Legacy TLS protocols (SSL, TLSv1.0, TLSv1.1) are disabled in favor of TLS v1.2 or 1.3.
- Strong cipher suites are enabled for key exchange, bulk encryption, and hashing to strengthen the confidentiality, integrity, and authenticity of the communication channel.
- The HTTP layer on top of TLS is strengthened through the following security best practice HTTP headers:
  - `Content-Security-Policy`—specifies policy for HTTPS access.
  - `Strict-Transport-Security`—specifies that browsers use HTTPS rather than HTTP.
  - `X-Frame-Options: sameorigin`—secures data access to the same HTTP instance.
  - `X-Content-Type-Options: nosniff`—prevents clients from determining the MIME type of the requested asset.
  - `X-XSS-Protection "1; mode=block"`—prevents cross-site scripting attacks on older browsers.
- To reduce unnecessary information disclosure of the specific server version and technology, the HTTP response headers contain a generic server string.
- The PAPI defines explicit limits on allowed HTTP verbs. Limits are defined individually on each resource and are operationally appropriate for each resource.
- Authentication is required and integrated with the OneFS authentication providers.
- Sessions are maintained using industry-standard HTTP cookies. Security attributes are enabled for such cookies.

- OneFS detects HTTP and HTTPS session inactivity and closes inactive sessions. Configurable timeout values control session closing.

Session timeouts

Sessions that are allowed to remain open indefinitely are a security risk. An attacker could use an already authenticated session to access a hosted application. As a protection against this type of attack, OneFS detects HTTP and HTTPS session inactivity and closes inactive sessions using configurable timeouts.

Use the `isi http settings modify` command to configure timeouts. The following table shows the timeout parameters, the corresponding Apache directives that they implement, and their default values.

Table 19. Session timeouts

Parameter in `isi http settings modify`	Defaults (in seconds)	
	Nonhardened cluster	**Hardened cluster**
`--service-timeout` This parameter affects the Apache instance and each HTTP service.	500	500
`--inactive-timeout`	0	600
`--session-max-age`	4 hours, or 14,400 seconds	600 seconds, or 10 minutes

For information about usage `isi http settings modify` and other commands that are related to HTTP configuration and services, see *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

HTTP services

The `isi http services list` command shows supported HTTP services and whether the service is enabled or disabled on your cluster. For example:

```
isi http services list
ID                    Enabled
------------------------------
Platform-API-External Yes
PowerScaleUI          Yes
RAN                   Yes
RemoteService         Yes
------------------------------
Total: 4
```

NOTE: The RestFul Access to namespace (RAN) is the data access service.

You can use the `isi http services modify` command to enable and disable services.

NFS security

NFS is disabled by default. If you support NFS, you must enable it. Dell Technologies recommends using authenticated NFSv4.

To enable NFS and learn about NFS security options, see the "File sharing" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

S3 security

The S3 service is disabled by default. With the S3 service enabled, only HTTPS access to S3 is enabled by default.

NOTE: The S3 HTTPS service is available on port 9021 by default. The port can be reconfigured to use 443 (standard HTTPS) or any port in the range 1024–65535.

NOTE: The S3 service is independent of the HTTP Server configuration.

For more information about S3, see the "S3 support" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

SMB security

On new installations, SMB data access to the cluster is disabled by default. On upgrades, if SMB was explicitly being used before the upgrade, it remains enabled.

To use SMB, you must:

1. Enable the SMB service.
2. Create an SMB share.

CAUTION: Due to security concerns, Dell Technologies does not recommend enabling the SMB1 protocol. To ensure long-term compatibility, consider transitioning away from SMB1.

NOTE: Versions before OneFS 9.7, SMB1 is enabled by default when the SMB service is started. If your workflow does not require SMB1, disable it by following the steps in the next section, Disable SMB1. Starting with OneFS 9.7, SMB1 is disabled by default. To verify SMB1 is enabled, run the **smb_v1_in_use** HealthCheck from the WebUI.

NOTE: For maximum security, do not enable SMB unless you intend to use it. Even though a share is required before SMB is usable, an attack might be possible without a share if there is a vulnerability in the OneFS implementation of SMB.

For more detail and to read about other SMB features and configuration, see the "File sharing" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Disable SMB1

Enabling SMB does not enable the SMB1 protocol.

It is recommended that you manually disable the SMB1 protocol before enabling SMB. For existing clusters, it is recommended that you manually disable SMB1.

NOTE: FIPS mode and the STIG hardening profile both disable SMB1 by default. Regardless, it is a good practice to disable SMB1 in case FIPS mode or the STIG hardening profile are disabled in the future.

1. Log in to an SSH session using root or account of last resort.
2. On a new cluster when the SMB service is not yet enabled, use these steps:
   a. Disable SMB1.

   ```
   isi smb settings global modify --support-smb1=false
   ```

   b. Enable the SMB service.
3. On an existing cluster when the SMB service is already running, use these steps:
   a. (Optional) Examine the protocol statistics for connected SMB1 clients.

   ```
   isi statistics client --protocols smb1
   ```

   If any clients are using SMB1, reconfigure or upgrade them to use SMB2. Otherwise, replace them with a client that supports SMB2.

   b. Disable SMB1.

   ```
   isi smb settings global modify --support-smb1=false
   ```

   c. Restart the smb service.
   This step disconnects any current SMB1 clients and updates the configuration to prevent new SMB1 connections.

SMB share security settings

You can view and configure the security settings of an SMB share. You can also view and configure default share settings that are used as a template for creating shares. The default share settings help to create more consistent configurations across all shares.

NOTE: Changes that are made directly to an SMB share override the default settings that are configured from the **Default Share Settings** tab.

There are many security options that you can use either on their own or in combination. The following steps get you started with viewing and configuring the settings. For descriptions of all options and their usage, see the "SMB security" section in the "File Sharing" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

1. To view and configure the security settings for an individual SMB share, use either the CLI or web administration UI.

   On the CLI, use variations of the following command:

   ```
   isi smb shares ...
   ```

   On the web administration UI:

   a. Click **Protocols** > **Windows Sharing (SMB)** > **SMB Shares**.
   b. Select the share.
   c. Click **View/Edit**.
   d. Click **Edit SMB Share**.

2. To view and configure the default SMB share security settings, use either the CLI or web administration UI.

   On the CLI, use variations of the following command:

   ```
   isi smb settings ...
   ```

   On the web administration UI:

   a. Click **Protocols** > **Windows Sharing (SMB)** > **Default Share Settings**.
   b. Click **Advanced Settings**.

Limit NetSessionEnum to admins only

A configuration setting can limit usage of the SMB `NetSessionEnum` function to admins only.

The SMB `NetSessionEnum` function lists all the SMB sessions running against the SMB server, which exposes usernames and could be a potential security risk.

By default, the SMB implementation in OneFS adheres to the Microsoft specification regarding `NetSessionEnum`. The specification permits any authenticated user to run `NetSessionEnum`.

In OneFS, you can limit `NetSessionEnum` usage to admins only. This enhancement affects any implementation of `NetSessionEnum`, including when the function is compiled within third-party tools that are commonly used in the public domain.

To implement this enhancement:

1. If SMB is enabled, disable it.

   ```
   isi services smb disable
   ```

2. Enable the `NetSessionEnum` limiting feature.

   ```
   # isi_gconfig registry.Services.srvsvc.Parameters.RequireAdministratorAccess=1
   ```

3. Enable the SMB service.

   ```
   isi services smb enable
   ```

NOTE: To make SMB usable, you must also create a share. For more information, see the "File sharing" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Mixed data-access protocol environments

With the OneFS operating system, you can access data with multiple file-sharing and transfer protocols. As a result, Microsoft Windows, UNIX, Linux, HDFS, and MacOS X clients can share the same directories and files.

For more information about data access protocol environments, see the Mixed Protocol Environment section of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*. Also see the Dell EMC PowerScale OneFS: Authentication, Identity Management, and Authorization , which is a technical white paper about multiprotocol data access and the OneFS unified permission model.

Data security

This section describes configuration options for securing stored data in OneFS clusters. For recommended best practices that protect data, see also Data-access protocols best practices.

Data access settings

OneFS supports two types of permissions data on files and directories that control who has access: Windows-style access control lists (ACLs) and POSIX mode bits (UNIX permissions). You can configure global policy settings that enable you to customize default ACL and UNIX permissions to best support your environment.

For more information, see the "Data access control" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Data-at-rest encryption

You can enhance data security on a cluster that contains only self-encrypting-drive nodes by providing data-at-rest encryption (DARE) protection. Data-at-rest encryption requires FIPS cryptography. Some drives are shipped to comply with FIPS 140-2 requirements. Otherwise, apply either STIG hardening or FIPS-enabled mode to the cluster. For more information about STIG hardening and FIPS, see United States Federal and DoD Standards and Compliance or FIPS Standards and Compliance.

You can enable external key management for self-encrypting drives (SED). This feature moves the data encryption keys off the drives. A KMIP 1.2 compatible external key management server is required.

For more information, see:

- The "Data-at-rest encryption" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide* administration guides
- The Key stores section in this guide
- The PowerScale OneFS Data-at-Rest Encryption white paper

Data sanitization

You can use the Instant Secure Erase (ISE) functionality to remove confidential data out of a drive before returning the equipment.

For more information, see the "Data Removal with Instant Secure Erase (ISE)" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Data recovery

In OneFS, you can back up and recover file-system data through the Network Data Management Protocol (NDMP). From a backup server, you can direct backup and recovery processes between a PowerScale cluster and backup devices.

For more information, see the "Administering NDMP" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Key stores

OneFS maintains key stores for storing sensitive information. The Key Manager is a backend service that manages the key stores.

The OneFS key stores are provider databases. A key store consists of backend storage and an encryption key that is used to encrypt the entries. All entries in the key stores are encrypted.

There are two key store domains in OneFS:

- Cluster key store
- Self-encrypted drive (SED) key store

The cluster key store manages keys for all cluster-wide domains, such as CloudPools, S3, JWT, Datamover, IPMI Mgmt, SSO, and so on. The `isi keymanager cluster status` command shows all domains that have keys in the cluster key store.

The SED key stores are stored locally on each node. You can optionally migrate the local key stores to a remote KMIP server. For more information, see the "Data-at-rest encryption" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

The key manager service maintains the key stores mostly without administrator involvement. If a breach or loss of trust occurs, administrators with `ISI_PRIV_KEY_MANAGER` privilege can rekey the key stores.

Rekey and reencrypt the data stores

The key stores should be reencrypted if the site experiences a security breach.

If you suspect a security breach or loss of trust, you should start the process to reencrypt the key stores. For example, if an employee with access to the root account leaves, that might be a reason to reencrypt.

The OneFS rekey operation does the following:

- Generates a new encryption key.
- Deencrypts each entry in the key store and reencrypts them with the new key.
- Preserves the old encryption key until reencryption with the new key is completed successfully.

The rekeying process does not interrupt any processing. OneFS can create entries and read existing entries in a key store during a rekeying operation.

Start a rekey operation

You can start a rekey operation using the Web UI or CLI.

1. Log in to OneFS with `ISI_PRIV_KEY_MANAGER` privilege.
2. Start the rekey operation.

Option	Description
On the Web UI	a. Go to **Access** > **Key Management** > **SED/Cluster Rekey**. b. Click **Rekey Now** in the SED keys or Cluster keys section.

On the CLI	To rekey the cluster key store:
	`isi keymanager cluster rekey start`
	To rekey the SED key stores:
	`isi keymanager sed rekey start`

3. View the status of the rekey operation.

Option	Description
On the Web UI	The **SED/Cluster Rekey** page shows the status of the current operation and the last time that the key store was rekeyed.

Option	Description

On the CLI	To view the cluster rekey status:
	`isi keymanager cluster status`
	To view the SED rekey status:
	`isi keymanager sed status`
	The **Key Creation Date** column shows the last time that the key store was rekeyed.

Set an automatic rekey schedule

Rekeying is typically performed on demand, only as needed. If security regulations at your site require more frequent rekeying, you can optionally set up an automatic rekeying schedule.

- On the Web UI, go to **Access** > **Key Management** > **SED/Cluster Rekey**.
- On the CLI, use either the `isi keymanager cluster rekey modify` or the `isi keymanager sed rekey modify` command.

You specify the schedule as a duration interval. On the Web UI, you can set the interval in days, months, and years. On the CLI, you have more granular options.

1. Log in to OneFS with `ISI_PRIV_KEY_MANAGER` privilege.
2. Set up the interval between rekey operations.

Option	Description
On the Web UI	a. Go to **Access** > **Key Management** > **SED/Cluster Rekey**. b. Click the **Automatic Rekey** checkbox in the SED keys or Cluster keys section. c. Use integers in the Day, Month, and Year text boxes to specify the interval between rekey operations.

On the CLI	To set a schedule for rekeying the cluster key store:
	`isi keymanager cluster rekey modify --key-rotation <duration>`
	To set a schedule for rekeying the SED key stores:
	`isi keymanager sed rekey modify --key-rotation <duration>`

3. View scheduling information.

Option	Description
On the Web UI	The **SED/Cluster Rekey** page shows the interval and the date of the next scheduled rekey operation.

On the CLI	To view the cluster rekey schedule:
	`isi keymanager cluster rekey view`
	To view the SED rekey schedule:
	`isi keymanager sed rekey view`
	The **Key Rotation** field shows the schedule.

Cryptography

OneFS uses globally recognized cryptographic algorithms and protocols, including:

- HTTPS
- Kerberos

- SSH
- Transport Layer Security (TLS)
- TLS to Lightweight Directory Access Protocol (LDAP)

The following sections describe cryptographic use in OneFS, including the current cryptographic releases, which algorithms are used, and where in the product the algorithms are used.

NOTE: Different releases of OneFS may support different cryptographic inventories. If you have questions about the cryptographic inventory for different versions of OneFS, contact Dell Technologies Support.

Cryptographic options

The following sections describe supported cryptographic options for each protocol.

Cryptographic inventory for HTTPS

The HTTPS cryptography applies to HTTPS clients and to the OneFS web administration interface.

TLSv1.2 cipher suites supported by HTTPS

NOTE: See the next section for the list of supported cipher suites when FIPS mode is enabled.

```
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1, secp384r1, or secp521r1 ECC curves)
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1, secp384r1, or secp521r1 ECC curves)
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (secp256r1, secp384r1, or secp521r1 ECC curves)
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (secp256r1, secp384r1, or secp521r1 ECC curves)
```

TLSv1.3 cipher suites supported by HTTPS

NOTE: See the next section for the list of supported cipher suites when FIPS mode is enabled.

```
TLS_AKE_WITH_AES_256_GCM_SHA384
TLS_AKE_WITH_CHACHA20_POLY1305_SHA256
TLS_AKE_WITH_AES_128_GCM_SHA256
```

Cryptographic inventory for HTTPS in FIPS enabled mode

The following cryptography applies to REST clients. It also applies to the OneFS web administration interface when FIPS mode is enabled.

TLSv1.2 cipher suites supported by HTTPS in FIPS enabled mode

For more information about FIPS support, see FIPS Standards and Compliance.

```
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
```

TLSv1.3 cipher suites supported by HTTPS in FIPS enabled mode

For more information about FIPS support, see FIPS Standards and Compliance.

```
TLS_AKE_WITH_AES_256_GCM_SHA384
TLS_AKE_WITH_AES_128_GCM_SHA256
```

Cryptographic inventory for CAC/PIV

The following cryptography applies to SSH clients used for authenticating using CAC or PIV.

```
x509v3-ecdsa-sha2-nistp384
x509v3-ecdsa-sha2-nistp521
x509v3-ssh-ed25519
x509v3-rsa2048-sha256
x509v3-ssh-rsa
```

Cryptographic inventory for NFS

This section lists the NFS cryptographic algorithms that are available in OneFS.

Usage of these algorithms depends on your configuration and workflow. For configuration information, see the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

NOTE: When kerberos is used, a time sync for NTP must be set up in common with the KDC.

NFS default settings

Setting	Enabled/disabled
NFS service	Disabled
NFSv3	Enabled (requires NFS service). OneFS upgrades maintain the previous NFSv3 setting.
NFSv4	Enabled (requires NFS service). OneFS upgrades maintain the previous NFSv4 setting.

NFSv3 algorithms

Algorithm	Description
Key Exchange Algorithms	RPCSEC_GSS, KerberosV5
Authentication Algorithms	*see NFS authentication algorithms table.
Encryption Algorithms	AES256-CTS AES128-CTS RC4-HMAC
Message Authentication Code Algorithms (integrity)	RPCSEC_GSS enforces the TCP protocol at the transport layer.

NFSv4 algorithms

Algorithm	Description
Key Exchange Algorithms	RPCSEC_GSS, KerberosV5
Authentication Algorithms	*see NFS authentication algorithms table.
Encryption Algorithms	AES256-CTS AES128-CTS RC4-HMAC
Message Authentication Code Algorithms (integrity)	RPCSEC_GSS enforces the TCP protocol at the transport layer.

NFS authentication algorithms

Authentication depends on the security approach but can be overridden if the device is blocked in a netgroup, or there is a rule mapping a uid to something else.

Security approach	Description
AUTH_UNIX	AUTH_UNIX, trust the remote device for authentication, no integrity check, no encryption.

Security approach	Description
krb5	Trust the kdc, no integrity check, no encryption
krb5i	Trust as krb5, integrity check using (RPCSEC_GSS) RPC headers are signed and headers and data are hashed, no encryption.
krb5p	Trust as krb5, integrity as krb5i, encryption in (AES256-CTS AES128-CTS RC4-HMAC)

Cryptographic inventory for OpenSSH

The following table shows the OpenSSH cryptographic algorithms that are supported in OneFS.

Algorithm	Description
Encryption Algorithms	aes192-ctr, aes256-ctr, aes256-gcm@openssh.com
Key Exchange Algorithms	curve25519-sha256, curve25519-sha256@libssh.org, ecdh-sha2-nistp256, ecdh-sha2-nistp384, ecdh-sha2-nistp521
Host Key Algorithms	rsa-sha2-512, rsa-sha2-256, ecdsa-sha2-nistp256, ssh-ed25519
Authentication Algorithms	Depends on cluster configuration.
Message Authentication Code Algorithms(integrity)	hmac-sha2-256

Cryptographic inventory for OpenSSH in FIPS enabled mode

The following table describes the OpenSSH cryptographic algorithms that are automatically used when FIPS mode is enabled.

NOTE: More cryptographic changes are desirable for FIPS compliance. In OneFS 9.5.0.0, you must perform these additional changes with CLI commands. To enable FIPS mode, ensure that you perform all the steps in Enable FIPS mode .

For more information about FIPS support, see FIPS Standards and Compliance.

Algorithm	Description
Encryption Algorithms	aes256-ctr
Key Exchange Algorithms	ecdh-sha2-nistp256, ecdh-sha2-nistp384, ecdh-sha2-nistp521
Host Key Algorithm	rsa-sha2-512, rsa-sha2-256, ecdsa-sha2-nistp256
Authentication Algorithms	Depends on cluster configuration.
Message Authentication Code Algorithms (integrity)	hmac-sha2-256

Cryptographic inventory for SNMPv3

This section lists the SNMPv3 cryptographic algorithms as used in OneFS.

Algorithm	Description
Authentication Algorithms	HMAC-SHA-96, MD5
Privacy	3DES, AES-128-CFB

NOTE: The SNMPv3 authentication algorithm defaults to MD5 and to privacy AES.

Cryptographic inventory for SMB

This section lists the SMB cryptographic algorithms that are available in OneFS.

NOTE: For ultimate security in your OneFS environment, it is recommended that you use encryption, and not signing.

Usage of these algorithms depends on your configuration and workflow. For configuration information, see the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

The SMB service in OneFS supports SMBv1, SMBv2, and SMBv3.

SMB algorithms

Table 20. Algorithms

Algorithm	Description
Authentication Algorithm	• krb5 • NTLM (GSS-SPNEGO)
SMBv3 Encryption Algorithm	• AES-128-CCM • AES-128-GCM (faster)

SMB signing algorithms

NOTE: For signing information, see the *SMB Signing* section in Design and Considerations for SMB Environments.

Table 21. SMB signing algorithms

SMB protocol version	SMB signing algorithm description
SMB 1	MD5
SMB 2.0.2, 2.1	HMAC-SHA256
	GSS-API SessionKey (key derivation)
SMB 3.0, 3.0.2, 3.11	AES-128-CMAC (signing)
	GSS-API SessionKey and KDF (key derivation)
	Used by the GSS-API, NTLM mechanism: • RC4 (`schannel` encryption) • MD5-HMAC (signing)
	Used by the GSS-API, KRB5 mechanism (all encryption types provide signing and encryption): • AES256-CTS • AES128-CTS • RC4-HMAC

Certificate management

PowerScale clusters ship with a self-signed TLS certificate. It is recommended that you replace the default TLS certificate with a signed certificate.

For instructions, see the Certificates section in the "General Cluster Administration" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Regulatory information

For information about regulatory information for OneFS, see the Dell Export Compliance List on the Support site.

Auditing and logging

OneFS supports several auditing, events, logging, and similar capabilities.

Table 22. Auditing and logging capabilities

Name	Description
Auditing	You can enable the following types of auditing on a cluster: ● Configuration change auditing—Configuration auditing tracks all system configuration events that the platform API handles, including writes, modifications, and deletions. ● Protocol activity auditing—Protocol audits record activity that occurs through SMB, NFS, and HDFS protocol connections. You can enable and configure protocol auditing for one or more access zones in a cluster. By default, audited access zones track only certain events on the PowerScale cluster, including successful and failed attempts to access files and directories. The events that are tracked by default are `create`, `close`, `delete`, `rename`, and `set_security`. ● System level auditing—System auditing tracks system platform events and user account events. Examples of platform events are node startup and shutdown, module loads and unloads, and user logins. User account events track user account and password changes.
Syslog forwarding	You can configure auditing to forward logs to one or more remote syslog servers. TLS communication is an option for syslog forwarding. You can enable forwarding separately for each of the auditing types. The recommended secure configuration for auditing is syslog forwarding with TLS properly configured.
Common Event Enabler (CEE)	You can configure OneFS to send protocol auditing logs to servers that support the Common Event Enabler (CEE).OneFS integration with the Common Event Enabler (CEE) enables third-party auditing applications to collect and analyze protocol auditing logs.
Tracking node splits and merges	OneFS monitors every node in a cluster. If a node is unreachable over the internal network, OneFS separates the node from the cluster. The node separation is called splitting. When the cluster can reconnect to the node, OneFS merges the node back into the cluster. When a node is split from a cluster, it continues to capture event information locally. When the node that was split rejoins the cluster, local events that were gathered during the split are deleted. You can view split node events in the node event log file at `/var/log/isi_celog_events.log`.

For more information about auditing, syslog forwarding, and CEE integration, see the "Auditing" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the "Auditing and Logging" chapter in *PowerScale OneFS 9.13.0.0 CLI Administration Guide*. Information about node splits and merges is in the "PowerScale scale-out NAS" chapter in the Administration guides.

Logs

For information about logs, see the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Dell Technologies recommends that you send syslogs to an external syslog server. This best practice protects logged events in cases where cluster access is compromised. For more information and the configuration steps, see Forward audited events to remote server.

Log management

OneFS supports the following methods for managing logs.

Log levels

The default logging level is controlled with the following command:

```
sysctl ilog.syslog
```

Output should include the following:

```
ilog.syslog: error,warning,notice
```

Available levels are `Error`, `Warning`, `Notice`, `Info`, and `Debug`.

NOTE: Avoid using `Info` and `Debug`, unless Dell Technologies Customer Support instructs you to enable them.

Logging to the console is off by default.

Log rotation

Log rotation capabilities are available in the `/etc/newsyslog.conf` file. You can modify the rotation of the logs. The `/var/log/messages` file defaults to five stored iterations.

System behavior on failed log attempts

When a log attempt fails, the log entry does not occur.

Log protection

For integrity protection, configure the permissions in the `/etc/newsyslog.conf` file. Use permissions that you consider appropriate. The standard configuration is recommended.

Logging format

For information about logging formats, see the "Auditing and Logging" section of the *PowerScale OneFS 9.13.0.0 CLI Administration Guide* or the "Auditing" section of the *PowerScale OneFS 9.13.0.0 Web Administration Guide*.

Events and alerts

OneFS continuously monitors the health and performance of your cluster and generates events when situations occur that might require your attention.

Events can be related to file system integrity, network connections, jobs, hardware, and other vital operations and components of your cluster. OneFS analyzes the captured events. Events with similar root causes are organized into event groups.

An event group is a single point of management for numerous events that are related to a particular situation. You can determine which event groups you want to monitor, ignore, or resolve.

An alert is the message that reports on a change that has occurred in an event group. For some events, you can set the thresholds at which to raise alerts.

You can control how alerts in an event group are distributed. Alerts are distributed through channels that you create. A channel can send alerts to a specific audience, control the content that the channel distributes, and limit the frequency of the alerts.

For information about viewing and managing events and configuring alerts, see the "Events and alerts" section in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Physical security

Physical security addresses a different class of threats than the operating environment and user access security concepts that are discussed elsewhere in this guide. The objective of physical security is to safeguard company personnel, equipment, and facilities from theft, vandalism, sabotage, accidental damage, and natural or human-made disasters.

Physical security concepts are applicable to all corporate facilities, but data center security is most relevant in terms of PowerScale deployment.

Security of the data center

PowerScale components are not designed to be self-secure in either resource discrimination or physical access. For example, drive data encryption keys reside on node hardware. If access is gained to these components, the security of the data cannot be guaranteed. Thus, data center physical security is a necessary compensating control.

In addition to superior resource delivery, a secure data center protects PowerScale components from security violations at the physical level including:

- Malicious power reset
- Interference with internal cabling
- Unauthorized local access to communication ports
- Unauthorized local access to internal node components

Optimal operation of a PowerScale cluster is achieved when the cluster is installed in a data center where proper measures are taken to protect equipment and data. See the *PowerScale Site Preparation and Planning Guide* for complete data center requirements.

Physical ports on nodes

For locations and descriptions of various ports on a node, see the node installation guide for your specific Isilon or PowerScale node type.

Follow these security guidelines when using the ports on a node:

- Connect only the minimum number of cables required. Leave unused ports empty.
- Follow the instructions in the node installation guide about which ports to use and which ports not to use.
- You can connect to a node using a serial cable and enter single user mode. Exception: SmartLock compliance clusters do not allow you to boot into single user mode.
- Use `isi security settings modify --usb-ports-disabled=true` to disable (or enable) USB ports.
- Contact Dell Technologies Support if you have any questions.

Statement of volatility

A Statement of Volatility (SOV) describes the conditions under which the nondisk components of physical PowerScale products retain data when power is removed. Examples of physical products include storage arrays and physical appliances. Customers should understand which parts of a product contain (and retain) customer-specific data when power is removed. Such data may be sensitive or affected by breaches, scrubbing, or data retention requirements.

Statements of Volatility are not directly customer accessible but can be made available to customers on request. Contact your account team for assistance.

Serviceability

This section describes the following OneFS features which assist customers in maintaining and troubleshooting a cluster.

- Dell Technologies connectivity services and remote support—Dell Technologies connectivity services sends events, logs, and telemetry from your cluster to Dell Technologies Support. Remote support allows secure access to your cluster, with permission by Dell Technologies Support.
- Security checks—A security check command scans the cluster for security and health anomalies.
- Maintenance aids—Diagnostic commands in OneFS gather information about a cluster.

- Technical advisories, Security advisories, and OneFS Patches—This information is gathered in one place and is accessible on the Dell Support Site. You can register to receive email notifications when new notices are posted.

Dell Technologies connectivity services

OneFS includes the ability for a cluster to connect remotely to Dell Technologies Support for support purposes. Customers can limit or manage such access.

Dell Technologies connectivity services and Secure Remote Services (SRS)

NOTE: Dell Technologies connectivity services is recommended for all clusters that can send telemetry data off-cluster and is a replacement for the legacy connectivity system - Secure Remote Services (SRS). SRS has reached end-of-service-life. It is recommended that new PowerScale OneFS clusters use Dell Technologies connectivity services, and that existing OneFS clusters migrate from SRS to Dell Technologies connectivity services immediately to avoid service disruption.

For information about configuring a cluster to use Dell Technologies connectivity services, see the Dell Technologies connectivity services section in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Security checks and verifications

The OneFS security check monitors the cluster for security anomalies. Administrators can configure specific actions when anomalies are discovered.

The OneFS security check runs the following types of security verifications.

Table 23. Security checks

Type of security check	Description
STIG hardening verifications	**NOTE:** This check applies only to clusters that have the STIG hardening profile applied. This check invokes the hardening reports. The reports compare the current configuration against the STIG hardening profile. Configurations that are not compliant with the hardening profile are identified. For more information about the hardening reports, see Run hardening compliance reports.
Security-related health checks	This check runs the checks in the security checklist in the OneFS HealthCheck utility. To see a list of the security checks, use the following command: `isi healthcheck checklists view security` For more information, see the *OneFS HealthCheck Guide*.
FreeBSD security checks	This check runs the periodic(8) FreeBSD security checks. These checks are standard daily system security checks.

The security check runs automatically and on-demand:

- The security check is a cron job. The job runs across the cluster on the first day of each month, at 12:20 am.
- The security check runs automatically on a node at every reboot.
- Administrators can run a security check on demand with the `isi security check start` command or Platform APIs. An on-demand security check runs on the cluster or on a specified list of nodes.

The default action when anomalies are discovered is to issue a CELOG event. You can change the default action using the `isi security check settings modify` command. The supported actions are:

- Send a CELOG event.
- Reboot the affected node.
- Shut down the affected node.

For on-demand security checks, the following options are available:

- Run all the security check types, or run a subset of them.

- Run checks against the entire cluster or against a specified list of nodes.
- Specify an action other than the default action for each on-demand run.

To view the results of the last security run, use the `isi security check report view` command.

The following topics show how to use the CLI commands to change default settings, run an on-demand check, and view results. For command usage details, see the *PowerScale OneFS 9.13.0.0 CLI Command Reference*.

Configure security check default values

You can change the default configuration for automatic security checks.

1. Log in to the cluster with ISI_PRIV_CLUSTER privilege.
2. View the current default security check settings.

```
# isi security check settings view
   Action: celog
```

3. Change the default security check settings.

   The following example changes the default action.

```
# isi security check settings modify --action shutdown
```

4. Confirm the change.

```
# isi security check settings view
   Action: shutdown
```

Run a security check on demand and view the results

You can run a security check on demand.

1. Log in to the cluster with ISI_PRIV_CLUSTER privilege.
2. Run a security check.

   The following example runs the STIG profile security check across all nodes in the cluster. The example specifies a node shutdown if anomalies are discovered.

```
# isi security check start --name ClusterHealthCheck --mode cluster --action shutdown
```

3. View the results of the security check.

```
# isi security check report view --format table
Last run passed successfully.
```

Maintenance Aids

Accounts

The `ese` account is required for Dell Technologies Support.

The `remotesupport` account is required for Secure Remote Services and Dell Technologies connectivity services behavior. This account is disabled by default and should not be enabled unless it is needed. If the account is enabled, a unique password for a trusted user is recommended.

As a general best practice to protect the secure connect gateway, an external gateway is recommended that allows only `remotesupport` access between endpoints.

Tools and Applications

The `isi diagnostics gather` and `isi diagnostics netlogger` commands gather information from the cluster.

These tools are described in the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*, in the "General Cluster Administration" chapter, in the Dell Technologies connectivity services Telemetry section.

It is recommended to periodically clean up old support files that are generated using `isi diagnostics gather` that are no longer needed for cluster diagnostics. These files can be found by default in `/ifs/data/Isilon_Support/pkg`.

NOTE: The diagnostic support files follow the naming format of `IsilonLogs-*.tgz` or, on older versions `IsilonPhoneHomeLogs-*.gz`.

Security Diagnostics

The following commands and utilities provide security-related diagnostics.

Table 24. Security diagnostics

Name	For more information
`isi healthcheck`	For general information and for the `isi healthcheck` command reference pages, see the *PowerScale OneFS 9.8.0.0 CLI Administration Guide* guide.
IOCA script	For instructions about updating the IOCA script, see "Update IOCA within Healthcheck framework" in the *PowerScale OneFS 9.8.0.0 CLI Administration Guide* guide.
`isi security check`	For information about configuring and running consolidated security checks on nodes and clusters, see Security checks and verifications .

For general diagnostics, run the `isi healthcheck` command. Some security-centric health checks exist. For a list of them, run `isi healthcheck checklists view security`.

You can run the IOCA script outside of `isi healthcheck`. This utility runs as root and provides basic diagnostic information about a running system.

```
/usr/libexec/isilon/ioca/IOCA
```

You can run on-demand security checks on a node or cluster with the `isi security check start` command.

Dell Technologies Technical Advisories, Security Advisories, and OneFS patches

Dell Technologies technical advisories (DTAs), Dell Technologies security advisories (DSAs), and OneFS patches are available on the Dell Technologies Support site. These documents provide important information and solutions for issues that affect the OneFS operating system.

Technical advisories

For the most up-to-date list of DTAs, go to the PowerScale product page on the Dell Technologies Support site, click the **Advisories** tab, and then select **Technical**.

To subscribe to receive email notifications about new DTAs:

1. Go to the PowerScale product page on the Dell Technologies Support site.
2. Ensure that you are logged in with a Dell Technologies customer account.
3. Locate the **Contact Us** tab on the right side of the browser window, and click **Contact Us** > **Notifications**.
4. Select the **Dell Technical Advisory** slider.

Security advisories

For the most up-to-date list of DSAs, go to the PowerScale product page on the Dell Technologies Support site, click the **Advisories** tab, and then select **Security**.

To subscribe to receive email notifications about new DSAs:

1. Go to the PowerScale product page on the Dell Technologies Support site.
2. Ensure that you are logged in with a Dell Technologies customer account.
3. Locate the **Contact Us** tab on the right side of the browser window, and click **Contact Us** > **Notifications**.
4. Select the **Dell Security Advisory** slider.

OneFS patches

For a list of patches for specific versions of OneFS, see Current PowerScale OneFS Patches on the Dell support site.

Authenticity and integrity

Digital signing, cryptographic checksums, and internal verification processes ensure the authenticity and integrity of product modules.

Package authenticity

Dell Technologies digitally signs all software and firmware upgrade packages before distribution.

In OneFS 9.4.0.0 and later, OneFS provides additional protection against compromised upgrade packages with a package catalog. The catalog stores, manages, and verifies upgrade packages. For upgrades to OneFS 9.4.0.0 and later clusters, OneFS automatically verifies authenticity and integrity during the upgrade process.

Packages that apply to OneFS 9.4.0.0 and later use a customized `.isi` file format that contains an embedded signature. For legacy compatibility, the `.isi` files may be named using the normal `.tar.gz` file extension. The `.isi` file format includes the following:

- The software package
- A readme file, if appropriate
- Supporting files such as manifests, signatures, timestamps, and other details.

The `isi upgrade catalog` commands manage the `.isi` files. You can import and export the files, list the available packages, view the readme files, and verify package contents. For information about using the `isi upgrade catalog` commands, see the "Catalog" section under "Cluster maintenance" in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

The catalog and the `isi upgrade catalog` commands apply to all upgrade package types: OneFS upgrades, patches, node firmware packages (NFPs), and DSPs. Users with ISI_PRIV_SYS_UPGRADE privilege can access the catalog.

Verifying packages and manifests

OneFS verifies package authenticity and integrity during the upgrade process.

Administrators with ISI_PRIV_SYS_UPGRADE privilege can manually verify the authenticity of packages and manifests. The `isi upgrade catalog verify` command does the following:

- Uses the OpenSSL library that is included with OneFS
- Verifies the SHA256 hash in the manifest against the included certificate
- Compares the chain-of-trust for included certificate against `/etc/ssl/certs`
- Compares the distinguished name on certificates against values in `/etc/upgrade/identities`
- Compares the SHA256 hash of data regions against values from the manifest
- Verifies the signature

Using UEFI secure boot

UEFI secure boot checks software authenticity at every reboot.

Secure boot is an optional feature for supported PowerScale nodes. A PowerScale cluster may include nodes with and without secure boot. For more information, see UEFI secure boot .

Checking MD5 hash files

The OneFS installer tarball file contains a complete list of MD5 hashes for OneFS.

The MD5 hashes are in the `/boot/.md5` file. If you store them in a separate, secure location, those hashes are useful in verifying the authenticity and integrity of the files. You can generate hashes for each file and compare them to the values in the `.md5` file.

To generate a hash value:

```
# md5 <filename>
```

For example, the following command displays the hash of the kernel:

```
# md5 /boot/kernel.amd64/kernel.gz
MD5 (/boot/kernel.amd64/kernel.gz) = baac9b1d6a71030476a1c21e3e7c714d
```

Then, compare the returned hash value, for example: `baac9b1d6a71030476a1c21e3e7c714d`, to the hash value of `/boot/kernel.amd64/kernel.gz` in the `/boot/.md5` file.

Restricted CLI

The OneFS Restricted command-line interface (Restricted CLI) is an audited interface for managing a cluster without access to the underlying file system. This scenario is required for US federal government sites. It can provide a high level of security for business customers.

The Restricted CLI is independent of the STIG hardening profile. Restricted CLI is available on hardened clusters and nonhardened clusters.

The primary features of the Restricted CLI are:

- No file access
- Limited configuration activities
- Audited sessions
- Users with the correct privilege can view audit logs.
- Selected users who have special privilege can temporarily escape out of a Restricted CLI session. These users must have access to the root password or user of last resort. They are placed into the default OneFS CLI (by `zsh`).

You can implement Restricted CLI in two modes.

Table 25. Restricted CLI modes

mode	Explanation
Global restricted shell enabled `isi security modify --restricted-shell-enabled=true`	This mode requires all SSH logins to use the Restricted CLI. In this mode, a root account and the specially assigned escape mechanism are the only ways to bypass the Restricted CLI shell usage. This mode is required for compliance with the United States federal government Approved Products List (APL). The STIG hardening profile enables this mode. You may enable this mode on nonhardened clusters. This mode is not compatible with SmartLock Compliance mode.
Global restricted shell disabled `isi security`	This mode allows mixed assignments for shell usage. You can assign shell usage in a tiered approach. ● For security, assign most users to use Restricted CLI.

Table 25. Restricted CLI modes (continued)

mode	Explanation
`modify --restricted-shell-enabled=false` to disable completely, but you can set a restricted shell on specific users as necessary.	• For configuration flexibility, assign a select few administrators to the default OneFS CLI (`zsh`). This mode is available only on nonhardened clusters.

Session description

The following table describes the characteristics of a Restricted CLI session.

Table 26. Restricted CLI sessions

Topic	Restricted CLI
Required user privileges	User accounts must have specific login privileges to log in to OneFS. The following privileges are required for any logins, whether using the Restricted CLI or the default OneFS CLI. Access type: SSH access — Privilege: ISI_PRIV_LOGIN_SSH Access type: Web UI access — Privilege: ISI_PRIV_LOGIN_CONSOLE
Required shell assignment in user profile	The user profile defines a path for a default SSH shell. For Restricted CLI, this path is: `/usr/local/restricted_shell/bin/restricted_shell.py` In force mode, only users with the above path in their profiles can log in to any SSH session. If there are no users with the above path in their profile, no user can log in. **NOTE:** The root user is an exception. However, Dell does not recommend enabling a root user.
RBAC	The OneFS role-based access control (RBAC) works the same in the Restricted CLI as in the default OneFS CLI. The default privileges, users, and roles remain in effect in the restricted environment. The Restricted CLI adds another layer of restrictions to existing RBAC settings.
SSH description	The Restricted CLI is not a full-featured shell. Shell commands that access the underlying file system are not available. For example, the `cat` command is not available in Restricted CLI. In contrast, the default OneFS CLI is a `zsh` session.
Allowed commands	Allowed commands in Restricted CLI are: • `clear`—Clears the screen. • `isi` commands—Users can enter any OneFS `isi` command in the Restricted CLI. The commands and options that are not executable in the restricted environment return a permissions error. This response is the same that a user receives when trying to run a command that is not authorized because of RBAC permissions. • `isi_log_access`—Allows examination of local node log files in `/var/log`. • `exit` • `logout` • `isi_recovery_shell`—Enters the default OneFS CLI `zsh`. Available only for users that have a specially assigned privilege and can provide the password of root or user of last resort . **NOTE:** For `isi_recovery_shell` to work, the following setting must also be enabled: `isi security settings modify --restricted-shell-enabled=true`
Auditing	All commands that are issued in a Restricted CLI session are captured in the audit stream.

Table 26. Restricted CLI sessions (continued)

Topic	Restricted CLI
Sessions	● When a user logs in to the Restricted CLI, a message of the day (MOTD) appears. ● When an SSH session ends, the following message appears: `You are being disconnected from OneFS.` ● A Restricted CLI session is terminated after 10 minutes of inactivity.

Limitations

Root users

Root users can interact with OneFS without auditing. The root user can access all files. It is recommended that you follow OneFS best practices and do not use a root account.

It is acceptable to configure one user of last resort account.

SmartLock Compliance mode

You can use Restricted CLI is compatible with SmartLock Compliance mode when global restricted shell mode is disabled. You can assign a small set of users to use the default OneFS CLI.

By definition, SmartLock Compliance mode does not support a root account or account of last resort. Without such a user, enabling the global restricted shell is not compatible with SmartLock Compliance mode. The global restricted shell is too restrictive in Compliance mode for the following reasons:

- The recovery shell capabilities would not work. That feature requires a password for root or account of last resort.
- You cannot configure any user profile to use the default OneFS CLI.

Audit logs and message types

The recommended best practice for auditing configuration changes is to send audit records off cluster with the OneFS auditing service.

Restricted CLI default messaging

The Restricted CLI captures all commands that are issued in a session. The logging is in `/var/log/messages` on the node where the commands are issued. The messages have an IDENT value of `limited`. For example:

```
/var/log/messages:2022-12-14T02:00:03.131075+00:00 <1.5> onefs-1(id1) limited[21467]:
Called ['/usr/bin/isi_log_access', '--list'], which returned 0.
```

Users with the correct privileges can view these logs. See View log files.

Recommended audit best practice

The OneFS auditing module offers comprehensive features for capturing and preserving configuration changes. OneFS auditing includes the ability to forward logs off cluster. The following configurations are recommended:

- Enable the OneFS configuration change audit feature. This feature captures all configuration changes that are issued through the OneFS Platform API (PAPI). By definition, all Restricted CLI commands are PAPI commands.
- Enable syslog forwarding for configuration change auditing.
- Enable TLS for syslog forwarding.

For configuration steps for these recommendations, see the "Auditing and Logging" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Enable and disable global restricted shell

When global restricted shell is enabled, all users must use the restricted CLI. When global restricted shell is disabled, you can specify any shell in the user profile, including the Restricted CLI.

If global restricted shell is enabled, all user profiles must have the Restricted CLI pathname in their user profile as their default shell. Users without that setting cannot log in.

NOTE: The STIG hardening profile enables global restricted shell.

1. Log in to OneFS with `ISI_PRIV_CLUSTER` privilege.
2. To enable global restricted shell:
   a. Run:

   ```
   isi security settings modify --restricted-shell-enabled true
   ```

   b. Change all user profiles to "`/usr/local/restricted_shell/bin/restricted_shell.py`" . See Assign shell to user profile.
3. To disable the global restricted shell, run:

   ```
   isi security settings modify --restricted-shell-enabled false
   ```

   In this mode, user profiles can specify any shell, such as the Restricted CLI, the default `zsh`, `bash`, or `csh`.

Assign shell to user profile

A user profile specifies the shell that opens for an SSH session.

The step to assign or change a user shell depends on the authorization provider and the customer setup scenario.

For information about authentication providers, see the chapter "Home Directories" in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Assign a local user to the Restricted CLI:

```
isi auth users modify tom --shell "/usr/local/restricted_shell/bin/restricted_shell.py"
```

Emergency exit from a Restricted CLI session

Administrators with the correct privilege can exit the Restricted CLI and enter the default OneFS CLI. An emergency exit might be required for recovery operations or for unforeseen support issues in Restricted CLI.

The administrator prerequisites are:

1. Have ISI_PRIV_LOGIN_SSH or ISI_PRIV_LOGIN_CONSOLE privilege.
2. Have their login shell set to "`/usr/local/restricted_shell/bin/restricted_shell.py`".
3. Have ISI_PRIV_RECOVERY_SHELL privilege.

   NOTE: No default roles have this privilege by default. It is recommended that you create a unique role for this privilege and assign that role to a limited set of administrators.

4. Know the password for the root or user of last resort.
1. From within a Restricted Shell session, run the following command:

   ```
   isi_recovery_shell
   ```

   NOTE: For `isi_recovery_shell` to work, the following setting must also be enabled:

   ```
   isi security settings modify --restricted-shell-enabled=true
   ```

2. Provide the root account password when prompted.

If the administrator has the required privileges and provides the correct password, they are logged into an unrestricted OneFS session. Actions in the OneFS session are treated as root user actions and not logged or audited.

It is recommended that the root password or password of last resort be changed after the recovery shell is used.

View log files

The OneFS `isi_log_access` command provides access to local node logs.

1. Log in to a Restricted CLI session with ISI_PRIV_SYS_SUPPORT privilege.
2. View the syntax for the `isi_log_access` command.

```
% isi_log_access --help
```

3. List the filenames that have access by running: `isi_log_access`.

```
% isi_log_access --list
LAST MODIFICATION TIME          SIZE        FILE
Tue Oct  4 15:37:41 2022        55          alert.log
Mon Oct 10 00:30:00 2022        72          all.log
Mon Oct 10 00:30:00 2022        111         all.log.0.gz
Mon Oct 10 00:00:00 2022        118         all.log.1.gz
Sun Oct  9 00:30:00 2022        110         all.log.2.gz
Sun Oct  9 00:00:00 2022        117         all.log.3.gz
Sat Oct  8 00:30:00 2022        110         all.log.4.gz
Sat Oct  8 00:00:00 2022        117         all.log.5.gz
Fri Oct  7 00:30:00 2022        109         all.log.6.gz
Tue Oct  4 15:37:41 2022        55          audit_config.log
Tue Oct  4 15:37:41 2022        55          audit_protocol.log
Mon Oct 10 16:46:11 2022        27224       auth.log
Tue Oct  4 16:04:38 2022        0           bam.log
Tue Oct  4 15:37:41 2022        55          boxend.log
Tue Oct  4 15:37:41 2022        55          bwt.log
Tue Oct  4 15:37:41 2022        55          cloud_interface.log
Tue Oct  4 15:37:41 2022        55          console.log
Mon Oct 10 17:00:00 2022        75429       cron
Mon Oct 10 08:30:00 2022        8594        cron.0.gz
Sun Oct  9 21:15:00 2022        8338        cron.1.gz
Sun Oct  9 09:45:00 2022        8680        cron.2.gz
Mon Oct 10 03:01:13 2022        2130        daily.log
Mon Oct 10 00:30:00 2022        113         daily.log.0.gz
Mon Oct 10 00:00:00 2022        948         daily.log.1.gz

.
.
.
Sat Oct  8 00:30:00 2022        113         weekly.log.0.gz
Sat Oct  8 00:00:00 2022        134         weekly.log.1.gz
Tue Oct  4 15:37:41 2022        0           wtmp
Tue Oct  4 15:37:41 2022        55          xferlog
Tue Oct  4 16:09:28 2022        1591        apache2/httpd.py.log
Sat Oct  8 09:54:40 2022        109641      apache2/webui_httpd_access.log
Sat Oct  8 02:45:20 2022        3091        apache2/webui_httpd_error.log
Tue Oct  4 15:37:41 2022        55          apache2/access.log
Tue Oct  4 15:37:41 2022        55          apache2/error.log
Tue Oct  4 16:34:23 2022        201         apache2/apache2.log
Mon Oct 10 16:46:11 2022        26585       audit/auth.log
Tue Oct  4 15:37:41 2022        55          audit/smb.log
Mon Oct 10 16:46:11 2022        26585       audit/auth.log.20221004T153741.0883180
                                                        68Z.not-terminated
Tue Oct  4 15:37:41 2022        0           audit/isi_pw.log
Tue Oct  4 15:51:43 2022        225         audit/pw.log
Tue Oct  4 15:51:43 2022        225         audit/pw.log.20221004T153741.104921016
                                                        Z.not-terminated
Tue Oct  4 15:37:41 2022        0           audit/isi_pw.log.20221004T153741.10499
                                                        0229Z.not-terminated
Sat Oct  8 09:54:40 2022        111048      audit/httpd.log
Sat Oct  8 09:54:40 2022        111048      audit/httpd.log.20221004T153741.105053
```

```
                                                                644Z.not-terminated
```

4. View the contents of a file by running: `isi_log_access --view <file.log>`

```
% isi_log_access --view apache2/apache2.log
2022-04-06T08:56:43 Shutting down webui httpd and its children
2022-04-06T08:56:43 Stopping webui httpd
2022-04-06T08:56:43 Removing potentially stale pid file
2022-04-06T08:56:43 Starting webui httpd
2022-04-06T08:56:52 Stopping apache2
2022-04-06T08:56:56 Shutting down webui httpd and its children
2022-04-06T08:56:56 Stopping webui httpd
2022-04-06T08:56:56 Removing potentially stale pid file
2022-04-06T08:56:56 Starting webui httpd
2022-04-06T08:57:15 Shutting down webui httpd and its children
2022-04-06T08:57:15 Stopping webui httpd
2022-04-06T08:57:15 Failed to stop webui httpd:
2022-04-06T08:57:15
2022-04-06T08:57:15 Removing potentially stale pid file
2022-04-06T08:57:15 Starting webui httpd
```

View the contents of compressed files, use the `--zview` option.

```
% isi_log_access --zview daily.log.0.gz
```

5. Watch the end of a file.

The following example displays the end of the `messages` file and waits for more messages.

```
% isi_log_access --watch messages
2022-04-06T09:20:40.741647+00:00 <1.5> test1(id1) pkg[11797]: test-snapshot-b-
ps113325-001-1.0 installed
2022-04-06T09:20:45.043265+00:00 <3.3> test1(id1) isi_mcp[1859]: [0x801a30000]:
failed to get file /etc/mcp/override/sysctl.conf from namespace
2022-04-06T09:20:45.058405+00:00 <3.3> test1(id1) isi_mcp[1859]: [0x801a30000]:
failed to perform the pull from the namespace
2022-04-06T09:21:25.376730+00:00 <1.5> test1(id1) boxend.py[12524]: chassis 0 is
DTRDUONEFS1183321
2022-04-06T09:21:25.376771+00:00 <1.5> test1(id1) boxend.py[12524]: Caching internal
machine name succeeded.
2022-04-06T10:21:28.849025+00:00 <1.5> test1(id1) boxend.py[12524]: chassis 0 is
DTRDUONEFS1183321
2022-04-06T10:21:28.849064+00:00 <1.5> test1(id1) boxend.py[12524]: Caching internal
machine name succeeded.
2022-04-06T11:11:17.996214+00:00 <3.5> test1(id1) isi_snapshot_d[9463]:
cleanup_snapshot_papi_requests: Removed 1 files with no errors.
2022-04-06T11:21:32.324441+00:00 <1.5> test1(id1) boxend.py[12524]: chassis 0 is
DTRDUONEFS1183321
2022-04-06T11:21:32.324514+00:00 <1.5> test1(id1) boxend.py[12524]: Caching internal
machine name succeeded.
```

6. Search the contents of one or more files for a given pattern.

The following example searches `apache2/apache2.log` for occurrences of `webui`.

```
% isi_log_access --grep "webui" apache2/apache2.log
2022-04-06T08:56:43 Shutting down webui httpd and its children
2022-04-06T08:56:43 Stopping webui httpd
2022-04-06T08:56:43 Starting webui httpd
```

To search compressed files, use the `--zgrep` option.

```
isi_log_access --zgrep test1user daily.log.0.gz
```

isi_log_access

Displays log file content.

Syntax

```
isi_log_access
    [-h}]
    [--list]
    [--view filename]
    [--more filename]
    [--less filename]
    [--watch filename]
    [--grep pattern filename...]
    [--zgrep pattern filename...]]
```

Usage

The `isi_log_access` command cannot access files outside of `/var/log` on the node where the command is run.

Options

`-h`

Gets help for this command.

`--list`

Lists the filenames that are valid values for usage with `isi_log_access`.

`--view` *filename*

Displays file content on standard output.

`--more` *filename*

Pages through a file. Press Enter to progress one line at a time. Press the space bar to progress one screenful. To gain context on a screenful progression, scroll up one line to see the last line of the previous screen. Use `q` to exit.

`--less` *filename*

Operates the same as `--more`. On OneFS, `--more` and `--less` are the exact same binary that changes its behavior depending on if it was executed as less or more..

`--watch` *filename*

Displays the end of a file and new lines as they are added. To exit, use Ctrl+C which also closes the Restricted CLI session.

`--grep` *pattern filename* [*filename...*]

Searches one or more files for a specified pattern and displays the lines on standard output. This option uses a subset of the BSD grep program. It is intended for simple patterns and basic regular expressions. The pattern you provide in the command is passed to BSD grep.

`--zgrep` *filename* [*filename ...*]

Searches one or more compressed files (`.gz` files) for a specified pattern and displays the lines on standard output. This option uses the basic regular expression pattern from GNU zgrep.

4

United States Federal and DoD Standards and Compliance

OneFS supports deployments in United States federal and Department of Defense (DoD) networks.

Topics:

- SRG and STIG Compliance
- CAT 1 security requirement
- Onsite customer deployment guidance
- Upgrading a previously hardened cluster to OneFS 9.5.0.0 or later
- IPv6 defaults
- Security hardening module
- Recurring security checks

SRG and STIG Compliance

A OneFS cluster is secure in its default configuration. The United States federal government requires configurations and limitations that are more strict than the default OneFS configurations.

The United States Federal Department of Defense (DoD) requires specific security controls to protect its information systems and software. The DoD Security Requirements Guides (SRGs) and Security Technical Implementation Guides (STIGs) define required security controls. These DoD publications contain technical guidance measures to protect information systems and software that may otherwise be vulnerable to exploitation. OneFS clusters that are deployed in US government agencies might be required to comply with SRGs.

To help with SRG and STIG compliance, OneFS provides a security hardening module. This module automates configuration changes to meet defined guidelines. It also provides a reporting mechanism that checks the cluster for continued compliance with the guidelines.

NOTE: Security hardening helps to make a cluster comply with SRGs by changing OneFS cluster configurations. The ecosystem that surrounds the OneFS cluster must be secure as well.

Beginning in OneFS 9.7.0.0, security hardening is available in virtual OneFS environments.

CAT 1 security requirement

The United States Defense Information Systems Agency (DISA) requires identification and remediation instructions for CAT 1 vulnerabilities.

DISA defines Severity Category Codes that are used to assess the vulnerability security posture of a system. A CAT I Severity Category Code describes findings that allow primary security protections to be bypassed, allowing immediate access by unauthorized personnel or unauthorized use of superuser privileges.

The STIG hardening profile in the OneFS security hardening module has no known CAT 1 weaknesses. If a CAT 1 weakness is discovered after a OneFS version is released, those discoveries are disclosed to customers in a Dell Security Advisory (DSA).

DSAs notify customers about potential security vulnerabilities and their remedies for Dell products. The advisories include specific details about an issue and instructions to help prevent or alleviate that security exposure. Common Vulnerabilities and Exposures (CVEs) identify publicly known security concerns. A DSA can address one or more CVEs. All OneFS DSAs and the CVEs that they address are listed on the Product Advisories tab on the Dell Technologies Support site.

To receive email notifications of advisories, see Register for advisory notifications.

Onsite customer deployment guidance

Enabling STIG

STIG compliance requires the OneFS Security Hardening module and periodic compliance checks. For information about licensing and using the hardening module, see Security hardening module. For information about compliance checks, see Run hardening compliance reports. For information about automatic compliance checks, see Recurring security checks .

User management with STIG hardening

User account management on a OneFS cluster is the same with or without STIG hardening. All `isi auth` commands work the same whether the STIG profile is applied to a cluster.

Administrator functions

In general, administrator functions on a OneFS cluster work the same with or without STIG hardening. Some STIG rules limit scope or permissions.

OneFS does not provide a way to manually lock a user account. An administrator can manually disable a user account. For information about creating, disabling, deleting, and modifying local accounts, see the section "Managing local users and groups" in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

An administrator can unlock a user account with the following command:

```
isi auth users modify <user> --unlock
```

Upgrading a previously hardened cluster to OneFS 9.5.0.0 or later

The Hardening Module in releases before OneFS 9.5.0.0 is not compatible with the Hardening Module in OneFS 9.5.0.0 and later. For this reason, hardening must be turned off on the cluster before upgrading to OneFS 9.5.0.0 or later.

The upgrade workflow for previously hardened clusters is:

1. Before upgrading, use the appropriate hardening command to revert hardening on the cluster.
2. Perform all upgrade activities.
3. Reapply the STIG hardening profile on the cluster using the `isi hardening apply` command.

When upgrading from OneFS 9.5.0.0 and later, the hardening engine reapplies any previously applied profiles, thus resetting any manually applied settings that are set by the hardening profile. This ensures that the cluster remains in a hardened state after new configurations are applied, and ensures any updates to the hardening configuration are also applied.

IPv6 defaults

Administrators can enable and configure IPv6 using the CLI.

IPv6 configuration defaults are as follows:

- On OneFS 9.5.0.0 and later, IPv6 support is disabled by default on new clusters. You can override this default by specifying to enable IPv6 in the initial configuration script.
- On an existing OneFS cluster that has IPv6 enabled, an upgrade to OneFS 9.5.0.0 or later does not change the IPv6 configurations. In this case, IPv6 remains enabled.
- IPv6 configuration options are disabled by default when you first enable IPv6 support. You can enable each option using the `isi network external modify` command.

The following table shows the IPv6 configuration options and how to change their configuration.

Table 27. IPv6 defaults

Option	Description	Command
Enable or disable IPv6 on the cluster.	Global setting	`isi network external modify --ipv6-enabled (true|false)`
Generate link-local IPs.	Global setting **NOTE:** Disabling this option does not impact backend Ethernet clusters.	`isi network external modify --ipv6-generate-link-local (true|false)`
Enable auto configuration.	Global setting that discovers and applies network settings from the IPv6 router advertisements (RAs).	`isi network external modify --ipv6-auto-config-enabled (true|false)`
Enable or disable ICMP redirects.	Global setting that controls if OneFS processes ICMP6 redirect messages.	`isi network external modify --ipv6-accept-redirects (true|false)`
Enable or disable Duplicate Address Detection (DAD) on the cluster.	Global setting	`isi network external modify --ipv6-dad (enabled|disabled|1-10)` Setting to `true` enables the behavior and sets the default timeout for finding duplicate addresses to five seconds. Setting the value to an integer enables the behavior and set the timeout to that value.
Enable or disable DAD on SmartConnect Service IPs (SSIPs).	Controls whether to perform DAD on SSIPs.	Enable global DAD and SSIP DAD using the `isi network external modify --ipv6-ssip-perform-dad (true|false)`
Enable or disable DAD on individual static network pools.	Applies to a specific network pool.	Enable global DAD using the `isi network pools modify <pool id> --ipv6-perform-dad (true|false)`

For information about configuring IPv6 options, see the "IPv6" section under "External Networks" in the "Networking" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Security hardening module

Security hardening is a separately licensed OneFS module. It is intended primarily for United States federal government accounts. This module provides automated support for compliance with FIPS, SRG, and STIG requirements.

Most hardening commands require the ISI_PRIV_HARDENING privilege.

Licensing

Security hardening is a licensed software feature of OneFS.

For information about obtaining, activating, and viewing the status of licenses, see the Licensing section in the chapter "General cluster administration" of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Hardening concepts

The Hardening Module helps to ensure that a cluster complies with a defined set of rules.

With a single command, you can apply a long list of predefined configuration rules to your cluster. With hardening reports, you can review the rules and see whether your cluster is in compliance with each rule.

Hardening profiles

The Hardening Module is profile-based.

A hardening profile is a collection of rules that define cluster configurations. The defined configuration changes make the cluster comply with security guidelines.

To apply a hardening profile to a cluster, use `isi hardening` commands or the OneFS Platform API (PAPI). Hardening applies to all nodes in the cluster and extends to new nodes that are added to the cluster.

Supported profile

OneFS supports one hardening profile. The profile name is STIG.

Smart rules

When possible, the rules in the STIG profile use the concept of smart rules to preserve current security settings.

Hardening does not change a configuration to a value that is less secure than the current setting. Smart rules compare the current setting to the expected hardened value. If the existing setting is already more secure than the hardened value, the existing setting remains in effect.

For example, an administrator might change the password policy to the strictest level possible. The STIG hardening profile requires a medium strict password policy. If you apply the STIG profile, smart rules ensure that the password policy remains at the strict level.

Smart rules only apply to configuration settings that are controlled with a single cluster-wide value. They do not apply to rules that are set separately on each node. See Run hardening compliance reports for information about distinguishing cluster-wide compared with node-specific rules.

Smart rules also do not apply to configurations that require edits to a text file. The hardening profile overwrites text file configurations.

Smart rules are not implemented by the `isi hardening disable` command. That command returns the cluster to the system default settings.

Hardening commands

Use the OneFS `isi hardening` commands to manage and apply profiles.

The following table shows the actions available when you have a Hardening Module license. These actions are also available using the PAPI.

Table 28. Hardening commands

Action	CLI command
View available profiles.	`isi hardening list`
Discover whether a profile is applied on the cluster or not.	`isi hardening list`
Apply a profile to the cluster.	`isi hardening apply <profile>`
Return the security settings to the original installed default values.	`isi hardening disable <profile>`
Gather compliance information about the cluster and all nodes.	`isi hardening report create`
View the list of rules in a profile and the status of the cluster against each rule.	`isi hardening report view <profile>`

Using the STIG profile

The STIG hardening profile is designed to make the OneFS cluster compliant with United States federal government Approved Product List (APL) requirements.

Unsupported and disabled services

Some services that run successfully on OneFS 9.8.0.0 clusters in nonhardened mode do not offer support for operating under the STIG hardening profile.

These services either cannot support the FIPS cryptography or cannot run on the infrastructure that the STIG hardening profile requires.

The STIG hardening profile disables these services. Enabling those services after applying the STIG profile is not supported and renders the cluster noncompliant.

The following services are unsupported in the STIG hardening profile:

- Dell Common Event Enabler (CEE)
- Common Anti-Virus Agent (CAVA)
- SmartLock Compliance
- NIS Authentication Provider
- Duo MFA Provider

Other services may not support FIPS cryptography. For a list of all rules in the STIG hardening profile, see Run hardening compliance reports.

View a complete list of STIG profile rules

You can list all rules in the STIG profile. You can see a comparison of the expected settings after applying the profile compared to the current settings on your cluster.

The following table summarizes how to use the hardening reports to research the rules in the STIG profile. For detailed steps and examples of the output, see Run hardening compliance reports.

Table 29. STIG profile reporting

Command for reporting on the STIG profile	Description
`isi hardening reports create`	This command gathers information from the cluster. It is a required first step before using the `isi hardening reports view` command.
`isi hardening reports view STIG`	This command lists all the rules in the profile and the location of the relevant configuration setting.
`isi hardening reports view STIG --verbose`	The verbose option adds the expected value for each rule and the values that are discovered on your cluster. The cluster settings that appear in the reports reflect the status at the time the `isi hardening reports create` command was last run.

Table 30. STIG hardening rules

STIG hardening rule	Description
ssh_accept_only_public_key	This rule forces all users to login using a public key.
ssh_certificate_authority_configured	Checks that there is a certificate authority configured.
ssh_ldap_certificate_authority_configured	Checks that there is an LDAP server that is configured as a certificate authority.
ssh_allow_root_pw_auth	• Allows the root and compadmin accounts to login using a password.

Table 30. STIG hardening rules (continued)

STIG hardening rule	Description
	• The relevant STIG requires that there is an account of last resort that can log in, this rule allows password auth for those accounts.

Required: Update password hash scheme

Before applying the STIG hardening profile, you must change the hash scheme for the root account password to a FIPS-compliant scheme.

The default password hash type is `NTHash`. That scheme is not FIPS-compliant. The following steps change the hash type to `SHA512`.

1. Login as root.
2. Set the password hash type to a FIPS 140-2-compliant value in the file provider.

```
isi auth file modify System --password-hash-type=SHA512
```

3. Set the password hash type to a FIPS 140-2-compliant value in the local provider.

```
isi auth local modify System --password-hash-type=SHA512
```

4. Reset passwords for the account of last resort and root accounts.

   This step is required to encode the passwords using the updated hash type.

   All accounts with a UID equal to 0 must reset their password whether they are defined in the file provider or local. You can reset passwords using the user-name or numeric user identifier 0.

```
isi auth users change-password root
or
isi auth users change-password --uid 0
```

Apply the hardening profile

Harden a cluster by applying the STIG profile to the cluster.

Before applying the STIG profile, ensure that the steps in Required: Update password hash scheme are completed on the cluster.

1. Login with ISI_PRIV_HARDENING privilege.
2. Apply the STIG profile.

```
# isi hardening apply STIG
..........
```

   OneFS works in the background to check settings for each rule in the profile on each node in the cluster. OneFS changes the settings that are not in compliance with a rule.

3. If the command returns any error messages, fix the reported conditions and rerun the command.
4. Wait for the following message to appear:

```
Hardening operation complete.
```

5. Restore SSH access. Do this step before logging out to ensure that you are not locked out.

```
isi ssh settings modify --host-key-algorithms='+ssh-dss,ssh-dss-cert-v01@openssh.com'
```

You can rerun hardening at any time. See Maintain compliance after hardening.

Adjust user accounts after hardening

Some user account settings must be changed after applying the STIG profile.

The STIG profile enforces rules that may require user account changes.

1. Change the shell pathname on all user accounts that log in to an SSH session.

   All SSH logins must use the Restricted CLI after the STIG profile is applied. The shell path must be changed to `"/usr/local/restricted_shell/bin/restricted_shell.py"`.

   For more information, see Assign shell to user profile.
2. Instruct users to change their passwords to comply with the STIG password complexity and password length rules.

Table 31. Password complexities

Criteria	Requirement
Minimum password length	15 characters
Required character types	lowercase, numeric, symbol, uppercase
Repeating character sets	not allowed

Maintain compliance after hardening

In a hardened cluster, certain administrative actions could cause noncompliance.

The Hardening Module identifies some noncompliance issues immediately. For example, if any file or local user has an insufficiently safe password, that account is disabled automatically.

The following steps describe proactive ways for you to catch noncompliance issues and how to correct those issues.

1. After adding new users, changing user profiles, adding zones, or changing cluster configurations, check for noncompliance using one of the following methods.

Option	Description
Run the **`isi hardening reports view`** command.	The hardening reports detect noncompliance and provide enough details for you to address the issues.
Run the **`isi security check start`** command.	You can run this command on demand at any time. It runs the hardening reports in addition to performing other security checks.
Run the **`isi security check [...]`** command on a scheduled basis.	The `isi security check` command runs routinely as a cron job.

2. Based on the output of the security reports, bring the cluster back into compliance using one of the following methods.

Option	Description
Use OneFS commands to manually correct issues.	Based on the output of the security reports, choose specific OneFS CLI commands to reconfigure noncompliant issues. For example, if the reports show that new user accounts are not in compliance, use `isi auth` commands to bring those accounts into compliance. This method provides the following advantages: ● It preserves any custom changes that you made after the STIG profile was applied. ● It offers the freedom to configure the exact values that you need, rather than using the STIG profile defaults.
Reapply the STIG profile.	The `isi hardening apply` command catches all new instances of noncompliance and fixes them. For example, administrators can add new users without enabling certain hardening profile settings that are required for STIG compliance. When you reapply the STIG profile, the hardening engine correctly sets those profile values in the new accounts. **NOTE:** This action applies changes uniformly across the cluster. If you made customized changes on settings that the STIG profile monitors and changes, your customizations are lost when the profile is reapplied.

Reset configurations to the cluster default values

Administrators can disable an applied profile and reset configurations to the original cluster default settings.

1. Run the `isi hardening disable` command.

```
isi hardening disable STIG
```

2. Restore SSH access. Do this step before logging out to ensure that you are not locked out.

```
isi ssh settings modify --host-key-algorithms='+ssh-dss,ssh-dss-cert-v01@openssh.com'
```

List profile name and view status

List the profile name and whether it is applied on the cluster.

Run `isi hardening list`.

```
isi hardening list
Name           Description                                                      Status
-------------------------------------------------------------------------------------------
 root-lockdown Enable security settings that disable the root account.   Not Applied
 STIG          Enable all STIG security settings (includes STIG_Legacy)  Applied
-------------------------------------------------------------------------------------------
Total: 2
```

The status indicates whether the profile is applied to the cluster. Values are:

Table 32. Profile statuses

Status	Description
Applied	The profile is applied on the cluster. Configuration settings that were not in compliance with rules in the profile were changed. **NOTE:** Administrators can change configurations after the profile is applied. Use the hardening reports to ensure continuing compliance status.
Not Applied	The profile is not applied on the cluster.

Run hardening compliance reports

Hardening reports list each rule in the profile and show status information about cluster compliance with the hardening rules.

To ensure that your cluster remains compliant with STIG standards, periodically run a hardening report. The hardening report checks all security configuration settings against the profile requirements. If the current configuration is less strict than the defined profile value, the report shows that the cluster is out of compliance.

NOTE: Values that are more strict than the defined profile value are in compliance.

For settings that can potentially be set or changed on a node, the reports show status per node. You can generate default or detailed (verbose) reports.

- The default report shows the status for each rule per node or clusterwide.
- A verbose report shows the status plus the configured and expected values for each rule, per node or clusterwide.

Noncompliance

Clusters or nodes can become noncompliant by manual changes to settings after a hardening profile is applied. Administrators with appropriate permissions might change configurations that are less strict than the applied hardening profile values.

To handle noncompliance, you can either:

- Reapply the profile, which resets out of compliance configurations to the value defined in the profile.
- Manually change a configuration so that it is in compliance.

Create report information

Use `isi hardening reports create` to gather and store detailed information about compliance status. The hardening engine uses this information later to generate reports.

- A Hardening Module license is required.
- The user must have ISI_PRIV_HARDENING privilege.

The `isi hardening reports create` command gathers status for all rules on all nodes in the cluster. The information is stored in `\ifs` for use later by the hardening engine to format requested reports. To update status information, rerun this command.

1. Gather compliance status information:

   ```
   isi hardening reports create
   ```

   This command may take some time to run.
2. To view the results, see the next task.

View hardening report

Use `isi hardening reports view` to format and print hardening compliance status reports.

- A Hardening Module license is required.
- The user must have ISI_PRIV_HARDENING privilege.

1. Display a default report for rules in the STIG hardening profile.

   ```
   isi hardening reports view STIG
   ```

   The output defaults to table format. To see additional options, use `--help`.

   The following example shows the beginning of the report on standard output.

   ```
   test-2# isi hardening reports view STIG
   Name                              Location  Status  Setting

   ---------------------------------------------------------------------------
                        ----------
   logout_zsh_clear_screen           Node 1    Applied /etc/zlogout

   logout_profile_clear_screen       Node 1    Applied /etc/profile

   logout_csh_clear_screen           Node 1    Applied /etc/csh.logout

   set_umask_77_root_cshrc           Node 1    Applied /root/.cshrc

   set_umask_077_root_profile        Node 1    Applied /root/.profile

   set_umask_77_etc_cshrc            Node 1    Applied /etc/csh.cshrc

   set_umask_077_etc_profile         Node 1    Applied /etc/profile

   set_umask_077_etc_login_dot_conf  Node 1    Applied /etc/login.conf

   set_umask_077_root_zshrc          Node 1    Applied /root/.zshrc

   require_password_single_user_mode Node 1    Applied /etc/ttys

   password_min_length_pam_01        Node 1    Applied /etc/pam.d/system

   password_min_length_pam_02        Node 1    Applied /etc/pam.d/other
   .
   ```

```
.
.
```

The following table describes the fields in the report.

Table 33. Report fields

Name	Description
Name	This field indicates the rule name.
Location	This field indicates a node identifier or the word "Cluster" to indicate the settings are clusterwide.
Status	This field indicates the status of the rule on the node or cluster: ● Applied—The node or cluster is compliant with the rule. **NOTE:** This status can appear on clusters that do not have the hardening profile applied. This condition happens because many SRG requirements are accepted best practices that OneFS implements by default. ● Not Applied—The node or cluster is noncompliant with the rule and the STIG hardening profile is not applied. ● Errors—The system encountered an error while trying to check the status of the rule. To discover more information about node errors, see the next step.
Setting	The location of the configuration setting that the rule verifies.

2. Display a verbose report in list format for rules in the STIG profile.

```
isi hardening reports view STIG --verbose --format list
```

The following example shows the beginning of the report on standard output.

```
test-2# isi hardening reports view STIG --verbose --format list
      Name: logout_zsh_clear_screen
  Location: Node 1
    Status: Applied
   Setting: /etc/zlogout
   Current: N/A
  Operator: N/A
Prescribed: N/A
   Message: Text clear was found as expected
--------------------------------------------------------------------------------
      Name: logout_profile_clear_screen
  Location: Node 1
    Status: Applied
   Setting: /etc/profile
   Current: N/A
  Operator: N/A
Prescribed: N/A
   Message: Text trap 'clear; echo You are being disconnected from OneFS' EXIT was
found as expected
--------------------------------------------------------------------------------
.
.
.
```

More rules later in the list illustrate the Current, Operator, and Prescribed fields.

```
--------------------------------------------------------------------------------
      Name: disable_webui_access_ran
  Location: Cluster
    Status: Applied
   Setting: webui_ran_access
   Current: False
  Operator: ==
Prescribed: False
   Message:
--------------------------------------------------------------------------------
```

```
       Name: set_ssh_config_client_alive_interval
   Location: Cluster
     Status: Applied
    Setting: client_alive_interval
    Current: 200
   Operator: ==
 Prescribed: 200
    Message:
--------------------------------------------------------------------------------
       Name: set_nfs_default_security_flavors
   Location: Cluster
     Status: Applied
    Setting: /protocols/nfs/settings/export:security_flavors
    Current: ['krb5p']
   Operator: ==
 Prescribed: ['krb5p']
    Message:
--------------------------------------------------------------------------------
```

The following table describes the fields in the verbose report.

Table 34. Verbose report fields

Column header	Description
Name	This field indicates the rule name.
Location	This field indicates a node identifier or the word "Cluster" to indicate the settings are clusterwide.
Status	This field indicates the status of the rule on the node or cluster: ● Applied—The node or cluster is compliant with the rule. **NOTE:** This status can appear on clusters that do not have the hardening profile applied. This condition happens because many SRG requirements are accepted best practices that OneFS implements by default. ● Errors—The node or cluster is noncompliant with the rule.
Setting	The location of the configuration setting that the rule verifies.
Current	This field indicates the configured value on the node or cluster setting.
Operator	The operator is used to compare the prescribed value to the current value.
Prescribed	The value that is expected for compliance. Not Applicable (N/A) means that the configuration cannot be stated as a value. For example, the configuration may be contained in a file.
Message	This field provides additional information about the rule.

If you make configuration changes, you must rerun `isi hardening reports create` before those changes are reflected in the `isi hardening reports view` output.

Recurring security checks

OneFS runs recurring security checks that include verifications of the STIG hardening profile settings.

The security check does the following:

- It runs the hardening compliance reports to check the current configuration against the STIG hardening profile.
- It runs the checks in the security checklist in the OneFS HealthCheck utility.
- It runs the `periodic(8)` FreeBSD security checks.

The security check runs automatically and on-demand:

- The security check is a cron job. The job runs across the cluster every Monday at 4:00 am.
- The security check runs automatically on a node at every reboot.

- Administrators can run a security check on demand with the `isi security check start` command or check PAPI. These security checks can run across the cluster or on a specified list of nodes.

To see the results of the latest security check, use the `isi security check report view` command.

The default action when anomalies are discovered is to issue a CELOG event. You can change the default action using the `isi security check settings modify` command. The supported actions are:

- Send a CELOG event.
- Reboot the affected node.
- Shut down the affected node.

For more information about the security check, how to configure options, and how to run an on-demand security check, see Security checks and verifications .

5

FIPS Standards and Compliance

This chapter describes how OneFS supports the FIPS 140-2 standard.

Topics:

- FIPS 140-2 compliance
- Enable FIPS mode
- Required: Update password hash scheme
- Disable FIPS mode
- Verify and reset FIPS mode
- Certified cryptographic modules
- FIPS and SSO

FIPS 140-2 compliance

You can configure a OneFS cluster to use FIPS cryptographic modules by following the instructions in this chapter.

Federal Information Processing Standard (FIPS) 140-2 defines United States federal government security requirements for cryptographic modules. FIPS defines four levels of security that protect sensitive but unclassified information in IT systems. To learn more about FIPS 140, see the FIPS 140 publication in Appendix A.

Enabling FIPS mode does the following:

- It enforces FIPS cryptography by enabling the FIPS cryptographic algorithms and restarting appropriate services that use them. See the section "Certified cryptographic modules" for a list of OneFS modules that support FIPS cryptography.

  NOTE: The services that do not support FIPS remain running after FIPS mode is enabled. You may optionally disable those services.

- It configures OpenSSL to support FIPS.

For lists of the FIPS algorithms that FIPS mode supports, see:

- Cryptographic inventory for HTTPS in FIPS enabled mode.
- Cryptographic inventory for OpenSSH in FIPS enabled mode.

You can enable and disable FIPS mode using the CLI or PAPI.

NOTE: The STIG hardening profile enables FIPS mode and also disables the services that do not support FIPS. For more information about the STIG profile, see the chapter "United States Federal and DoD Standards and Compliance."

Enable FIPS mode

Enable the cluster to use FIPS related cryptographic algorithms.

The `--fips-mode-enabled` option acts as a switch, ensuring that all FIPS-related configurations are either set for FIPS mode, or returned to their non-FIPS mode system defaults. When enabled, it ensures that all FIPS mode configurations are set accordingly.

1. Log in to OneFS with `ISI_PRIV_CLUSTER` privilege.
2. Enable FIPS mode.

   ```
   isi security settings modify --fips-mode-enabled=true
   ```

   The `--fips-mode-enabled` option acts as a switch, ensuring that all FIPS-related configurations are either set for FIPS mode or returned to their non-FIPS mode system defaults. When enabled, it enables FIPS mode, ensuring all configurations

are set accordingly. Enabling FIPS mode requires active confirmation that can be bypassed using the `--force` option. It displays the warning that it disables NTHASH password support, which means the OneFS web administration interface login is inaccessible. Administrator accounts can still use SSH, although the OneFS web administration interface is inaccessible. Users not using FIPS-compliant algorithms must update their passwords.

Required: Update password hash scheme

Before enabling FIPS mode, you must change the hash scheme for the root account password to a FIPS-compliant scheme.

The default password hash type is `NTHash`. That scheme is not FIPS-compliant. The following steps change the hash type to `SHA512`.

1. Login as root.
2. Set the password hash type to a FIPS 140-2-compliant value in the file provider.

```
isi auth file modify System --password-hash-type=SHA512
```

3. Set the password hash type to a FIPS 140-2-compliant value in the local provider.

```
isi auth local modify System --password-hash-type=SHA512
```

4. Reset passwords for the account of last resort and root accounts.

   This step is required to encode the passwords using the updated hash type.

   All accounts with a UID equal to 0 must reset their password whether they are defined in the file provider or local. You can reset passwords using the user-name or numeric user identifier 0.

```
isi auth users change-password root
or
isi auth users change-password --uid 0
```

Disable FIPS mode

You can return the cluster to non-FIPS mode. You can return the cryptographic set to the non-FIPS default.

1. Log in to OneFS with `ISI_PRIV_CLUSTER` privilege.
2. Disable FIPS mode or ensure that cryptography is set to the system default.

```
isi security settings modify --fips-mode-enabled=false
```

   If cryptography was changed on the cluster, you can always return to the default set by reissuing `--fips-mode-enabled=false`, even if the mode is already false.

All cryptographic modules are returned to their system default values.

Verify and reset FIPS mode

Ensure that FIPS settings remain accurate.

1. Log in to OneFS with `ISI_PRIV_CLUSTER` privilege.
2. View the current FIPS mode setting.

```
isi security settings view
```

   It is possible for authorized administrators to change some FIPS-related configurations individually using other commands. Those independent actions can make the cluster noncompliant. For example, the `isi ssh` command can change the cryptographic algorithms in use to a noncompliant set even when FIPS mode is enabled. In that case, the output of the `isi security settings view` command may not accurately reflect the true state of FIPS compliance.

3. Reset FIPS mode to ensure FIPS settings.

   You can ensure FIPS settings by periodically reissuing the `isi security settings modify --fips-mode-enabled=true` command at any time to reset all configurations.

   ```
   isi security settings modify --fips-mode-enabled=true
   ```

4. Verify that the ssh cryptographic settings are accurate.

   ```
   isi ssh settings view
   ```

   Compare the cryptographic algorithms in the output to the ones that are listed in Enable FIPS mode . If there are any differences, use `isi ssh settings modify` to update the algorithms.

Certified cryptographic modules

OneFS uses validated cryptographic modules.

The National Institute of Standards and Technology (NIST) participates in the Cryptographic Module Validation Program (CMVP). The CMVP promotes the use of validated cryptographic modules. It provides Federal agencies with a security metric to use in procuring equipment containing validated cryptographic modules. For information about CMVP, see Cryptographic Module Validation Program.

When FIPS mode is enabled, OneFS uses validated modules in the following areas:

- NTP server
- HTTP server
- SSH server
- CloudPools
- Key Manager

In addition, all self-encrypting drives (SEDs) within PowerScale platforms use firmware that is FIPS 140-2 validated. For more information, see the Data-at-Rest Encryption white paper.

FIPS and SSO

FIPS mode and SSO are independent of each other and compatible with each other in OneFS. No special procedures or configurations are required.

6

Security Best Practices

Topics:

- Overview
- General cluster security best practices
- Login, authentication, and privileges best practices
- SNMP security best practices
- SSH security best practices
- Data-access protocols best practices
- Web interface security best practices
- CloudPools best practices

Overview

Administrators can maximize security on PowerScale clusters using the best practices here. Consider these recommendations in the context of your specific business policies and use cases.

Although root-level privileges are required to perform many of these procedures, the following options are available instead:

- Restrict the root account, and use an RBAC account with root privileges.
- Restrict the root account, and use the `sudo` command with privilege elevation.

If a procedure requires you to "log in as root," you must log in using a business-authorized privileged account. Examples are root, an RBAC account with root privileges, or `sudo`.

NOTE:

Ensure that the latest security updates are installed. For more information, see the PowerScale OneFS Current Patches document on the Dell support site.

Persistence of security settings

Some of these best-practice configurations do not persist after OneFS is upgraded, and might not persist after a patch for OneFS is applied. For best results, track which best practices you implement, so that if the settings do not persist, you can configure them again.

The following lists all the best practices that are described in this chapter. Use this list to implement security settings on the cluster.

General cluster best practices	• Protect /ifs and /ifs/data. • Set BIOS password for node physical security • Set iDRAC user passwords • Disable USB boot on nodes. • Create a login message. • Change password on backend switches • Consider implementing UEFI secure boot. • Confirm install authenticity and integrity. • Set a timeout for idle CLI sessions. • Set a timeout for idle SSH sessions. • Forward audited events to a remote server • Set firewall security • Disable OneFS services that are not in use. • Configure WORM directories using SmartLock.

	• Backup cluster data • Specify an NTP time server.
Login, authentication, and privileges best practices	• Restrict root logins to the cluster. • Use RBAC accounts instead of root. • Disable the root account for SSH sessions. • Privilege elevation: Assign select root-level privileges to nonroot users. • Use zones other than System zone for protocol access. • Restrict authentication by external providers. • Use secure connections to an LDAP server. • Set password policy
SNMP best practices	• Use SNMPv3 for cluster monitoring. • Keep SNMP disabled except for SNMP monitoring. • Change the default community string for SNMPv2.
SSH best practices	• Restrict SSH access to specific users and groups. • Disable root SSH access to the cluster. • Manage SSH host keys.
Data-access protocols best practices	• Use a trusted network to protect files and authentication credentials that are sent in cleartext. • Use compensating controls to protect authentication credentials that are sent in cleartext. • Use compensating controls to protect files that are sent in cleartext. • Initial Sequence Numbers (ISNs) through TCP connections • FTP best practices • HDFS best practices • HTTP file protocol best practices • NFS best practices • SMB best practices • SMB signing
Web interface best practices	• Replace the TLS certificate. • Remove persistent older versions of TLS.

General cluster security best practices

The following general security recommendations can be applied to any cluster.

Protect /ifs and /ifs/data

Ensure that permissions on the `/ifs` and `/ifs/data` directories are set to 755. This setting preserves administrative write permissions and prevents unintended access.

NOTE: The calculated mode of the permissions that are using ACLs might show that these directories having a different UNIX permission than what is present. If there are ACLs set, there will be a plus sign (+) after the permissions. If that + is present, the displayed calculated permissions do not match the baseline permissions.

For new installations of OneFS 9.3.0.0 and later, the recommended permission of 755 is set by default.

For upgrades to OneFS 9.3.0.0 and later from earlier releases, the upgrade does not change the permissions from the current setting. If you are doing an upgrade, check the permissions on `/ifs` and `/ifs/data`. If needed, change the permissions as follows:

```
chmod 755 /ifs /ifs/data
chmod +a# 1 group admin allow dir_gen_write,std_write_dac,delete_child /ifs /ifs/data
chmod +a# 1 user compadmin allow dir_gen_write,std_write_dac,delete_child /ifs /ifs/data
```

Set BIOS password for node physical security

There are many disruptive changes that could occur with BIOS access. Dell Technologies recommends that you protect the physical security of a node by setting a password to secure access to BIOS operations. The steps to set a password are different for various node models.

Set BIOS password using BIOS options

These steps apply to the following nodes:

- H-Series: H710, H7100
- A-Series: A310, A3100

1. Reboot.
2. **F2** (to enter Setup).
3. Select **System BIOS**.
4. Select **System Security**.
5. Select **Setup Password**
6. For **Create New Password**, enter the new password.
7. For **Confirm New Password**, reenter the new password.
8. **ESC** (to return and exit).

Set BIOS password using BIOS options

These steps apply to the following nodes:

- F-Series: F800, F810
- H-Series: H400, H500, H600, H5600, H700, H7000
- A-Series: A200, A2000, A300, A3000

1. Reboot.
2. **F2** (to enter Setup).
3. Use arrows to select **Security**.
4. Select **Administrator Password**.
5. For **Create New Password**, enter the new password.
6. For **Confirm New Password**, reenter the new password.
7. **F4** (Save and Exit).

Set BIOS password using iDRAC

The following nodes have an Integrated Dell Remote Access Controller (iDRAC) for management purposes. These steps apply to those nodes:

- F-Series: F200, F600. F900

1. Log in to iDRAC.
2. Select **Configuration**.
3. Select **BIOS Settings**.
4. Expand **System Security**.
5. Enter password in **Setup Password**.
6. Reenter password in **Confirm Setup Password**.
7. Click **Apply**.
8. Click **Apply And Reboot**.

Set BIOS password using BIOS options on older supported nodes

These steps apply to the following node:

- X-Series: X210

1. Reboot.
2. **F2** (to enter Setup).
3. Use arrows to select **Security**.
4. Select **Set Administrator Password**.
5. In **Create New Password**, enter the new password.
6. In **Confirm New Password**, reenter the new password.
7. **F10** (Save).
8. ESC (Exit).

Set iDRAC user passwords

The following nodes have an Integrated Dell Remote Access Controller (iDRAC) for management purposes.

F-series: F200, F600, F900

There are many disruptive changes that could occur with iDRAC access. Dell Technologies recommends that you protect the physical security of nodes with iDRACs by setting passwords to secure access to iDRAC operations.

1. Log in to iDRAC.
2. Select **iDRAC Settings**.
3. Select **Users**.
4. For each user, ensure that a password is set and that it is a secure nondefault password.

Disable USB ports across the cluster

USB ports are enabled on all Isilon and PowerScale nodes by default. Dell Technologies recommends that you disable the USB ports on all nodes as a security best practice.

NOTE: The STIG hardening profile disables all USB ports.

A disabled USB port prevents USB devices from interacting with OneFS. By disabling USB ports, you prevent unauthorized copying of data onto USB storage devices. A CLI command can disable (or enable) all USB ports across the cluster.

Manage all USB ports across the cluster.

- Disable all USB ports:

```
isi security settings modify --usb-ports-disabled=true
```

- Enable all USB ports:

```
isi security settings modify --usb-ports-disabled=false
```

Enable and disable USB ports on individual nodes

USB boot ports are enabled on all Isilon and PowerScale nodes by default. Dell Technologies recommends that you disable the USB ports on all nodes across the cluster for security reasons. If you need a USB port to update the OneFS version, reimage a node, or perform a field replaceable unit (FRU) operation, you can temporarily reenable the port on an individual node.

The steps to manually enable (and disable) USB ports on individual nodes are different for the various node types.

Enable (or disable) USB boot with BIOS

These steps apply to the following node types:

- H-Series: H710, H7100
- A-Series: A310, A3100

1. Reboot the node.
2. **F2** to enter Setup.
3. Select **System BIOS**.
4. Select **Integrated Devices**.
5. Select **User Accessible USB Ports**.
6. Select **All Ports On** to enable USB ports, or **All Ports Off** to disable USB ports.
7. **F4** to Save and Exit.

Enable (or disable) USB boot with BIOS

These steps apply to the following node types:

- F-Series: F800, F810
- H-Series: H400, H500, H600, H5600, H700, H7000
- A-Series: A200, A2000, A300, A3000

1. Reboot the node.
2. **F2** to enter Setup.
3. Use arrows to move to **Advanced**.
4. Select **USB Configuration**.
5. Select **USB Mass Storage Driv** * or *__USB Mass Storage Driver Support__ .

   NOTE: The field is labeled differently on different nodes.

6. Select **Enabled** to enable the port, or **Disabled** to disable the port.
7. **F4** to Save and Exit.

Enable (or disable) USB boot with iDRAC

These steps apply to nodes that have an Integrated Dell Remote Access Controller (iDRAC) for management purposes. The node types with an iDRAC are:

- F-series: F200, F600, F900

1. Log in to iDRAC.
2. Select **Configuration**.
3. Select **BIOS Settings**.
4. Expand **Integrated Devices**.
5. In **User Accessible USB Ports**:
   - Select **All Ports On** to enable.
   - Select **All Ports Off** to disable.
6. Click **Apply**.
7. Click **Apply And Reboot**.

Enable (or disable) USB boot with BIOS on older supported nodes

These steps apply to the following node types.

- X-Series: X210

1. Reboot.
2. **F2** (to enter Setup).
3. Use arrows to move to **Boot Options**.
4. Select **USB Boot Priority**.
5. Select **Enabled** to enable the port or **Disabled** to disable the port.
6. **F10** (Save).
7. ESC (Exit).

Enable (or disable) USB boot with OneFS

You may be able to use OneFS commands to disable or enable USB boot for a local node or across a PowerScale cluster. These instructions apply to nodes that support the `isi_config_usb` command.

To locate the command:

```
# /usr/bin/isi_hwtools/isi_config_usb
usage: isi_config_usb [-h] [--nodes NODES] --mode {display,on,off}

isi_config_usb: error: argument --mode is required
#
```

NOTE: As indicated in the output, the `--mode` argument is always required.

- `isi_config_usb --mode {display,on,off}` is supported on the following nodes running OneFS 9.2.1.0 and later:
  - F-series: F200, F600, F900
  - H-Series: H700, H7000, H710, H7100
  - A-Series: A300, A3000, A310, A3100

    NOTE: A310, A3100, H710, and H7100, supports OneFS 9.11.0.0 or later.

- `isi_config_usb -mode {display,on,off}` is supported on some nodes running earlier releases. If you try running the command and receive an error, the command is not supported for the node and software combination. In that case, use the BIOS procedure above.

To disable USB boot on the local node:

```
isi_config_usb --mode off
reboot
```

To disable USB boot across the cluster, for all nodes that support the `isi_config_usb` command:

```
isi_config_usb --nodes all --mode off
isi cluster reboot --node-lnn all
```

To enable USB boot on the local node:

```
isi_config_usb --mode on
reboot
```

To enable USB boot across the cluster, for all nodes that support the `isi_config_usb` command:

```
isi_config_usb --nodes all --mode on
isi cluster reboot --node-lnn all
```

Create a login message

A login message appears as a separate box on the login page of the OneFS web administration interface. The message also appears at the end of the introductory text on the command-line interface after a user logs in.

A login message is a best practice. The login message can convey information, instructions, or warnings that a user should know before using the cluster.

NOTE: Login messages convey policy information and are typically written with a legal team.

For additional information and instructions for creating the login message, see the section "Login banner configuration."

Change password on backend switches

To ensure backend switch security, change the default password on backend switches.

PowerScale OneFS ships with hard coded default usernames and passwords for access to backend switches. The hard coded defaults in OneFS are due to the use of hard coded default credentials. For security, you should change the backend switch password to a value other than the default. To do so, you must change the password values on the switches and in OneFS.

NOTE: For complete switch security best practices, including changing passwords, see the vendor documentation for your switch environment.

OneFS stores the changed backend switch credentials in the OneFS Key Manager. If no values are stored in Key Manager, OneFS continues to use the shipped default credentials.

1. Change the password on the backend Dell Networking switches.
   a. Run the command for setting the user *admin*, and use a new password.

   ```
   OS10(config)# username admin password newpassword@1 role sysadmin
   ```

   b. Run the command for setting the user *linuxadmin*, and use a new password.

   ```
   OS10(config)# system-user linuxadmin password {clear-text-password | hashed-
   password}
   ```

   c. Save the new password.

   ```
   OS10(config)# exit
   OS10# write memory
   ```

   d. Repeat on each backend switch.

   NOTE: All switches must be configured to use the same credential values.

   NOTE: In a leaf-spine architecture:
   - Change the password on all the leaf modules.
   - It is not required to change the password on the spine modules. If you do change them, there are no negative effects.

2. Change the credentials in OneFS:
   a. Log in to any node in the OneFS cluster.
   b. Run this command:

   ```
   sudo isi_config_be_cred
   ```

   OneFS verifies that the new credentials are valid on all backend switches before successfully changing the values in Key Manager. For example:

   ```
   Accelerator9-1# sudo isi_config_be_cred
    Verifying credentials ...
    Switch credentials valid on int -a
    Switch credentials valid on int -b
   Credentials saved to Keymanager.
   Both isi_dump_fabric int -a | int -b commands are operational
   again.
   ```

3. Change the REST_USER password and store it in Key Manager:
   a. Log in to any node in the OneFS cluster.
   b. Run this command:

   ```
   curl -X PUT -k -u "REST_USER:<old_password>" -d '{"NewPassword": "<new_password>"}'
   "https://<IP_ADDRESS>/redfish/v1/Dnv/ChangePassword"
   ```

Example: `curl -X PUT -k -u "REST_USER:Admin@1234" -d '{"NewPassword": "Hello@12345"}' "https://100.104.87.220/redfish/v1/Dnv/ChangePassword"`

c. To store the new password in Key Manager, run this command:

```
sudo isi_config_be_cred
```

d. Enter the username as `REST_USER` and then enter the new password that was configured.

OneFS will verify that the new credentials are valid on all backend switches for `REST_USER` before changing the values in Key Manager.

```
clusternode-1# sudo isi_config_be_cred
Username:REST_USER
Password:
Do you want to continue? (y/n)
y
No validation error on int-a fabric
No validation error on int-b fabric
Verifying credentials ...
Switch credentials valid on int-a
Switch credentials valid on int-b
Credentials saved to Keymanager.
```

NOTE: If the `REST_USER` default password is not changed, the `isi_config_be_cred` script runs in the background to change the password to `D@111234`. Changing the `REST_USER` password avoids EEMI messages prompting to change the password, and avoids CELOG events for validation errors on DNOS switch for `REST_USER`.

Network connections to managed switches

Network connections to managed switches allow administrators to connect an Ethernet cable to a management module for debugging and modifying configuration.

Network connections to managed switches allow administrators to connect an Ethernet cable to a management module for debugging and modifying configuration. During normal operation, you should not connect any cable to this module, however there might be circumstances that require you to do so, such as forwarding switch logs to a remote server for a Support engagement.

To prevent potential network security breaches, only connect to a trusted network, and only allow trusted administrators access through an account with a changed password. Consider this user a "root" user. Do not create additional user accounts for untrusted users. When the Support engagement is complete, disable any accounts that are not in use (except for the admin account), and disconnect the Ethernet cable.

UEFI secure boot

UEFI secure boot verifies the authenticity of the OneFS software at every reboot of any node that enables the feature. If any of the cited checks fail, UEFI secure boot prevents the system from booting . Secure boot is turned off by default on PowerScale nodes.

When secure boot is enabled on a node, the node firmware uses a sha256 hash to check the authenticity of the OneFS software at every reboot. The firmware verifies the following items at each reboot:

- Checks whether kernel modules and operating system start-up files are altered.
- Checks whether the manifest was altered.
- Checks OneFS authenticity.

The OneFS software package is signed by default with a Dell Technologies encryption key. A separate installation package for secure boot is not required.

Consider the following to decide whether to enable secure boot:

- Secure boot is an optional feature that offers an enhanced layer of security to a data center.
- A PowerScale cluster can include nodes with secure boot enabled and nodes with secure boot disabled.
- Secure boot must be enabled individually on each node.

Secure boot is turned off by default. You can enable it through the BIOS during OneFS boot or reboot. Instructions for each node type follow. Also see Dell PowerScale OneFS: Security Considerations.

Supported node types and prerequisites for UEFI secure boot

UEFI secure boot is supported on the following node types when those nodes are running the required OneFS version and node firmware package (NFP).

Table 35. Required software and firmware for UEFI secure boot

Supported nodes	Required OneFS version	Required NFP	Required actions for using secure boot
A310, A3100, H710, H7100	9.11.0.0 or later	13.1 or later	1. If needed, upgrade OneFS and the NFP. 2. Enable secure boot.
A2000	9.3.0.0 or later	11.4 or later	1. If needed, upgrade OneFS and the NFP. 2. Enable secure boot.
A300, A3000 H700, H7000	9.3.0.0 or later	11.4 or later	1. If needed, upgrade OneFS and the NFP. 2. Enable secure boot.
The following nodes preexisting in a cluster: B100 F200, F600, F900 P100	9.3.0.0 or later	11.4 or later	1. If needed, upgrade OneFS and the NFP. 2. Manually change the BIOS. 3. Enable secure boot.
The following nodes shipped new with OneFS 9.4.0.0: B100 F200, F600, F900 P100	9.4.0.0 or later installed at the factory	11.4 or later	1. Enable secure boot. **NOTE:** The BIOS changes were performed at the factory.

Use the following references to prepare nodes for UEFI secure boot:

- To upgrade the OneFS version, see the *PowerScale OneFS Upgrade Guide*.
- To upgrade the NFP, see the firmware release notes:
  1. On the Dell Support site PowerScale page, click the Downloads tab.
  2. In the version box, select only the top-level button. Do not select a specific OneFS version.
  3. In the list of available downloads, click the name of the Node Firmware Package.
  4. Click **Related Content** to see the Release Notes.
- To make required changes to the BIOS on preexisting B100, F200, F600, F900, and P100 nodes, contact Customer Support.
- To enable (or disable) secure boot on any node, see the next section, Enable and disable UEFI secure boot.

Enable and disable UEFI secure boot

You can enable or disable secure boot in the BIOS during an initial boot up or a reboot.

1. Ensure that the nodes are running the required OneFS and NFP versions, as listed in Supported node types and prerequisites for UEFI secure boot.
2. (Optional but recommended) To prevent unauthorized disabling of secure boot, set a BIOS password on nodes that are enabled with secure boot. For detailed steps, see Set BIOS password for node physical security.

Using the BIOS user interface, perform the following procedure individually on each node for which you want to enable UEFI secure boot.

1. During firmware loading, **F2** to interrupt the loader.

   NOTE: If you see the `OK` prompt with a blinking cursor, you were too late. Type `reboot` to start over.

2. Select **Security** > **Secure boot**.
3. Set **secure boot** to **Enabled** or **Disabled**.
4. Disable CSM support on the A2000, A300, A3000, H700, and H7000 nodes.

   NOTE: This step is required for the listed nodes.

   a. Select **Advanced** > **CSM Configuration**.
   b. Set **CSM Support** to **Disabled**.
5. Select **Save**.
   The loading process proceeds.

Determine if secure boot is enabled

The EFI boot loader generates messages that describe whether secure boot is enabled or disabled.

When **secure boot is disabled**, the following settings are reported:

```
SecureBoot: 0, SetupMode: 0
```

When **secure boot is enabled**, the following settings are reported:

```
SecureBoot: 1, SetupMode: 0
```

To configure the Secure Boot setting in the BIOS for H710, H7100, A310, A3100:

1. Reboot the system.
2. `F2` to enter Setup
3. Select `System BIOS`.
4. Select `System Security`.
5. Select `Secure Boot`.
6. Select `Enabled` to enable Secure Boot or `Disabled` to disable Secure Boot.
7. `ESC` to return and exit.

Interpret secure boot verification messages

Secure boot issues messages indicating secure boot status and verification results.

Secure boot disabled

When secure boot is disabled, the following settings are reported:

```
SecureBoot: 0, SetupMode: 0
```

Those settings are followed by messages similar to:

```
/boot/manifest.rcerts: Validation failed, err = 54
Unverified <module-name>.ko
```

Those messages are normal when secure boot is disabled. The firmware cannot verify software.

Secure boot enabled, verification successful

When secure boot is enabled, the following settings are reported:

```
SecureBoot: 1, SetupMode: 0
```

Those settings are followed by messages indicating whether verification was successful or not. Successful verification messages look similar to:

```
verify loader.lua, cli.lua, config.lua, hook.lua, core.lua, color.lua,
password.lua, screen.lua
verify /boot/kernel.amd64/isi_glue_lz4.ko
```

Secure boot enabled, verification not successful

When secure boot is enabled, the following settings are reported:

```
SecureBoot: 1, SetupMode: 0
```

The following types of messages indicate failed verifications:

```
/boot/kernel.amd64/isi_glue_lz4.ko: sha256 hash != manifest hash
panic: cannot continue
Unverified /boot/lua/../manifest (Dell Technologies Inc.)
Startup error in /boot/lua/loader.lua:
LUA ERROR: cannot open /boot/lua/loader.lua: no error.
```

```
Unverified /boot/lua/../manifest (Dell Technologies Inc.)
Startup error in /boot/lua/loader.lua:
LUA ERROR: cannot open /boot/lua/loader.lua: no error.
```

The previous messages indicate a corrupted, changed, or attacked software package. Contact Dell Technologies Support.

Verify install package authenticity

Verify the authenticity of a software package before running an upgrade or patch.

On-cluster verification on OneFS 9.4.0.0 and later

The OneFS Catalog stores upgrade, patch, and DSP packages. All packages are securely stored as artifacts in the `/ifs/.ifsvar/catalog` directory, and each artifact has an ID that corresponds to the package SHA256 hash. The packages are verified against included certificates. The upgrade procedures use packages from the OneFS Catalog.

Administrators use the `isi upgrade catalog` command to interact with the OneFS Catalog. They can list the contents of the catalog, import and export packages, verify packages, and remove packages.

For usage instructions, see the OneFS Catalog section under the Cluster maintenance section in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

On-cluster verification on OneFS versions earlier than 9.4.0.0

The OneFS Catalog was introduced in OneFS 9.4.0.0. If you are upgrading from a version earlier than 9.4.0.0, the *PowerScale OneFS Security Configuration Guide* for OneFS 9.3.0.0 or earlier includes instructions for verifying an upgrade package.

Off-cluster verification

If your site requires verification before the packages are moved to the OneFS cluster, contact Dell Technologies Support for instructions.

Set a timeout for idle CLI sessions (CLI)

The timeout value is the maximum period after which an inactive CLI user session is terminated. This timeout applies to both SSH connections and serial console connections that are running directly in the defined shells.

For additional security, it is recommended that you also configure an idle SSH session timeout (see the *Set a timeout for idle SSH sessions* section of this guide). If you configure both timeouts, the shorter timeout applies to SSH sessions only.

NOTE: These changes take effect for all new shell logins for all existing and new users. The changes do not affect existing login sessions until the user logs out and logs in again.

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Create a backup directory by running the following command:

```
mkdir /ifs/data/backup/
```

3. Set the permissions on the backup directory to 700:

```
chmod 700 /ifs/data/backup
```

4. Check whether the `/usr/local/etc/profile` file exists on every node in the cluster:

```
isi_for_array 'test -f /usr/local/etc/profile || echo /usr/local/etc/profile \
missing on node `hostname`'
```

   If the file exists on every node in the cluster, there is no output. If the file does not exist on every node, the output displays which nodes do not contain the file.
5. Perform one of the following actions:
   - If the file exists on every node in the cluster, make a working copy and a backup copy in the `/ifs/data/backup` directory:
     a. Run this command:

```
cp /usr/local/etc/profile /ifs/data/backup/profile
```

     b. Check if a file with the name `profile.bak` exists in the backup directory.

     CAUTION: If so, decide if you can safely overwrite the existing file. To save the old backups, rename the new file with a timestamp or other identifier.

     c. Run this command:

```
cp /usr/local/etc/profile /ifs/data/backup/profile.bak
```

   - If the file does not exist on every node in the cluster, the integrity of the OneFS installation is in doubt. Stop here and contact Dell Technologies Support to check the OneFS installation on the node. This file is part of a normal installation, and you should understand how and why it was removed.
6. Open the `/ifs/data/backup/profile` file in a text editor.
7. Add the following lines at the end of the file, after the `# End Isilon` entry. Replace *<seconds>* with the timeout value in seconds. For example, a 10-minute timeout would be 600 seconds.

```
# Begin Security Best Practice
# Set shell idle timeout to <seconds> seconds
TMOUT=<seconds>
export TMOUT
readonly TMOUT
# End Security Best Practice
```

8. Confirm that the changes are correct. Then save the file and exit the text editor.
9. Check whether the `/usr/local/etc/zprofile` file exists, and then do one of the following things:

- If the file exists, run the following commands to create a working and a backup copy in the `/ifs/data/backup` directory:

```
cp /usr/local/etc/zprofile /ifs/data/backup/zprofile
```

```
cp /usr/local/etc/zprofile /ifs/data/backup/zprofile.bak
```

NOTE: If the `zprofile.bak` file name exists in the backup directory, decide whether to overwrite the existing backups or save the old backups. To save the old backups, rename the new file with a timestamp or other identifier.

- If the file does not exist, create it in the `/ifs/data/backup` directory:

```
touch /ifs/data/backup/zprofile
```

10. Open the `/ifs/data/backup/zprofile` file in a text editor.
11. Add the same lines that you added to the `/ifs/data/backup/profile` file, where *<seconds>* is the timeout value in seconds. Add these lines at the end of the file:

```
# Begin Security Best Practice
# Set shell idle timeout to <seconds> seconds
TMOUT=<seconds>
export TMOUT
readonly TMOUT
# End Security Best Practice
```

12. Confirm that the changes are correct. Then save the file and exit the text editor.
13. Set the permissions on both files to 644 by running the following command:

```
chmod 644 /ifs/data/backup/profile /ifs/data/backup/zprofile
```

14. Run the following two commands to copy the two files to the `/etc` directory on all the nodes in the cluster:

```
isi_for_array 'cp /ifs/data/backup/profile /usr/local/etc/profile'
```

```
isi_for_array 'cp /ifs/data/backup/zprofile /usr/local/etc/zprofile'
```

15. (Optional) Delete the working and backup copies from the `/ifs/data/backup` directory:

```
rm /ifs/data/backup/profile /ifs/data/backup/profile.bak \
/ifs/data/backup/zprofile /ifs/data/backup/zprofile.bak
```

Set a timeout for idle SSH sessions

The timeout value is the maximum period after which an inactive SSH session is terminated.

An idle SSH session is an unresponsive SSH session where the client and server are experiencing an interruption in SSH protocol data flow. Such an interruption is typically caused by network interruption. The steps described here do not apply to user inactivity. They also do not apply to connections to the cluster through a serial console.

For additional security that responds to user inactivity, it is recommended that you configure an idle CLI session timeout. See Set a timeout for idle CLI sessions (CLI).

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Configure SSH timeouts with the following commands:

```
isi_gconfig -t ssh-config client_alive_count_max=<count>
isi_gconfig -t ssh-config client_alive_interval=<interval>
isi ssh settings modify --tcp-keep-alive=<true | false>
```

For information about these configuration options, see the `ClientAliveCountMax`, `ClientAliveInterval`, and `TCPKeepAlive` sections of the manual page for `sshd_config`.

The `client alive` messages are sent after the SSH server detects that the SSH client is unresponsive. If `client_alive_count_max` is set to `0`, the system sends a `client alive` message and then immediately drops the connection.

3. Confirm the timeout values:

```
isi_gconfig -t ssh-config client_alive_count_max
isi_gconfig -t ssh-config client_alive_interval
isi ssh settings view
```

Forward audited events to remote server

The auditing and audit forwarding capabilities in OneFS are recommended. Auditing can detect many potential sources of data loss, including fraudulent activities, inappropriate entitlements, and unauthorized access attempts.

Forwarding audited events to a remote server has the following security benefits:

- You can scan the data for security issues on the remote server and avoid interfering with cluster operation or performance.
- You can send syslog output from multiple locations to the same remote server and run scanning software on all the logs in one location. This method may be easier and more convenient than trying to run scanning software on the cluster.
- When hackers access a system such as a PowerScale cluster, they try to erase their tracks. If audit information is forwarded to a remote server, the audit trail on the server is preserved, making identification and containment of the breach simpler.
- If the cluster node that contains the syslog events fails, you can access the information that was forwarded to the remote server for diagnosis and troubleshooting.

To forward protocol access auditing and system configuration changes to a remote server, follow these steps:

1. Enable auditing.
2. Send audited events to syslog.
3. Configure syslog forwarding.

For detailed instructions, see the Managing audit settings section in the "Auditing and Logging" chapter of the *PowerScale OneFS 9.13.0.0 CLI Administration Guide* or the "Auditing" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide*.

External to cluster firewall security

Use a firewall to limit access to the cluster to only those trusted clients and servers that require access. Allow restricted access only to ports that are required for communication. Block access to all other ports.

OneFS includes a host-based firewall that comes with predefined global policies. The global policies allow the OneFS default ports and block all others. You can also define custom policies. The firewall is disabled by default.

Dell Technologies recommends enabling the firewall and using the default policies, with adjustments as needed.

1. Ensure that the cluster uses a default SSH or HTTP port before enabling. The default firewall policies block all nondefault ports until you change the policies.
2. Enable the OneFS firewall.
3. Compare your cluster network port configurations against the default ports listed in the section "Network port usage."
4. Change the default firewall policies to accommodate any nondefault ports in use in the cluster.

   NOTE: The firewall policies do not automatically update when port configurations are changed.

5. Limit access to the OneFS Web UI to specific administrator terminals through an IP address. Another option is to isolate web-based access to a specific management network.

In addition to the OneFS firewall, you may use an external firewall as a defense-in-depth method.

For more information about the OneFS firewall, see the "Host-based firewall" section under "External networks" in the "Networking" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Disable OneFS services that are not in use

OneFS has some services that are safe to disable when they are not in use.

See Services that are safe to disable for a list of the services that should be disabled when not in use and instructions for disabling them.

Configure WORM directories using SmartLock

Use the SmartLock feature to create write-once read-many (WORM) directories to protect files from being modified for a specified retention period.

There are two options for SmartLock implementation:

- **Compliance mode**: This mode is designed for organizations that are legally required to comply with the United States Securities and Exchange Commission's (SEC) rule 17-a4(f).
- **Enterprise mode**: This mode is designed for organizations that have no legal requirement but want to use WORM technology to protect their data. SmartLock compliance mode commits files to a WORM state.

NOTE: WORM file access does not protect against hardware or file system issues. If the data on the cluster becomes unavailable, the WORM files are also unavailable. It is recommended that you also back up the cluster data to separate physical devices.

Back up cluster data

OneFS offers various backup options to preserve user and application data. These options protect data from accidental or malicious modification, deletion, or encryption (for example, through a ransomware attack).

To protect data, use local snapshots plus Network Data Management Protocol (NDMP) backups. If you have SyncIQ hardware already in place, you can use SyncIQ replication in place of NDMP.

Table 36. Back up options

Option	Required license	Description
NDMP backups	None	Back up and restore data through NDMP. From a backup server, you can direct backup and restore processes between the cluster and backup devices. Backup devices include tape devices, media servers, and virtual tape libraries (VTLs). Although this option does not make the original data more secure, it does provide a backup if the data is compromised or lost. It is recommended that you locate the external backup system in a different geographical area from the PowerScale cluster to protect against physical disasters.
Local snapshots	SnapshotIQ	Snapshots protect data against accidental deletion and modification by enabling you to restore deleted and modified files. Snapshots do not protect against hardware or file system issues. Snapshots reference data that is stored on a cluster. If the data on the cluster becomes unavailable, the snapshots are also unavailable. It is recommended that you also back up the cluster data to separate physical devices.
Replication to a secondary PowerScale cluster	SyncIQ	Replicate data from one PowerScale cluster to another. You can specify which files and directories to replicate. SyncIQ also offers automated failover and failback capabilities so that you can continue operations on the secondary cluster should the primary cluster become unavailable. While this option does not make the data more secure, it does provide a backup if the data is compromised or lost. It is recommended that you locate the secondary cluster in a different geographical area or media from the primary cluster to protect against physical disasters. It is also recommended that the secondary cluster has a different password from the primary cluster in case the primary cluster is compromised.
Datamover	SyncIQ	Datamover ensures that you have a consistent copy of your data on another PowerScale cluster or cloud platform. Datamover allows you to control the frequency of data transfers at scheduled times using policies. Similar to the SyncIQ module, you can transfer data at the directory level, while optionally excluding specific files and subdirectories from being transferred. The embedded Datamover feature provides data replication for file and object deployments on-premises or in the cloud. Datamover enables file-to-file transfers between PowerScale clusters using RPC and file-to-object copy transfers to S3 (ECS, AWS) and Azure cloud systems.

Use NTP time

Network Time Protocol (NTP) is recommended as the most consistent source for cluster time. In a Windows environment, it is recommended to use the Active Directory domain controller NTP service.

Use the OneFS web administration interface to configure NTP time service synchronization to an external time service.

NOTE: It is recommended that you point the cluster to an NTP server within the perimeter of your network environment.

For additional recommendations for using NTP time with SmartLock directories and SmartLock compliance mode, see the "File retention with SmartLock" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Specify an NTP time server

You can specify one or more Network Time Protocol (NTP) servers to synchronize the system time on the PowerScale cluster. The cluster periodically contacts the NTP servers and sets the date and time using information from the NTP servers.

1. Click **Cluster Management** > **General Settings** > **NTP**.
2. In the **NTP Servers** area, type the IPv4 or IPv6 address of one or more NTP servers. If you want to use a key file, type the key numbers in the field next to the server IP address.

   Click **Add Another NTP Server** if you are specifying multiple servers.
3. Optional: If you are using a key file for the NTP server, type the file path for that file in the **Path to Key File** field.
4. In the **Chimer Settings** area, specify the number of chimer nodes that contact NTP servers (the default is 3).
5. To exclude a node from chiming, type its logical node number (LNN) in the **Nodes Excluded from Chiming** field.
6. Click **Save Changes**.

Login, authentication, and privileges best practices

This section describes security best practice recommendations for configuring user logins, authentication, and access privileges.

Restrict root logins to the cluster

A strong security stance entails using the root account as little as possible.

Permitting SSH access through an unrestricted shell poses a significant security risk. Only highly privileged administrators should have unrestricted SSH access to the cluster. Root users should have UNIX shell access only.

You can use one or more of the following methods to restrict root access to the cluster:

- Use SmartLock compliance mode to completely remove root access to the cluster. This method is the most restrictive option. When you are logged in to a SmartLock compliance mode cluster through the compliance administrator account, you can perform administrative tasks through the `sudo` command. Using the `sudo` command provides an audit trail by logging all command activity to `/var/log/auth.log`.
- Disable root SSH access to the cluster. See Disable root SSH access to the cluster for instructions. You can still log in as root using other methods, such as console access or an RBAC-authorized account.
- Disable and prevent access to the root account by applying the `root-lockdown` hardening profile. For best practices, see Use Root Lockdown Mode. For instructions on applying RLM, see the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*
- Limit the number of people who know the root password by doing one or both of the following:
  - Assign admin users an RBAC role with only the privileges that they require to do their job.
  - If an admin user needs greater privileges than the RBAC role can provide, use privilege elevation to give them select root-level privileges.

Use Root Lockdown Mode

Best practices for using Root Lockdown Mode.

Root Lockdown Mode (RLM) ensures that protections that are enabled by other features cannot be overridden by the root account, by disabling and preventing access to the root account. Some best practices for using RLM are:

- Since RLM disables the root account, do not use the root account to apply or disable RLM. Instead, use any nonroot account with the ISI_PRIV_HARDENING privilege.
- Create separate administrative accounts to manage RLM. If access to these accounts is lost, the account of last resport (compadmin) can be used to change the cluster. RLM requires compadmin to be enabled and have a valid shell that is configured before applying RLM.
- Securely store the root password in the event RLM will be disabled.
- Always check the root-lockdown hardening report to determine if RLM is enabled. Some PAPI endpoints may improperly report that compliance mode is enabled while RLM is enabled.

For instructions on applying or disabling RLM, see the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Use RBAC accounts instead of root

Instead of using the root account, assign roles and privileges to users and groups as needed by using the role-based access control (RBAC) functionality.

The following RBAC best practices are recommended:

- Ensure that each administrator has a unique user account. Do not allow users to share accounts.
- For each user and group, assign the lowest level of privileges required.
- Use privilege elevation to assign select root-level privileges to specified users as needed.

Disable the root account for SSH sessions

If security procedures at your site require it, you can disable the root account for SSH sessions. If SSH access is still needed for other users, you can provide individual users or groups with SSH privileges.

See SSH security best practices for details about both procedures.

Privilege elevation: Assign select root-level privileges to nonroot users

A root account is necessary for some cluster administration purposes. For security reasons, the root privileges should be closely monitored.

Instead of providing the root account to administrators, you can elevate their privileges so that they can run selected root-level commands using `sudo`. Using the `sudo` command also provides an audit trail by logging all command activity to `/var/log/auth.log`.

NOTE: This procedure is not intended for use on clusters that are in SmartLock compliance mode. In SmartLock compliance mode, the `compadmin` account exists with the correct `sudo` infrastructure.

NOTE: Logged-in users are unaffected by the following changes. They must log out and log in again for the changes to take effect.

You can perform steps 1 to 5 below using the OneFS web interface. See the *PowerScale OneFS 9.13.0.0 Web Administration Guide*.

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Create a group to assign elevated privileges to, where *<groupname>* is the name of the group. This group must be in the local provider and System zone.

   ```
   isi auth groups create <groupname> --provider local --zone system
   ```

   For example, you can create a group that is named SPECIAL, as follows:

   ```
   isi auth groups create SPECIAL --provider local --zone system
   ```

3. (Optional) Verify that the users that you want to add to the SPECIAL group are already members of either the SystemAdmin or the SecurityAdmin role. Since these two roles have strong security privileges, this step ensures that the user has already been approved for a high level of access. To check whether the user is a member of the SystemAdmin or SecurityAdmin role, run the following two commands to list the members of those roles:

   ```
   isi auth roles members list SystemAdmin
   ```

   ```
   isi auth roles members list SecurityAdmin
   ```

4. Add an existing user to the group that has the elevated privileges.

```
isi auth groups modify <groupname> --add-user <username>
```

For example, to add a user who is named bob to the SPECIAL group:

```
isi auth groups modify SPECIAL --add-user bob
```

5. Confirm that the user is in the group:

```
isi auth groups members list <groupname>
```

6. Create a backup directory:

```
mkdir /ifs/data/backup/
```

7. Set the permissions on the backup directory to 700:

```
chmod 700 /ifs/data/backup
```

8. Make a working copy of the `/etc/mcp/override/sudoers` file in the backup directory:

```
cp /etc/mcp/override/sudoers /ifs/data/backup
```

9. Make a backup copy of the `/etc/mcp/override/sudoers` file in the backup directory:

```
cp /etc/mcp/override/sudoers /ifs/data/backup/sudoers.bak
```

NOTE: If a file with the same name exists in the backup directory, there are two options:

- Overwrite the existing file.
- Name the new file with a timestamp or other identifier. This option saves the old backups.

.

10. Open the `/ifs/data/backup/sudoers` file in a text editor and add the following entry:

```
# Begin Security Best Practices
%<groupname> ALL=(ALL) PASSWD: PROCESSES, SYSADMIN, ISI, ISI_ADMIN, ISI_SUPPORT, \
ISI_HWTOOLS, ISI_HARDENING
# End Security Best Practices
```

For example, the entry for the SPECIAL group is:

```
%SPECIAL ALL=(ALL) PASSWD: PROCESSES, SYSADMIN, ISI, ISI_ADMIN, ISI_SUPPORT, \
 ISI_HWTOOLS, ISI_HARDENING
```

NOTE: You can change the entry as described in the last bullet below.

This entry in the `sudoers` file provides the following security benefits:

- It requires the user to preface all root-level commands with `sudo`.
- It requires the user to type the user password the first time that they run a `sudo` command in a session. The system caches these credentials for five minutes. After five minutes, the user must retype the password to run `sudo` commands.
- A comma-separated list of command sets (called `command aliases`) is assigned to the group (for example, PROCESSES, SYSADMIN, ISI, and so on). These command aliases include all the diagnostic and hardware tools available, making the privileges equivalent to the `compadmin` role in a SmartLock compliance mode cluster. You can modify the line to include fewer command aliases, or different command aliases, to allow only the privileges that you want the group to have. To see the available command aliases and the lists of commands that are in each alias, review the `/etc/mcp/templates/sudoers` file.

CAUTION: Do not modify the `/etc/mcp/templates/sudoers` file.

11. Confirm that the changes are correct. Then save the file and exit the text editor.
12. Copy the `/ifs/data/backup/sudoers` file to the `/etc/mcp/override/sudoers` file.

```
cp /ifs/data/backup/sudoers /etc/mcp/override/sudoers
```

13. To identify the commands that are now available to the user, log in as the user and run the following command:

```
sudo -l
```

The output looks similar to the following.

```
User bob may run the following commands on <hostname>:
    (ALL) NOPASSWD: ISI_PRIV_SYS_TIME, (ALL) /usr/sbin/isi_upgrade_logs, (ALL)
     ISI_PRIV_ANTIVIRUS, (ALL) /usr/sbin/isi_audit_viewer, (ALL)
     ISI_PRIV_CLOUDPOOLS, (ALL) ISI_PRIV_CLUSTER, (ALL) ISI_PRIV_DEVICES, (ALL)
     ISI_PRIV_EVENT, (ALL) ISI_PRIV_FILE_FILTER, (ALL) ISI_PRIV_FTP, (ALL)
     ISI_PRIV_HARDENING, (ALL) ISI_PRIV_HDFS, (ALL) ISI_PRIV_HTTP, (ALL)
     ISI_PRIV_JOB_ENGINE, (ALL) ISI_PRIV_LICENSE, (ALL) ISI_PRIV_NDMP, (ALL)
     ISI_PRIV_NETWORK, (ALL) ISI_PRIV_NFS, (ALL) ISI_PRIV_NTP, (ALL)
     ISI_PRIV_QUOTA, (ALL) ISI_PRIV_REMOTE_SUPPORT, (ALL) ISI_PRIV_SMARTPOOLS,
     (ALL) ISI_PRIV_SMB, (ALL) ISI_PRIV_SNAPSHOT, (ALL) ISI_PRIV_SNMP, (ALL)
     ISI_PRIV_STATISTICS, (ALL) ISI_PRIV_SYNCIQ, (ALL)
     ISI_PRIV_VCENTER, (ALL) ISI_PRIV_WORM
    (ALL) PASSWD: /bin/date, /sbin/sysctl, /sbin/shutdown, /bin/ps,
     /usr/sbin/ntpdate, /sbin/ifconfig, /usr/sbin/newsyslog, /usr/sbin/nfsstat,
     /usr/sbin/pciconf, /usr/sbin/tcpdump, (ALL) /usr/bin/isi_classic,
     /usr/bin/isi_for_array, /usr/bin/isi_gconfig, /usr/bin/isi_job_d,
     /usr/bin/isi_vol_copy
```

- The privileges listed after `(ALL) NOPASSWD` are the privileges for the assigned RBAC role. Those privileges do not require the user to retype the password.
- The commands listed after `(ALL) PASSWD` are the `sudo` commands that are available to the user. Those commands require the user to type the user password after typing the command.

NOTE: It could happen that the privilege elevation includes commands that the user already has privilege to through an existing RBAC role. In that case, the user is not required to retype the password to access those commands.

14. Verify that everything looks correct.
15. (Optional) Delete the working and backup copies from the `/ifs/data/backup` directory:

```
rm /ifs/data/backup/sudoers /ifs/data/backup/sudoers.bak
```

CAUTION: The `ISI_PRIV_JOB_ENGINE` privilege allows the user to run jobs through the Job Engine. These jobs run as root. Under specific circumstances, a user could use some of these jobs to delete entire sections of OneFS. Also, a user could potentially acquire ownership of files that they otherwise would not have permission to access. Care must be exercised when granting this privilege. The recommendation is to only grant this level to trusted users.

Restrict authentication by external providers

OneFS provides certain system-defined accounts for the file provider in the System zone (also known as the System file provider). OneFS relies on the identity of these system-defined accounts to ensure normal cluster functionality and security. The identity includes the UID, GID, shell, passwords, privileges, permissions, and so on. Problems can arise if an external authentication provider authenticates a user or group with the same name as one of these system-defined accounts.

The OneFS mapping service consolidates all user or group accounts with the same name from all authentication providers into a single access token. This token identifies the user and controls access to directories and files. For each access zone in OneFS, there is an ordered list of providers.

CAUTION: When an identity is found in more than one authentication provider, the provider that comes earliest in the list acts as the source for that identity. If the external provider comes earlier in the list than the System file provider, the externally provided identity overrides the system-defined identity. In this case, unintended users could gain inappropriate access to the cluster and appropriate administrators could lose access to the cluster.

OneFS provides the following cluster management accounts for the System file provider:

User accounts

- `root`
- `admin`
- `compadmin`
- `remotesupport`
- `ese`
- `ftp`
- `insightiq`
- `www`
- `nobody`
- `everyone`
- `git_daemon`
- `isdmgmt`

Group accounts

- `wheel`
- `admin`
- `remotesupport`
- `ese`
- `ftp`
- `guest`
- `video`
- `ifs`
- `nobody`
- `git_daemon`

To prevent externally provided identities from overriding the system-defined identities, use the `unfindable-users` and `unfindable-groups` options of the `isi auth ads|ldap|nis` CLI command. Run the command for each user or group account that you do not want to be overridden. These accounts can be in any access zone. They can include the system-defined accounts that are described here and accounts that you create. For details on how to use the commands, see the *PowerScale OneFS 9.13.0.0 CLI Command Reference*.

On the Web UI, to view the users and groups that the System file provider manages, click **Access** > **Membership & Roles**. Click either the **Users** or the **Groups** tab. Select **System** from the **Current Access Zone** list, and select **FILE: System** from the **Providers** list.

Alternatively, you can run one of the following commands on the command-line interface:

```
isi auth users list --provider='lsa-file-provider:System'
```

```
isi auth groups list --provider='lsa-file-provider:System'
```

Use secure connections to LDAP server

By default, communications between the PowerScale cluster and an LDAP server are not secure and occur in plain text.

To make communications more secure, configure the LDAP provider to use TLS when it communicates with the LDAP server. For maximum security, you can also configure the LDAP provider to require strict verification of the certificates that are used to establish the secure connection.

The parameters to set these configurations are valid in either of the following commands:

- `isi auth ldap create` used to create the LDAP provider.
- `isi auth ldap modify` used to change a previously created LDAP provider.

The following information describes only the parameters in those commands that are related to TLS. There are more parameters that are used to create or modify an LDAP provider. For complete syntax and usage information, see the *PowerScale OneFS 9.13.0.0 CLI Command Reference* .

Parameters for configuring TLS

This section describes the parameters that configure TLS.

Table 37. Parameters for configuring TLS

Purpose	Syntax and description
Enable or disable TLS.	`--require-secure-connection={yes|no}` Where: • `yes`—Encrypts all communication between the cluster and the LDAP server using TLS. This verifies that the certificates are valid and not expired. • `no`—Sends all communication between the cluster and the LDAP server in plain text. The same result occurs when the parameter is never specified on the cluster.
Set a valid certificate authority file.	`--certificate-authority-file <path/to/cacert/file>` This parameter is required when `--require-secure-connection=yes`. Provide the path to the root certificate file.
Do not allow TLS errors.	`--ignore-tls-errors={yes|no}` The recommended setting for security best practices is `no`. The default setting is `no`. If TLS is enabled and this parameter is set to `yes`, the LDAP provider uses TLS regardless of errors. TLS may issue certificate verification errors, but the LDAP provider continues to use the certificate and TLS communication. TLS logs the errors.

Enforce additional verifications of certificates received from the LDAP server in the TLS handshake.	`--tls-revocation-check-level={strict|allowNoSrc|allowNoData| none}`
	
	Where:
	• `strict`—Requires valid and current revocation information for all certificates that are received from the LDAP server in the TLS handshake. If any certificates do not comply, the LDAP provider ends the TLS session.
	• `allowNoSrc`—Accepts certificates from the LDAP server if no revocation retrieval information is available for them. A warning is logged for such certificates. Otherwise, the LDAP provider ends the TLS session if either of the following is true for any certificate:
	  ○ It is not possible to retrieve the revocation information.
	  ○ The revocation state indicates that the certificate is not valid and current.
	• `allowNoData`—Accepts certificates from the LDAP server if it is not possible to retrieve the revocation state. A warning is logged for such certificates. If a revocation state is successfully retrieved, it must indicate that the certificate is valid and current. Otherwise the LDAP provider ends the TLS session.
	• `none`—No revocation checking is performed. This is the default setting.

(Optional) Define the location of revocation information.	`--ocsp-server-uris <uri-list>` Where: `<uri-list>` is a comma-separated list of URIs. Use this parameter to provide the location of revocation information to the LDAP provider. If this option is not set, the LDAP provider looks for the Online Certificate Status Protocol (OCSP) responder URI within the certificates.

Examples for configuring TLS

For specific command usage details, see the *PowerScale OneFS 9.13.0.0 CLI Command Reference*

The following example creates an LDAP provider that requires TLS encryption.

```
isi auth ldap create myLDAPProvider \
        --require-secure-connection=yes  \
        --ignore-tls-errors=no \
        --certificate-authority-file  /ifs/.ifsvar/modules/isi_certs/system/ca/zone_1/
certs.cer \
        --base-dn dc=<domain>,dc=com \
        --server-uris <ldap server>
        <other required and optional settings>
```

The following example adds TLS encryption to a previously created LDAP provider.

```
isi auth ldap modify myLDAPProvider \
        --certificate-authority-file /path/to/root/ca/file.cer \
        <other required and optional settings>
```

The following example creates an LDAP provider that requires TLS encryption and strict certificate validation of certificates that are received from the LDAP server. The OCSP URIs are not provided, so the LDAP provider uses information in the certificate.

```
isi auth ldap create myLDAPProvider \
        --require-secure-connection=yes  \
        --ignore-tls-errors=no \
        --certificate-authority-file /path/to/root/ca/file.cer \
        --tls-revocation-check-level=strict  \
        --base-dn dc=<domain>,dc=com \
        --server-uris <ldap server>
        <other required and optional settings>
```

The following `isi auth ldap modify` example adds an OCSP responder URI for validating certificates from the LDAP server.

```
isi auth ldap modify myLDAPProvider \
        --ocsp-server-uris http://ocsp.entrust.net/ocsp  \
        <other required and optional settings>
```

Set password policy

Password complexity increases the number of possible passwords that an attacker must check before the correct password is guessed.

You can configure the local password policy and specify the default for each setting using the `isi auth local modify` command.

For the detailed procedure and descriptions of each password policy setting, see the "Managing local users and groups" section in the "Authentication" chapter of the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

SNMP security best practices

If you plan to monitor cluster statistics, it is recommended that you use SNMPv3. If you do not plan to monitor cluster statistics, you should leave the SNMP service disabled.

For more information about how to configure SNMP, see the Cluster monitoring section in the "General cluster administration" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Use SNMPv3 for cluster monitoring

The recommended configuration for network devices is SNMP Version 3 with authentication and privacy, using FIPS 140-2 validated cryptography.

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Configure SNMPv3 by running `isi snmp settings modify` with the following arguments, where:
   a. `--snmp-v3-access yes` - Enables SNMPv3.
   b. `--snmp-v3-read-only-user <string>` - Sets the read-only user for SNMP v3 read requests.
   c. `--snmp-v3-auth-protocol {SHA | MD5}` Set the authentication protocol. For maximum security, use SHA.
   d. `--snmp-v3-priv-protocol {AES | DES}` Set the privacy protocol. For maximum security, use AES.
   e. `--snmp-v3-security-level {noAuthNoPriv | authNoPriv | authPriv}` - Specifies the cryptography to use for monitoring the cluster. The value `authPriv` is the most secure.
   f. `--set-snmp-v3-password` - Change the SNMPv3 authentication password so that it is not the default value. The CLI prompts you for the new password value.
   g. `--set-snmp-v3-priv-password` - Change the SNMPv3 privacy password so that it is not the default value. The CLI prompts you for the new password value. The value must be complex and greater than or equal to 8 bytes in length. Otherwise, you receive an error.
3. (Recommended) Disable SNMPv1 and SNMPv2 access:

```
isi snmp settings modify --snmp-v1-v2c-access no
```

For more information about SNMP configuration, see the "SNMP monitoring" section in the "General cluster administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Keep SNMP disabled except for SNMP cluster monitoring

The SNMP service is disabled by default.

If you enable cluster monitoring as described previously in Use SNMPv3 for cluster monitoring, that procedure enables SNMP. SNMP must remain enabled for cluster monitoring to work.

Disabling SNMP on the cluster does not affect the sending of SNMP trap alerts from the cluster to an SNMP server.

Change default community string for SNMPv2

If SNMPv2 is needed, change the default community string (I$ilonpublic) to something different.

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Edit the <string> in the `gconfig` file:

```
isi snmp settings modify --read-only-community=NEWCOMMUNITY --service=true
```

3. Disable and then enable `snmpd`:

```
isi services -a snmp disable
isi services -a snmp enable
```

SSH security best practices

Choose from the following practices depending on what is best for your environment.

NOTE: For security reasons, it is not suggested connecting to a virtual node over SSH. If SSH access is required for your workflow, use a restricted shell to access nodes directly.

It is crucial to limit unrestricted command-line access to only trusted users to safeguard against emergent threats. Unauthorized access can lead to manipulation of system settings, data breaches, and outages. Stringent access control for all user levels is a fundamental aspect of maintaining system integrity and security.

Restrict SSH access to specific users and groups

By default, only the SecurityAdmin, SystemAdmin, and AuditAdmin roles have SSH access privileges. You can grant SSH access for specific cluster management tasks to users and groups that have more restricted roles.

To perform these steps, you must log in as a user who has the `ISI_PRIV_ROLE` privilege. That privilege allows you to create roles and assign privileges.

To grant SSH access to users and groups using custom roles:

1. Open a secure shell (SSH) connection to any node in the cluster and log in.
2. Create a custom role:

   ```
   isi auth roles create <role_name>
   ```

   Where *<role_name>* is the custom role.

3. Add the `ISI_PRIV_LOGIN_SSH` privilege to the role:

   ```
   isi auth roles modify <role_name> --add-priv ISI_PRIV_LOGIN_SSH
   ```

4. Add a user or a group to the role with one of these commands:

   ```
   isi auth roles modify <role_name> --add-user <user_name>
   ```

   ```
   isi auth roles modify <role_name> --add-group <group_name>
   ```

   Where:

   - *<user_name>* is an existing username.
   - *<group_name>* is an existing group name.

Disable root SSH access to the cluster

Disabling root SSH access to the cluster prevents attackers from accessing the cluster by brute-force hacking the root password.

After disabling root SSH access, you can still log in as root by performing one of the following actions:

- Physically connect to the cluster using a serial cable, and log in as root.
- Open a secure shell (SSH) connection to any node in the cluster, and log in using an RBAC-authorized account. At the command prompt, type **`login root`** and press ENTER. Type the root password when prompted. This method has the security benefit of requiring two passwords (the user password and the root password).

You can also elevate the privileges for select users to give them access to specified root-level commands. See Restrict SSH access to specific users and groups.

1. If needed, you can ensure that there is at least one user with SSH privileges on the cluster.
   - On the command-line interface, run the following command and confirm that there is at least one nonroot user listed:

     ```
     isi auth roles view SecurityAdmin
     ```

   - On the web administration interface, click **Access > Membership and Roles > Roles** . Select the **view/edit** button in the **SecurityAdmin** section.
2. Open a secure shell (SSH) connection to any node in the cluster and log in as a user that has `ISI_PRIV_AUTH` privileges.

   NOTE: Users with that privilege have the right to "Configure external authentication providers."

3. Run the following command to disable the ability of the root user to log in through an SSH session:

```
isi ssh settings modify --permit-root-login False
```

Manage SSH host keys

By default, only the SecurityAdmin, SystemAdmin, and AuditAdmin roles have SSH access privileges. You can grant SSH access for specific cluster management tasks to users and groups that have more restricted roles.

When the Open SLL configuration is modified, the SSH host key is automatically regenerated. This ensures that the cryptographic identity of the server remains valid and reflects the current configuration. Users should delete the old host key entry from the local `known_hosts` file when reconnecting.

Data-access protocols best practices

To prevent unauthorized client access through unused or unmonitored protocols, disable protocols that you do not support. For those protocols that you do support, limit access to only the clients who require it.

Use a trusted network to protect files and authentication credentials that are sent in cleartext

The security between a client and the PowerScale cluster depends on the protocol. Some protocols send files and authentication credentials in cleartext.

Use the following methods to protect your data and authentication information from interception:

- Implement a compensating control, as described in the following sections.
- Ensure that the path between clients and the cluster is on a trusted network.

Even if you implement a compensating control, a trusted network provides an additional layer of security.

Use compensating controls to protect authentication credentials that are sent in cleartext

Some protocols send authentication credentials in cleartext. You can use compensating controls to enable more secure authentication.

Protocols that send authentication credentials in cleartext include:

- FTP
- HDFS (and WebHDFS)
- HTTP
- NFS

Compensating controls for cleartext authentication in OneFS include:

- Kerberos authentication (supported by some protocols)
- NTLM authentication (supported by some protocols)
- Secure impersonation on HDFS
- TLS enabled on the FTP service
- SSH tunneling (Wraps an existing nonsecure protocol and moves all communication to an encrypted channel.)
- The OneFS API sends all authentication credentials over TLS.

Use compensating controls to protect files that are sent in cleartext

Files specific to the web administration interface are sent over TLS. Files specific to `/ifs` are sent differently depending on the protocol. You can use compensating controls to increase the security of files that are sent in cleartext.

Protocols that may send `/ifs` files in cleartext include:

- FTP
- HDFS (and WebHDFS)
- HTTP
- NFS
- Some versions of SMB

Compensating controls for data transmission in OneFS include:

- The OneFS API (all file access communication is sent over TLS).
- SSH tunneling (wraps an existing nonsecure protocol and moves all communication to an encrypted channel).

Initial Sequence Numbers (ISNs) through TCP connections

During a TCP connection, the `syncache` is used to limit the amount of data that the kernel tracks until the connection is established. If the `syncache` is full, the kernel switches to `syncookies` to prevent DOS attempts through a SYN flood attack. However, these cached values could be susceptible to attacks on the initial sequence numbers (ISN) which, by default, are based on source and destination ports. If you disable `syncookies`, OneFS generates more random ISNs. The ISNs are generated every fifteen seconds.

The `syncookies` setting is enabled by default. To disable it (to generate random ISNs), use the `sysctl` command to set `net.inet.tcp.syncookies` to zero:

```
sysctl net.inet.tcp.syncookies=0
```

FTP best practices

The FTP service is disabled by default. It should remain disabled unless your site requires it.

Only use FTP for anonymous FTP. Do not use FTP for authenticated communication on an insecure network.

If you must use FTP, it is recommended that you enable TLS on the FTP service, and then connect with an FTP client that supports TLS. For configuration instructions for enabling TLS on FTP, see FTP security.

HDFS best practices

The HDFS service on the cluster is disabled by default, and should remain disabled unless you intend to support it.

If you support Hadoop, enable the HDFS service:

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Run the following command:

   ```
   isi services hdfs enable
   ```

Limit HDFS access to specific access zones

HDFS is configured on a per-access-zone basis. Disable HDFS access from any access zones that do not require it.

NOTE: Disabling HDFS for an individual access zone prevents HDFS access to that zone. It does not disable the HDFS service on the cluster.

1. From the OneFS web administration interface, click **Protocols > Hadoop (HDFS) > Settings**.

2. From the **Current Access Zone** list, select the access zone for which you want to disable HDFS.
3. In the **HDFS Service Settings** area, clear the checkbox for **Enable HDFS service for *zonename* zone**.
4. Click **Save**.

HDFS is disabled for the selected access zone.

General HDFS security

The following security features for HDFS are recommended:

- Use HDFS with Kerberos if the network is not trusted.
- Use the HDFS Transparent Data Encryption (TDE). This feature requires that you enable Kerberos authentication. For more information about this recommendation, see the PowerScale OneFS HDFS Reference Guide.
- Use TLS with WebHDFS.

HTTP file protocol best practices

HTTP is disabled by default.

You can enable HTTP to support the HTTP file protocol for file sharing.

- When the file protocol service is enabled, the server uses port 80.
- When encryption is enabled, port 443 is used and requests to 80 are redirected to 443.

For file access on a nonsecure network, use only HTTPS.

HTTP allows access only to files that are readable by others. However, those files are readable without requiring a valid user account on the cluster. If you do not support the HTTP file protocol, HTTP should remain disabled on the cluster.

Beginning in OneFS 9.5.0.0, all data path operations are separated from all control path operations. Control path services, including the OneFS WebUI service, use different ports than the data path services.

The OneFS WebUI service always uses HTTPS and port 8080. This service is enabled by default. HTTPS is always available for accessing the web administration interface even when HTTP is disabled.

If it is required at your site, you may disable the OneFS WebUI service. For information about the various HTTP and HTTPS services and how to enable and disable them individually, see HTTP services.

Enable HTTP file protocol

The HTTP file protocol service name is `apache2`.

1. To enable HTTP on the web administration interface:
   a. Click **Protocols** > **HTTP Settings** .
   b. In the Service area, select **Enable HTTP**.
   c. Click **Save Changes**.
2. To enable HTTP on the command line:
   a. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
   b. Run the following command:

```
isi http settings modify --service=enabled
```

NFS best practices

NFS data access to the cluster is disabled by default.

To support NFS, you must:

1. Enable the service.
2. Create one or more directories to share.

   A default `/ifs` directory exists in the file system. Create subdirectories under it to share.

NOTE: Dell Technologies does not recommend sharing the entire `/ifs`.

3. Create exports for the directories to share.

   No default NFS exports are created automatically. Create the export for each directory to share over the front-end protocol.

   NOTE: It is recommended to create the exports in subdirectories of `/ifs`, not in `/ifs` itself.

For details about these tasks, see the "File sharing" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

If you support NFS, recommendations for limiting access are provided in the following sections. If you do not support NFS, the service should remain disabled on the cluster.

Use Kerberos on nontrusted networks

Use NFS with Kerberos if the network is not trusted.

Limit access to NFS exports

Use the OneFS web administration interface or command-line interface to control which IP addresses or machines can access NFS shares and to configure their access levels.

For details, see the "File sharing" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Limit access to parent directories

To hide parent directories of NFSv4 exports, use NFS aliases.

For details, see the "NFS aliases" section of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Enable export hiding

OneFS includes a way to hide export paths from unauthorized hosts.

By default, when a client connects to an export path that does not exist, it receives a `No such file or directory` error. This exposure of nonexported paths might not be wanted and can be changed to an `access denied` error.

Export hiding prevents unauthorized hosts from viewing the mounts. To enable export hiding:

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Set the value of `MountdDeniedStatusOnNotAllowed` to 1 as follows:

```
isi_gconfig
registry.Services.lwio.Parameters.Drivers.nfs.MountdDeniedStatusOnNotAllowed=1
```

3. Restart NFS on the cluster by disabling and then reenabling the service.

   NOTE: The restart action could cause loss of service for NFS clients that are connected when the restart is conducted.

   From the WebUI, go to **Protocols > UNIX sharing (NFS) > Global settings**. Clear the box for **NFS export service enabled** to disable the service. Recheck the box for **NFS export service enabled** to reenable the service.

When export hiding is disabled, hosts receive the following error when they try to mount an export that does not exist.

```
mount.nfs: mounting 10.20.30.4:/ifs/data/testdir failed, reason given by server: No such
file or directory
```

When export hiding is enabled, hosts receive the following error when they try to mount an export that does not exist.

```
mount.nfs: access denied by server while mounting 10.20.30.4:/ifs/data/testdir
```

Disable `showmount` command

The `showmount` command allows an NFS client to see all exports on a cluster. An option was introduced to prevent off-node clients from performing `showmount -e`.

To enable the option to prevent off-node clients from performing `showmount -e`:

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Modify the setting and refresh NFS using the following two commands:

   ```
   isi_gconfig
   registry.Services.lwio.Parameters.Drivers.nfs.MountdAllowForeignShowmountERequests=0

    isi_for_array '/usr/likewise/bin/lwsm refresh nfs'
   ```

   To revert to the default setting, use these commands:

   ```
   isi_gconfig
   registry.Services.lwio.Parameters.Drivers.nfs.MountdAllowForeignShowmountERequests=1

    isi_for_array '/usr/likewise/bin/lwsm refresh nfs'
   ```

When export hiding is enabled, unauthorized hosts receive the following error when they try to list exports using `showmount -e <cluster-domainname>`.

```
"rpc mount export: RPC: Authentication error; why = Client credential too weak"
```

SMB best practices

SMB data access to the cluster is disabled by default.

To enable data access through SMB, you must enable the service, create shares, and manage access through ACLs and other identity management features.

Enable SMB and create shares

See SMB security for important practices and procedures regarding SMB. They include:

- Enable SMB only if needed.
- Ensure that SMB1 is disabled.
- Create shares in subdirectories of `/ifs`, rather than in `/ifs` itself.

Also see the note about using the SMB Guest account in Preloaded accounts.

If you support SMB, it is recommended that you limit access to the shares. That process is described in the following section.

Limit access to SMB shares

It is possible to restrict access to a share by using the share access control list (ACL). However, it is preferred to configure the share ACL to grant full control to everyone. Then use file system ACLs to manage access to individual files and directories.

Limiting the entire share to read or read/write permissions can complicate management because these restrictions override existing more permissive permissions on individual files and directories. For example, if the share is configured for read-only access, but an individual file is configured for read/write, only read access is granted to the file. More permissive permissions on the share do not override more restrictive permissions that exist on individual files and directories.

For details, see the "File sharing" chapter in the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

More about access control lists (ACLs)

See Access Control Lists on PowerScale OneFS. This paper provides an overview of ACLs in OneFS. It describes how OneFS works internally with various ACLs to provide multiprotocol access.

More about authentication, identity management, and authorization (AIMA)

For information about the expected security workflow regarding SMB data access, see PowerScale OneFS: Authentication, Identity Management, and Authorization. This paper describes the OneFS AIMA stack, OneFS multiprotocol data access, and the unified permissions model.

Nontrusted network

Use signing or encryption if the network is not trusted.

More SMB security

Use these practices for more SMB security:

- Kerberos authentication is preferred over NTLM.
- Join the cluster to the AD domain or the Kerberos realm.
- Access the cluster through the DNS name. Do not access it directly using the IP.
- Only use AD or Kerberos accounts for SMB access. Do not use accounts from the local provider or file provider.

SMB signing

SMB is used for file sharing.

In addition, SMB is a transport protocol for Remote Procedure Call (RPC) services such as:

- SAMR (modify local users).
- LSAR (look up local users).
- SRVSVC (modify SMB shares configuration).

SMB and the Distributed Computing Environment Remote Procedure Call (DCERPC) services, which use SMB for transport, are susceptible to man-in-the-middle attacks. In a man-in-the-middle attack, an attacker intercepts and potentially alters communication between parties who believe that they are in direct communication with one another.

SMB signing can prevent man-in-the-middle attacks within the SMB protocol. However, SMB signing has performance implications and is disabled by default on PowerScale clusters. Customers should carefully consider whether the security benefits of SMB signing outweigh the performance costs. The performance degradation SMB signing causes can vary widely depending on the network and storage system implementation. Performance can be verified only through testing in your network environment.

If SMB signing is needed, you can perform one of the following actions:

- Enable SMB signing for all connections. This action is the easiest and most secure solution. However, this option causes significant performance degradation because it requires SMB signing for both file transfer and control path DCERPC connections.
- Enable SMB signing for the control path only. This solution requires that clients use SMB signing when accessing all DCERPC services on the cluster, but does not require signed connections for the data path. This option requires you to enable four advanced parameters on the cluster. With these parameters enabled, the OneFS server rejects any nonsigned IPC request that a client initiates. If clients are configured not to sign, they can access files over SMB but cannot perform certain other functions, such as SMB share enumeration.

Enable SMB signing for all connections

To enable SMB signing for all connections, perform the following steps.

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Run the following command:

```
isi smb settings global modify --require-security-signatures yes
```

3. Configure the client to enable SMB signing. SMB signing may already be enabled by default. See the client documentation for instructions.
4. Restart SMB by running the following commands:

```
isi services smb disable
isi services smb enable
```

Enable SMB signing for the control path only

To enable SMB signing for the control path only, perform the following steps.

1. Open a secure shell (SSH) connection to any node in the cluster and log in as root.
2. Run the following four commands. The value of `1` at the end of the command enables the parameter:

```
isi_gconfig \
registry.Services.lsass.Parameters.RPCServers.dssetup.RequireConnectionIntegrity=1
```

```
isi_gconfig \
registry.Services.lsass.Parameters.RPCServers.lsarpc.RequireConnectionIntegrity=1
```

```
isi_gconfig \
registry.Services.lsass.Parameters.RPCServers.samr.RequireConnectionIntegrity=1
```

```
isi_gconfig \
registry.Services.srvsvc.Parameters.RequireConnectionIntegrity=1
```

```
isi_gconfig \
registry.Services.lsass.Parameters.RPCServers.wkssvc.RequireConnectionIntegrity=1
```

3. To review the value for each of the settings, run each command again omitting the settings at the end. In the response, the value at the end of the line indicates whether the parameter is enabled `(1)` or disabled `(0)`.

   For example:

```
isi_gconfig \
registry.Services.lsass.Parameters.RPCServers.dssetup.RequireConnectionIntegrity

registry.Services.lsass.Parameters.RPCServers.dssetup.RequireConnectionIntegrity
(uint32) = 0
```

4. Configure the client to require SMB signing. This step is required for the DCERPC services to function. See the client documentation for instructions.
5. Restart SMB by running the following commands:

```
isi services smb disable
isi services smb enable
```

Web interface security best practices

This section provides recommendations for limiting access to the OneFS web administration interface, configuring security headers, and strengthening the posture of TLS. You can perform one or more of these procedures depending on what is best for your environment.

Replace the TLS certificate

PowerScale clusters ship with a self-signed TLS certificate. It is recommended that you replace the default TLS certificate with a certificate signed by a trusted Certificate Authority.

For instructions, see the Certificates section in the "General Cluster Administration" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Remove persistent older versions of TLS

Some upgrade paths or manual customer updates can cause an older TLS version to persist. If your current configuration at `/etc/mcp/templates/webui_httpd.conf` contains `+TLSv1` or `+TLSv1.1`, install the latest security patches. For more information, see the Current PowerScale OneFS Patches document on the Customer Support site.

CloudPools best practices

The following section provides best practices for configuring CloudPools.

Restricting access to untrusted users

This section outlines why access should only be granted to trusted users.

General points about CloudPools

- CloudPools is a feature that allows storing cluster data on a network accessible to external servers.
- ISI_PRIV_CLOUDPOOLS or ISI_PRIV_CLOUDPOOLS_ACCOUNTS are the privileges that restrict the ability to create or modify CloudPools configuration.
- CloudPools endpoints return diagnostic information in case a failure occurs. This information is essential for an administrator to troubleshoot the connection they are trying to configure.
- Network storage appliances can be configured at many different URLs.
- It may be possible for an administrator with ISI_PRIV_CLOUDPOOLS to learn about the existence of network servers accessible from a OneFS node by misusing these endpoints.

See Login, authentication, and privileges best practices for more information for configuring user logins, authentication, and access privileges.

7

Miscellaneous Configuration and Management Elements

Any miscellaneous configuration changes to OneFS are not recommended. Only use OneFS security and roll-up patches to modify your environment, and check your manifest to verify the installation. For links to Dell Security Advisories (DSAs) and related patches, see Security resources .

Topics:

- Preventing malware
- Specialized security devices
- Intel microarchitectural mitigations

Preventing malware

CAUTION: When an ICAP or CAVA anti-virus server is configured, the network between the cluster and the anti-virus server must be a trusted network. The file contents are visible to people and programs that have access to the network packets.

CAVA requires that the SMB protocol is enabled. Scan requests and heartbeats travel between the cluster and CEE or CAVA servers using HTTP on port 12228. The anti-virus software reads and updates files over SMB (port 445) using the configured IP pool addresses.

For clusters using SmartSync with ICAP, it is highly recommended to rescan replicated or restored data before using it.

For information about preventing malware using either ICAP or CAVA, see the "anti-virus" chapter of the *PowerScale OneFS 9.13.0.0 Web Administration Guide* or the *PowerScale OneFS 9.13.0.0 CLI Administration Guide*.

Specialized security devices

OneFS supports several security device integration and configuration options.

OneFS supports multifactor authentication (MFA) using the DUO 2FA for authentication over SSH.

MFA is a system access control method that grants access to a user who has successfully presented several separate pieces of evidence to an authentication mechanism. Typically, authentication uses at least two of the following categories:

- Knowledge (something they know).
- Possession (something they have).
- Inherence (something they are).

MFA enables the LSASS daemon to require and accept multiple forms of credentials other than a username and password combination for some forms of authentication.

For more information, see the following sections in the "Authentication" chapter in the *PowerScale OneFS CLI Administration Guide*:

- Multifactor authentication (MFA)
- SSH Authentication and Configuration section (contains MFA Prerequisites).

Intel microarchitectural mitigations

PowerScale incorporates microarchitectural mitigations from Intel. Some mitigations are implemented as tunable options that may be enabled or disabled by default.

Background

In early 2018, researchers discovered several side-channel vulnerabilities in Intel processors, including vulnerabilities named Spectre and Meltdown. Later, new variants of these and other vulnerabilities against Intel processors and their memory caches were announced. Intel releases fixes, also known as mitigations, to these vulnerabilities on a regular quarterly cadence. Dell Technologies implements the mitigations into PowerScale.

To prevent potential attacks, Dell Technologies recommends that you install the most recent node firmware packages (NFP) and software patches for your PowerScale hardware and software. Some vulnerabilities are addressed with operating system fixes. Other vulnerabilities occur in the BIOS and are addressed in NFP fixes that directly update the system firmware. You are encouraged to consume all fixes regardless of how tightly you control your login environment.

How to tune

To make a temporary change to a tunable, type:

```
sysctl <component.subcomponent.name>=<value>
```

The value remains in effect until you reboot. The reboot loads the default.

To make a permanent change, add the tunable to `/etc/mcp/override/sysctl.conf`. On bootup, values in that file override the defaults.

Informational commands

It can be difficult to determine which value turns a mitigation on or off. Sometimes, a `0` value indicates on and in other cases, the `0` value indicates off.

The informational commands that are listed in the sections below interpret whether the mitigation is on (active) or off (inactive). The informational output also shows you the set value.

Tunable mitigations

A tunable option is provided for mitigations that may affect performance. You can enable or disable these mitigations. Make your choices by assessing your vulnerability to risk against performance needs.

NOTE: Risks exist when nonadmin users are allowed to run arbitrary code. If you do not allow SSH access by nontrusted users, you can safely disable all the following mitigations, restoring performance with no security risk.

Enabling the restricted CLI for accounts with the `ISI_PRIV_LOGIN_SSH` or the `ISI_PRIV_LOGIN_CONSOLE` privileges is another mitigation that prevents users from being able to run arbitrary code.

The following table describes the tunable mitigations in PowerScale, their default state, associated informational command, and tuning options.

Table 38. Tunable mitigations

Name	Description and instructions

Speculative Store Bypass (SSB)	`# sysctl hw.spec_store_bypass_disable`
	`hw.spec_store_bypass_disable: 0`
	`/* mitigation off (0) by default */`
	
	`# sysctl hw.spec_store_bypass_disable_active`
	`hw.spec_store_bypass_disable_active: 0`
	`/* informational command*/`
	
	To enable this mitigation, change `hw.spec_store_bypass_disable`. Dell Technologies recommends using `2`, which allows the system to automatically determine when to apply the mitigation. Valid settings are:
	• `2`—Auto
	• `1`—On
	• `0`—Off

Microarchitectural Data Sampling (MDS)	`# sysctl hw.mds_disable`
	`hw.mds_disable: 0`
	`/* mitigation off (0) by default */`
	
	`# sysctl hw.mds_disable_state`
	`hw.mds_disable_state: inactive`
	`/* informational command */`
	
	To enable this mitigation, set `hw.mds_disable` to `1`. That setting verifies whether the processing data segment is readable or writable from the current privilege level. It is the recommended setting.

Spectre v2	For Spectre v2, the mitigation is on by default.
	
	`# sysctl hw.ibrs_disable`
	` hw.ibrs_disable: 0`
	`/* Mitigation on (0) by default*/`
	
	`# sysctl hw.ibrs_active`
	`hw.ibrs_active: 1`
	`/* informational command  */`
	
	To disable this mitigation, set `hw.ibrs_disable` to `1`. However, Dell Technologies recommends the default setting.

Meltdown	`# sysctl vm.pmap.pti`
	` vm.pmap.pti: 1 | 0`
	`/* Mitigation on or off by default.*/`
	`/* See note.*/`
	
	NOTE: This value can be on or off by default. The software automates the setting of this value. The value is determined by whether the hardware itself or the microcode already completely mitigates the issue.
	
	Because the software analyzes the hardware requirement regarding the setting of this value, it is recommended that you leave the default setting. However, if your environment does not require local nonroot logins and the default setting is 1, you can safely change it to 0.
	The meltdown mitigation is tuned in a different way from the other mitigations that are described above. To change:
	
	1. On each node in the cluster, do the following:
	  a. Edit the `/boot/loader.conf` file.

Table 38. Tunable mitigations (continued)

Name	Description and instructions
	b. Under the Kernel tunables heading, add the following line: `vm.pmap.pti="0"` 2. Reboot the cluster for the change to take effect.
Other mitigations	All other recent changes are enabled by default and are not tunable.

8

Glossary

Topics:

- Terminology

Terminology

The following terms and abbreviations describe some of the features and technology of the PowerScale OneFS system and PowerScale cluster.

Access-based enumeration (ABE)	In a Microsoft Windows environment, ABE filters files and folders to show only the files that the user has permissions to access on a file server.
Access control entry (ACE)	An element of an access control list (ACL) that defines access rights to an object (like a file or directory) for a user or group.
Access control list (ACL)	A list of access control entries (ACEs) that provide information about the users and groups allowed access to an object.
ACL policy	Defines which access control methods are enforced when a user accesses a file on a system that is configured for multiprotocol access to file systems. Access control methods are: NFS permissions and Windows ACLs. The ACL policy is set using the web administration interface.
Authentication	The process for verifying the identity of a user trying to access a resource or object, such as a file or a directory.
Certificate Authority (CA)	A trusted third party that digitally signs public key certificates.
Certificate Authority Certificate	A digitally signed association between an identity (a Certificate Authority) and a public key. The host uses the certificate to verify digital signatures on public key certificates.
Command-line interface (CLI)	An interface for entering commands through a shell window to perform cluster administration tasks.
Dell Technologies connectivity services	A secure support system that includes 24x7 remote monitoring of a PowerScale cluster. With permission, it provides remote access for Dell Technologies Support personnel to gather cluster data and troubleshoot issues. Dell Technologies connectivity services replace Secure Remote Services (SRS) as the primary service path for PowerScale and OneFS.
Digital certificate	An electronic ID issued by a certificate authority that establishes user credentials. It contains: ● The user identity (a hostname) ● A serial number ● Expiration dates ● A copy of the public key of the certificate holder—The public key is used to encrypt messages and digital signatures. ● A digital signature from the certificate-issuing authority, so recipients can verify that the certificate is valid.
Directory server	A server that stores and organizes information about users and resources on a system network and allows network administrators to manage user access to the resources. X.500 is the best-known open directory service. Proprietary directory services include Microsoft Active Directory.
Group Identifier (GID)	A numeric value used to represent a group account in a UNIX system.
Hypertext Transfer Protocol (HTTP)	The communications protocol used to connect to servers on the World Wide Web.

Hypertext Transfer Protocol Secure (HTTPS)	HTTP over TLS. All network traffic between the client and server system is encrypted. In addition, HTTPS provides the option to verify server and client identities. Typically, server identities are verified and client identities are not.
Kerberos	An authentication, data integrity, and data-privacy encryption mechanism that is used to encode authentication information. Kerberos co-exists with NTLM and provides authentication for client/server applications using secret-key cryptography.
Lightweight Directory Access Protocol (LDAP)	An information-access protocol that runs directly over TCP/IP. LDAP is the primary access protocol for Active Directory and LDAP-based directory servers. LDAP Version 3 is defined by Proposed Standard documents in Internet Engineering Task Force (IETF) RFC 2251.
LDAP-based directory	A directory server that provides access through LDAP. Examples of LDAP-based directory servers include OpenLDAP and SUN Directory Server.
Network File System (NFS)	A distributed file system that provides transparent access to remote file systems. NFS allows all network systems to share a single copy of a directory.
Network Information Service (NIS)	A service that provides authentication and identity uniformity across local area networks and allows you to integrate the cluster with your NIS infrastructure. Designed by Sun Microsystems, NIS can be used to authenticate users and groups when they access the cluster.
OneFS API	A RESTful HTTP-based interface that enables cluster configuration, management, and monitoring functionality, and enables operations on files and directories.
OpenLDAP	The open-source implementation of an LDAP-based directory service.
Public Key Infrastructure (PKI)	A means of managing private keys and associated public key certificates for use in Public Key Cryptography.
Role-based Access Control (RBAC)	RBAC grants the rights to perform particular administrative actions to users who have authenticated to a cluster. Security Administrators create roles, assign privileges to the roles, and then assign members to the roles.
Secure Connect Gateway (SCG)	A gateway for proactive, automated issue detection, case creation and notification, analytics-based recommendations, and predictive analysis failure detection for server hard drives and backplanes. SCG offers remote access and secure, two-way communication between Dell Technologies and the customer environment for accelerated issue resolution. Both Dell Technologies connectivity services and Secure Remote Services can use SCG to connect a cluster to Dell Technologies Support.
Secure Remote Services (SRS)	Enables 24x7 proactive, secure, high-speed remote monitoring and repair for many Dell Technologies products. SRS requires a secure connect gateway for connection. Use the latest version of the secure connect gateway when configuring SRS. **NOTE:** Dell Technologies connectivity services replace SRS. SRS has reached end-of-service-life. It is recommended that OneFS clusters use Dell Technologies connectivity services and migrate from SRS immediately to avoid service disruption.
Secure Sockets Layer (SSL)	A security protocol that provides encryption and authentication. SSL encrypts data and provides message and server authentication. SSL also supports client authentication when required by the server.
Security Identifier (SID)	A unique, fixed identifier represents a user account, user group, or other secure identity component in a Windows system.
Server Message Block (SMB)	A network protocol used by Windows-based systems that allows systems within the same network to share files.
Simple Network Management Protocol (SNMP)	A protocol that can be used to communicate management information between the network management stations and the agents in the network elements.
Transport Layer Security (TLS)	The successor protocol to SSL for general communication authentication and encryption over TCP/IP networks.
User Identifier (UID)	Alphanumeric value used to represent a user account in a UNIX system.
X.509	A widely used standard for defining digital certificates.

A

Links to security standards

The following references provide more information about security standards.

- Common Criteria
- DISA
- DoD Public SRG\STIG Downloads
- FIPS 140-2
- MITRE CVE
- NIST CCSS
- NIST SP 800-53